Fabrikam Lettings Ltd

Microsoft 365 tenant review

TENANT
Fabrikam Lettings Ltd

PRIMARY DOMAIN
fabrikam.example

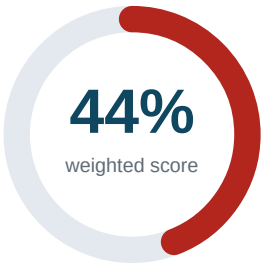
TENANT ID
c0ffee00-1111-2222-3333-444455556666

REVIEW DATE
17/10/2026

REVIEWED BY
Review Engineer (engineer@reviewer.example)

REPORT VERSION
Tool v1.4.1

1. Executive summary



Red

112 checks assessed: 15 pass, 77 warning, 20 fail

25
Licensed users
Enabled, licensed members

88%
MFA capable
22 of 25 users

5
Global admins
Recommended 2 to 4

3
Guests
External accounts

25
Mailboxes
2 shared

10
Intune devices
1 non-compliant

4
Defender devices
2 discovered, not onboarded

48.8%
Secure Score
312 of 640 points

5
Spare licences
Paid, unassigned

7
Unused licensed features
11 more partly used

22%
CIS v7.0.0
29 of 130 assessed controls met

26%
CISA SCuBA
24 of 92 assessed controls met

26%
Azure score
9 fail, 18 warning (see Azure)

14%
Server score
20 fail, 7 warning (see Servers)

Overview

Fabrikam Lettings Ltd's Microsoft 365 tenant was reviewed on 17/10/2026 against 131 checks across 15 areas. The weighted score is 44% (Red). Of the checks assessed, 20 failed, 77 need attention and 15 passed. 16 high-severity issues should be addressed first. Estimated remediation effort for all failed and warning items is about 353.0 hours (47.1 days).

The tenant already has licences for features that are not being used. Not used: 7. Partly used: 11. Setting these up is estimated at 36.5 days (see Opportunities).

Against the published benchmarks the tenant meets: CIS v7.0.0 22% (29 of 130 assessed controls, 15 to check manually); CISA SCuBA 26% (24 of 92 assessed controls, 6 to check manually) (see Benchmarks).

Azure was reviewed separately (2 subscriptions): the Azure score is 26%, with 9 failed and 18 needing attention (see Azure).

Servers were reviewed separately (6 systems from collected server data): the server score is 14%, with 20 failed and 7 needing attention (see Servers).

What needs doing

Must do
39 items
Start within 2 weeks
About 17.5 days

Should do
16 items
Within 3 months
About 5 days

Could do
96 items
Within 6 months
About 25 days

Use what you already pay for
18 features
After the fixes above
About 36.5 days

39 must-do items should be started within two weeks (about 17.5 days), 16 should-do items within three months (about 5 days) and 96 could-do items within six months (about 25 days). In total this is about 47.5 days of engineer time, or roughly 25 weeks at 2 engineer days a week. 12 of the must-do and should-do items are quick wins of an hour or less. A further 18 licensed features you already pay for could be put to use (about 36.5 days). See the action plan.

Top priorities

When	What good looks like	What we found	Effort
Must do	Windows servers run a supported version	1 of 5 Windows servers is out of support; 1 more loses support within six months.	2.5 days
Must do	Microsoft Defender for Cloud protects servers and data services	3 Defender plans are not on for resources in use, including Defender for Servers in 1 subscription. The plans in Fabrikam Dev could not be read (the account needs Security Reader or Reader there).	3 hours
Must do	Licensed users are registered for MFA	88% of 25 enabled licensed users are MFA capable (3 not capable).	4 hours
Must do	Privileged AD groups are small and protected	Domain Admins is too large (7 members; two to four is recommended).	3 hours
Must do	SPF records are valid	Mail domains with SPF problems: 1 of 2.	1 hour
Must do	Compliance policies cover every enrolled platform	No assigned compliance policy for: Android	4 hours
Must do	Devices are onboarded to Defender for Endpoint	Onboarded devices: 4. Intune managed Windows and macOS devices: 4 of 6 onboarded (66.7%).	4 hours
Must do	Linux servers run a supported release and are	The only Linux server is out of support or missing security updates.	1.5 days

When	What good looks like	What we found	Effort
	patched		
Must do	No retired Basic SKU public IPs or load balancers	1 public IP address still uses the retired Basic SKU.	4 hours
Must do	No guest accounts hold admin roles	Admin role assignments held by guests: 1.	30 minutes

Results by area

Area	RAG	Fail	Warning	Pass	Info or manual
Active Directory	Red	5	2	1	0
Applications	Amber	0	3	1	1
Autopilot and enrolment	Amber	0	2	0	0
Azure governance and cost	Red	1	7	0	1
Azure resilience	Red	2	3	0	0
Azure security	Red	6	8	0	1
Compliance	Amber	0	2	1	0
Email authentication	Red	3	1	1	1
Exchange Online	Red	2	11	6	1
Governance	Not rated	0	0	0	1
Hyper-V	Amber	1	1	0	0
Identity and access	Red	4	16	3	2
Intune and devices	Red	3	7	1	1
Intune configuration health	Amber	0	4	0	0
Intune connections	Red	1	2	1	0
Licensing	Amber	0	4	0	1
Linux servers	Red	3	1	0	0
Microsoft Defender XDR	Red	3	5	0	1
Microsoft Purview	Amber	0	4	0	1

Area	RAG	Fail	Warning	Pass	Info or manual
Microsoft Secure Score	Amber	1	0	0	0
Permissions	Amber	0	1	0	1
Privileged access	Red	2	3	0	1
SharePoint and OneDrive	Amber	0	5	1	3
Teams and groups	Amber	0	1	0	4
VMware	Not rated	0	0	0	2
Windows security configuration	Amber	1	6	0	0
Windows servers	Red	11	3	0	1

Licensed but not used

Status	Feature	Licensed users	Current use
Not used	Self-service password reset	24	Enabled for SSPR: 0 of 24 licensed users; registered: 21.
Not used	Dynamic groups	24	Dynamic membership groups: 0.
Not used	Universal Print	24	Printers registered in Universal Print: 0.
Not used	Sensitivity labels	24	Sensitivity labels: 0; active label policies: 0.
Not used	Online archiving	24	User mailboxes with an active archive: 0 of 22; mailboxes over 40 GB without an archive: 1.
Not used	Device-based Conditional Access	22	Enabled policies requiring a compliant or joined device: 0 (0 for all users).
Not used	Teams Phone	2	Users licensed for Teams Phone: 2; numbers assigned to users: 0; other assigned numbers: 0.
Partly used	Retention policies	25	Active retention policies: 1; workloads covered org-wide: Exchange.

2. Action plan

This plan turns the findings into work, grouped by what it protects and ordered by urgency. Must do items are serious gaps to fix first, should do items are important improvements, and could do items are good practice. Effort is the estimated engineer time to make each change; it is for planning only and does not include time for agreeing changes, telling staff or testing with Fabrikam Lettings Ltd.

Must do
39 items
Start within 2 weeks
About 17.5 days

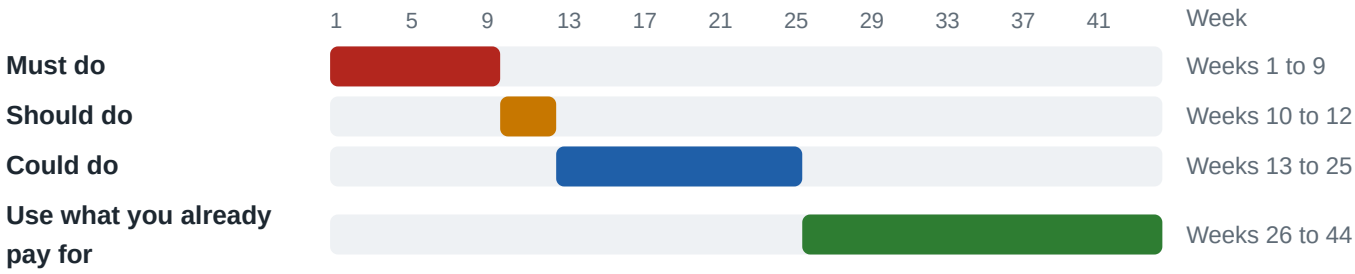
Should do
16 items
Within 3 months
About 5 days

Could do
96 items
Within 6 months
About 25 days

Use what you already pay for
18 features
After the fixes above
About 36.5 days

39 must-do items should be started within two weeks (about 17.5 days), 16 should-do items within three months (about 5 days) and 96 could-do items within six months (about 25 days). In total this is about 47.5 days of engineer time, or roughly 25 weeks at 2 engineer days a week. 12 of the must-do and should-do items are quick wins of an hour or less. A further 18 licensed features you already pay for could be put to use (about 36.5 days).

Indicative timeline



Based on 2 engineer days a week. With more engineer time the phases can overlap and finish sooner. Some licensed features overlap with the fixes, so that work may take less time once the earlier phases are done.

1 Must do: start within 2 weeks

Serious gaps that leave the business open to attack, data loss or disruption today. These should be fixed first.

Patch, protect and back up servers

About 5.5 days

Why it matters. Servers hold your most important data and systems. Servers that are out of support, unpatched, unprotected or not backed up are the most common way ransomware gets in and causes lasting damage.

Windows servers run a supported version — 2.5 days
We found: 1 of 5 Windows servers is out of support; 1 more loses support within six months.

Windows servers are patched and rebooted — 4 hours
We found: 1 of 5 servers is missing security updates.

Windows servers have working EDR and antivirus — 2 hours
We found: 1 of 5 servers has no EDR.

Remote management is not exposed or weakly protected — 2 hours
We found: 1 of 5 servers allows weakly protected remote access.

SMBv1 is disabled and SMB signing is required — 2 hours

We found: SMBv1 is enabled on 1 server; signing is not required on 2 servers.

Local administrator accounts are managed — 3 hours

We found: 1 of 3 member servers has unmanaged local administrator accounts.

Servers are backed up — 2 hours

We found: 1 server has not completed a Windows Server Backup in the last two days.

No out-of-support server software — 1.5 days

We found: 4 items of out-of-support software were found.

WHAT YOUR STAFF WILL NOTICE

Servers may need short, planned restarts outside working hours.

WHAT WE NEED FROM YOU

Agree a maintenance window, and budget for replacing any servers that are out of support.

Secure your Azure services

About 2.5 days

Why it matters. Cloud servers and services that are open to the internet, or have no security monitoring, are a frequent target for attackers.

Microsoft Defender for Cloud protects servers and data services — 3 hours

We found: 3 Defender plans are not on for resources in use, including Defender for Servers in 1 subscription. The plans in Fabrikam Dev could not be read (the account needs Security Reader or Reader there).

Management ports are not open to the internet — 2 hours

We found: 1 rule in use allows management or database ports from the internet.

Servers run a supported operating system — 1.5 days

We found: 3 servers are out of support. 1 more server is on extended security updates or loses support within six months.

Azure servers are onboarded to Defender for Endpoint — 3 hours

We found: 2 of 3 running servers are not onboarded to Defender for Endpoint.

Storage accounts block public access and require TLS 1.2 — 2 hours

We found: 1 of 2 storage accounts allows anonymous access, HTTP or old TLS.

WHAT YOUR STAFF WILL NOTICE

No change for staff.

WHAT WE NEED FROM YOU

Confirm which Azure services must be reachable from the internet.

Protect sign-ins and accounts

About 1.5 days

Why it matters. Most attacks start with a stolen or guessed password. These changes make it much harder for anyone to get into a staff account, even if they have the password.

Licensed users are registered for MFA — 4 hours

We found: 88% of 25 enabled licensed users are MFA capable (3 not capable).

All administrators are registered for MFA — 1 hour

We found: Admin accounts not MFA capable: 1 of 7.

Users cannot consent to applications — 1 hour

We found: Users can consent to any application for any delegated permission.

Directory synchronisation is healthy — 2 hours

We found: Last sync 16/10/2026 10:31 (30 hours ago).

WHAT YOUR STAFF WILL NOTICE

Staff may be asked to set up an authenticator app and could be prompted to sign in again on their devices.

WHAT WE NEED FROM YOU

Agree a date to tell staff, and confirm any shared or emergency accounts that need different treatment.

Secure Active Directory

About 2 days

Why it matters. Active Directory controls sign-in to every PC and server. A weakness here can let one compromised account take over the whole network.

Privileged AD groups are small and protected 3 hours

We found: Domain Admins is too large (7 members; two to four is recommended).

No accounts open to Kerberos and delegation attacks 4 hours

We found: 2 high-risk account settings found (3 more to review).

Domain password and lockout policy is strong 2 hours

We found: The domain password or lockout policy is weak: minimum length 8, no account lockout, history 12.

Domain controllers are hardened 3 hours

We found: Both domain controllers need hardening.

WHAT YOUR STAFF WILL NOTICE

Mostly no change. A few old accounts may be disabled and some service accounts given new passwords.

WHAT WE NEED FROM YOU

Confirm which old accounts and service accounts are still needed.

Stop others sending email as you

About 3 hours

Why it matters. SPF, DKIM and DMARC records prove your email is genuine. Without them, criminals can send convincing emails that look as if they come from you, to your staff, customers and suppliers.

SPF records are valid 1 hour

We found: Mail domains with SPF problems: 1 of 2.

DKIM signing is enabled for every mail domain 1 hour

We found: Email domains not DKIM signing: 1 of 2.

DMARC is published and enforced 1 hour

We found: Domains without DMARC: 2; not enforcing: 1.

WHAT YOUR STAFF WILL NOTICE

No change for staff.

WHAT WE NEED FROM YOU

Access to your DNS provider, and a list of other services that send email for you (for example invoicing or marketing systems).

Secure laptops, desktops and phones

About 2 days

Why it matters. Devices hold company data and are used to sign in. Managing, encrypting and updating them protects that data if a device is lost, stolen or infected.

Compliance policies cover every enrolled platform 4 hours

We found: No assigned compliance policy for: Android

Windows devices are encrypted 4 hours

We found: Windows devices reporting as not encrypted: 2 of 6.

Windows devices run a supported version 4 hours

We found: Windows devices: 6; on Windows 10: 1; on Windows 11 below the minimum build: 1.

WHAT YOUR STAFF WILL NOTICE

Devices may restart for updates, and staff may be asked to enrol phones or accept new settings.

WHAT WE NEED FROM YOU

Agree a small pilot group first, then a date for everyone else.

Detect and respond to threats

About 2 days

Why it matters. Security tools only help if they are switched on, cover every device and someone acts on their alerts.

Devices are onboarded to Defender for Endpoint 4 hours

We found: Onboarded devices: 4. Intune managed Windows and macOS devices: 4 of 6 onboarded (66.7%).

No critical vulnerabilities with public exploits 1.5 days

We found: Software with critical vulnerabilities: 2 (2 with public exploits). Software with high or critical vulnerabilities: 3.

Security incidents are triaged and resolved 2 hours

We found: Incidents in the last 90 days: 2. Open: 1 (1 high severity). High-severity incidents open for more than 7 days: 1.

WHAT YOUR STAFF WILL NOTICE

No change for staff.

WHAT WE NEED FROM YOU

Confirm who should receive security alerts, including out of hours.

Patch and harden Linux servers

About 2 days

Why it matters. Linux servers often run websites, databases and file transfers that face the internet. Keeping them patched and locked down stops them becoming a way in.

Linux servers run a supported release and are patched — 1.5 days

We found: The only Linux server is out of support or missing security updates.

Linux SSH and accounts are hardened — 2 hours

We found: The only Linux server allows risky SSH or account access.

Linux servers have EDR, a firewall and audit logging — 3 hours

We found: The only Linux server has no EDR.

WHAT YOUR STAFF WILL NOTICE

Servers may need short, planned restarts outside working hours.

WHAT WE NEED FROM YOU

Agree a maintenance window and who owns each server.

Make sure Azure can recover

About 7 hours

Why it matters. Backups and protection against accidental deletion mean a mistake or a ransomware attack does not become a lasting outage.

No retired Basic SKU public IPs or load balancers — 4 hours

We found: 1 public IP address still uses the retired Basic SKU.

Virtual machines are backed up — 3 hours

We found: 2 of 4 virtual machines are not protected by Azure Backup, and 1 more has not backed up recently.

WHAT YOUR STAFF WILL NOTICE

No change for staff.

WHAT WE NEED FROM YOU

Confirm how much data you could afford to lose and how quickly systems must be back.

Lock down administrator access

About 30 minutes

Why it matters. Administrator accounts can change or delete anything. Keeping them few in number and well protected limits the damage if one is compromised.

No guest accounts hold admin roles — 30 minutes

We found: Admin role assignments held by guests: 1.

WHAT YOUR STAFF WILL NOTICE

Only IT administrators are affected.

WHAT WE NEED FROM YOU

Confirm who genuinely needs administrator access.

Strengthen email security

About 1 hour

Why it matters. Email is the most common way criminals reach staff, through phishing and harmful attachments. These settings block more threats and stop email being quietly forwarded outside the business.

Mailbox forwarding is reviewed — 1 hour

We found: Mailboxes forwarding mail: 1 (1 to external addresses).

WHAT YOUR STAFF WILL NOTICE

Little change for staff. Some suspicious messages will be held in quarantine instead of reaching inboxes.

WHAT WE NEED FROM YOU

Tell us about any automatic forwarding to outside addresses that the business relies on.

Keep device management working

About 1 hour

Why it matters. Device management relies on certificates and connections to Apple and Google. If these lapse, company phones and tablets can no longer be managed or wiped, and fixing it can mean re-enrolling every device.

Apple MDM push certificate is valid — 1 hour

We found: The Apple MDM push certificate expires in 20 days (06/11/2026). Renew it with Apple ID it.fabrikam@personal.example.

WHAT YOUR STAFF WILL NOTICE

No change for staff if this is done before the expiry date.

WHAT WE NEED FROM YOU

Access to the Apple or Google account that was used to set these up.

Control Azure access and cost

About 2 hours

Why it matters. Clear ownership, budgets and removing unused resources stop surprise bills and limit who can change live systems.

Subscription owners are limited and not guests — 2 hours

We found: 4 privileged role assignments at subscription or management group level (2 to users directly, 1 to service principals, 1 to guests).

WHAT YOUR STAFF WILL NOTICE

No change for staff.

WHAT WE NEED FROM YOU

Agree a monthly Azure budget and who should be alerted.

2 Should do: within 3 months

Important improvements that close real risks. Plan these into the next three months.

Secure laptops, desktops and phones

About 1.5 days

Why it matters. Devices hold company data and are used to sign in. Managing, encrypting and updating them protects that data if a device is lost, stolen or infected.

Windows LAPS policy manages local administrator passwords — 2 hours

We found: Assigned LAPS policy: Windows LAPS. Passwords are backed up to Microsoft Entra ID, rotated every 90 days.

BitLocker policy requires encryption and escrows recovery keys — 3 hours

We found: BitLocker encryption is required (policy: BitLocker), but no assigned policy makes devices save recovery keys to Entra ID before encrypting.

Attack surface reduction rules are in block mode — 4 hours

We found: 7 rules configured: 4 in block mode, 3 in audit, warn or off. 2 of the three standard protection rules are not blocked.

Windows Firewall is enforced on every profile — 2 hours

We found: No assigned policy turns on Windows Firewall.

WHAT YOUR STAFF WILL NOTICE

Devices may restart for updates, and staff may be asked to enrol phones or accept new settings.

WHAT WE NEED FROM YOU

Agree a small pilot group first, then a date for everyone else.

Protect sign-ins and accounts

About 2 hours

Why it matters. Most attacks start with a stolen or guessed password. These changes make it much harder for anyone to get into a staff account, even if they have the password.

Legacy authentication is blocked — 2 hours

We found: Legacy authentication block is in report-only mode: CA002 Block legacy authentication

WHAT YOUR STAFF WILL NOTICE

Staff may be asked to set up an authenticator app and could be prompted to sign in again on their devices.

WHAT WE NEED FROM YOU

Agree a date to tell staff, and confirm any shared or emergency accounts that need different treatment.

Control connected apps

About 3 hours

Why it matters. Apps connected to your accounts can often read email and files. Reviewing them, and requiring approval for new ones, stops data being handed to unsafe apps without anyone noticing.

High-risk application permissions are reviewed — 3 hours

We found: Applications with high-risk application permissions: 2.

WHAT YOUR STAFF WILL NOTICE

Staff will need approval before connecting new apps to their work account.

WHAT WE NEED FROM YOU

Confirm which connected apps are used for business.

Secure Active Directory

About 5 hours

Why it matters. Active Directory controls sign-in to every PC and server. A weakness here can let one compromised account take over the whole network.

LAPS covers domain computers — 3 hours

We found: LAPS covers 53.4% of computers in the weakest domain.

Directory recovery and krbtgt hygiene — 2 hours

We found: fabrikam.local: AD Recycle Bin off; krbtgt password 1461 days old; machine account quota 10; domain functional level Windows2012R2Domain.

WHAT YOUR STAFF WILL NOTICE

Mostly no change. A few old accounts may be disabled and some service accounts given new passwords.

WHAT WE NEED FROM YOU

Confirm which old accounts and service accounts are still needed.

Lock down administrator access

About 1 hour

Why it matters. Administrator accounts can change or delete anything. Keeping them few in number and well protected limits the damage if one is compromised.

Between two and four Global Administrators — 1 hour

We found: Global Administrators: 5.

WHAT YOUR STAFF WILL NOTICE

Only IT administrators are affected.

WHAT WE NEED FROM YOU

Confirm who genuinely needs administrator access.

Strengthen email security

About 2 hours

Why it matters. Email is the most common way criminals reach staff, through phishing and harmful attachments. These settings block more threats and stop email being quietly forwarded outside the business.

SMTP AUTH client submission is disabled — 2 hours

We found: SMTP AUTH is enabled for the whole organisation.

WHAT YOUR STAFF WILL NOTICE

Little change for staff. Some suspicious messages will be held in quarantine instead of reaching inboxes.

WHAT WE NEED FROM YOU

Tell us about any automatic forwarding to outside addresses that the business relies on.

Detect and respond to threats

About Minimal

Why it matters. Security tools only help if they are switched on, cover every device and someone acts on their alerts.

Microsoft Secure Score — Minimal

We found: Secure Score 312 of 640 (48.8%). Comparable organisations (TotalSeats) average 44.6.

WHAT YOUR STAFF WILL NOTICE

No change for staff.

WHAT WE NEED FROM YOU

Confirm who should receive security alerts, including out of hours.

Patch, protect and back up servers

About 1.5 days

Why it matters. Servers hold your most important data and systems. Servers that are out of support, unpatched, unprotected or not backed up are the most common way ransomware gets in and causes lasting damage.

Windows servers meet the hardening baseline — 6 hours

We found: 49.7% of baseline settings are met across 5 servers. 3 servers are below 60%.

Server volumes have free space — 1 hour

We found: 1 volume is under 10% free.

Server time, certificates and stability — 1 hour

We found: 2 of 5 servers have time, certificate or stability issues.

WHAT YOUR STAFF WILL NOTICE

Servers may need short, planned restarts outside working hours.

WHAT WE NEED FROM YOU

Agree a maintenance window, and budget for replacing any servers that are out of support.

Keep virtualisation hosts healthy

About 2 hours

Why it matters. One host runs many servers, so a problem there affects all of them. Old snapshots, unsupported versions and missing redundancy put every virtual server at risk.

Hyper-V virtual machines are healthy — 2 hours

We found: 2 virtual machines have old checkpoints, replication or cluster problems.

WHAT YOUR STAFF WILL NOTICE

Hosts may need planned maintenance windows.

WHAT WE NEED FROM YOU

Agree maintenance windows and any budget for host upgrades.

Secure your Azure services

About 1 hour

Why it matters. Cloud servers and services that are open to the internet, or have no security monitoring, are a frequent target for attackers.

App Service apps enforce HTTPS and TLS 1.2 — 1 hour

We found: 1 of 1 apps allows HTTP, old TLS or plain FTP.

WHAT YOUR STAFF WILL NOTICE

No change for staff.

WHAT WE NEED FROM YOU

Confirm which Azure services must be reachable from the internet.

3 Could do: within 6 months

Good-practice improvements that tighten security further and bring you in line with the published benchmarks. Select an item to see what we found.

Protect sign-ins and accounts

About 3 days

Why it matters. Most attacks start with a stolen or guessed password. These changes make it much harder for anyone to get into a staff account, even if they have the password.

Administrators use phishing-resistant MFA — 3 hours

Weak MFA methods (SMS and voice) are disabled — 2 hours

Conditional Access requires compliant or managed devices — 4 hours

Users cannot register applications or create tenants	30 minutes
Guest invitations are restricted	30 minutes
Guest user access to the directory is restricted	30 minutes
No inactive enabled user accounts	3 hours
Windows LAPS is enabled	2 hours
Strong authentication methods are enabled	1 hour
Report-only and disabled Conditional Access policies	1 hour
Admin consent workflow is enabled	1 hour
Self-service sign-up is disabled	30 minutes
Passwords are set not to expire	30 minutes
No inactive guest accounts	1 hour
No stale devices in Entra ID	2 hours

WHAT YOUR STAFF WILL NOTICE
Staff may be asked to set up an authenticator app and could be prompted to sign in again on their devices.

WHAT WE NEED FROM YOU
Agree a date to tell staff, and confirm any shared or emergency accounts that need different treatment.

Lock down administrator access

About 6 hours

Why it matters. Administrator accounts can change or delete anything. Keeping them few in number and well protected limits the damage if one is compromised.

Privileged accounts are cloud-only	2 hours
Service principals with privileged directory roles	1 hour
Admins use separate accounts from daily email accounts	3 hours

WHAT YOUR STAFF WILL NOTICE
Only IT administrators are affected.

WHAT WE NEED FROM YOU
Confirm who genuinely needs administrator access.

Strengthen email security

About 2 days

Why it matters. Email is the most common way criminals reach staff, through phishing and harmful attachments. These settings block more threats and stop email being quietly forwarded outside the business.

Mail flow rules do not weaken security	2 hours
Anti-spam policies do not allow whole sender domains	1 hour
Anti-phishing protection is configured	2 hours
Safe Links protects email, Teams and Office apps	2 hours
Safe Attachments is enabled	1 hour
Sign-in is blocked for shared and resource mailboxes	1 hour
External sender tagging is enabled in Outlook	30 minutes
Calendar details are not shared anonymously	30 minutes
Outlook on the web third-party storage is disabled	30 minutes
POP and IMAP are disabled where not needed	1 hour
Mailboxes approaching their quota	1 hour

WHAT YOUR STAFF WILL NOTICE
Little change for staff. Some suspicious messages will be held in quarantine instead of reaching inboxes.

WHAT WE NEED FROM YOU
Tell us about any automatic forwarding to outside addresses that the business relies on.

Stop others sending email as you

About 1 hour

Why it matters. SPF, DKIM and DMARC records prove your email is genuine. Without them, criminals can send convincing emails that look as if they come from you, to your staff, customers and suppliers.

Domains that do not send mail are locked down	1 hour

WHAT YOUR STAFF WILL NOTICE
No change for staff.

WHAT WE NEED FROM YOU
Access to your DNS provider, and a list of other services that send email for you (for example invoicing or marketing systems).

Secure laptops, desktops and phones

About 5 days

Why it matters. Devices hold company data and are used to sign in. Managing, encrypting and updating them protects that data if a device is lost, stolen or infected.

Devices without a compliance policy are marked non-compliant	30 minutes
Managed devices are compliant	3 hours
Endpoint security policies are deployed	6 hours
App protection policies protect mobile data	3 hours
Policies apply without errors or conflicts	3 hours
Microsoft Defender Antivirus protections are on	2 hours
Windows Hello for Business is configured	3 hours
Security baselines are deployed and current	6 hours
Autopilot profiles are assigned and users are not local administrators	2 hours
Enrolment Status Page holds users until setup completes	2 hours
Required apps install successfully	3 hours
Devices are checking in with Intune	1 hour
Personal Windows device enrolment is blocked	1 hour
Intune policies are assigned	1 hour
Device clean-up rule removes inactive devices	30 minutes
Windows update management	Minimal

WHAT YOUR STAFF WILL NOTICE
Devices may restart for updates, and staff may be asked to enrol phones or accept new settings.

WHAT WE NEED FROM YOU
Agree a small pilot group first, then a date for everyone else.

Keep device management working

About 3 hours

Why it matters. Device management relies on certificates and connections to Apple and Google. If these lapse, company phones and tablets can no longer be managed or wiped, and fixing it can mean re-enrolling every device.

Apple Apps and Books (VPP) tokens are valid	1 hour
Android Enterprise is connected	2 hours

WHAT YOUR STAFF WILL NOTICE
No change for staff if this is done before the expiry date.

WHAT WE NEED FROM YOU
Access to the Apple or Google account that was used to set these up.

Detect and respond to threats

About 2 days

Why it matters. Security tools only help if they are switched on, cover every device and someone acts on their alerts.

Discovered devices that can be onboarded	2 hours
Onboarded devices report a healthy sensor	2 hours
High-impact secure configuration gaps are addressed	6 hours
No devices with a high exposure level	2 hours
Defender for Endpoint is connected to Intune	1 hour

WHAT YOUR STAFF WILL NOTICE
No change for staff.

WHAT WE NEED FROM YOU
Confirm who should receive security alerts, including out of hours.

Control file sharing

About 4.5 hours

Why it matters. Files shared with open links can be passed on to anyone. Tightening sharing reduces the chance of sensitive documents reaching the wrong people.

Anonymous (Anyone) sharing links are controlled	2 hours
Guests cannot reshare content they do not own	30 minutes
Guests must sign in with the invited account	30 minutes
Legacy authentication is blocked for SharePoint	30 minutes
Idle session sign-out is configured	1 hour

WHAT YOUR STAFF WILL NOTICE
Staff may need to share with named people rather than with anyone who has the link.

WHAT WE NEED FROM YOU
Agree how staff should share files with clients and suppliers.

Secure meetings, chat and groups

About 2 hours

Why it matters. Settings for who can join meetings, message your staff and create groups decide how easily outsiders get in and how easily information leaks out.

Every group and Team has an owner	2 hours

WHAT YOUR STAFF WILL NOTICE
External guests may wait in a lobby or need an invitation to join.

WHAT WE NEED FROM YOU
Confirm which outside organisations staff need to work with.

Control connected apps

About 3 hours

Why it matters. Apps connected to your accounts can often read email and files. Reviewing them, and requiring approval for new ones, stops data being handed to unsafe apps without anyone noticing.

User-consented applications are reviewed	2 hours
App registration credentials are current	1 hour

WHAT YOUR STAFF WILL NOTICE
Staff will need approval before connecting new apps to their work account.

WHAT WE NEED FROM YOU
Confirm which connected apps are used for business.

Protect and keep important information

About 3 days

Why it matters. Backup, retention, audit logging and data loss prevention help you meet obligations such as UK GDPR, recover deleted information and investigate problems.

Windows compliance policy checks the essentials	2 hours
Mobile compliance policies require a passcode and block jailbroken devices	2 hours
Data loss prevention policies protect sensitive data	6 hours
Retention policies cover email, files and Teams	3 hours
Sensitivity labels are defined and published	1.5 days
Default alert policies are enabled and notify administrators	1 hour

WHAT YOUR STAFF WILL NOTICE
Staff may see a tip before sharing sensitive information outside the business.

WHAT WE NEED FROM YOU
Confirm how long different types of information must be kept.

Tidy up who can see what

About 1 hour

Why it matters. Over time people collect access to mailboxes, sites and groups they no longer need. Removing it limits what a leaver or an attacker could see.

Mailbox permissions do not reference deleted or disabled accounts	1 hour

WHAT YOUR STAFF WILL NOTICE
Some staff will lose access to mailboxes or sites they no longer use.

WHAT WE NEED FROM YOU
Confirm who should keep access.

Make sure licences are right

About 2.5 hours

Why it matters. Unused or unsuitable licences cost money every month and can leave security features out of reach.

Subscriptions are in good standing	30 minutes
Unassigned paid licences	30 minutes
No licences assigned to disabled accounts	1 hour
Shared and resource mailboxes are not licensed unnecessarily	30 minutes

WHAT YOUR STAFF WILL NOTICE
No change for staff.

WHAT WE NEED FROM YOU
Approve any licence changes.

Patch, protect and back up servers

About 6 hours

Why it matters. Servers hold your most important data and systems. Servers that are out of support, unpatched, unprotected or not backed up are the most common way ransomware gets in and causes lasting damage.

Security logging and audit policy are in place	2 hours
Unnecessary and risky services are not running	2 hours
Physical servers encrypt their disks	2 hours

WHAT YOUR STAFF WILL NOTICE
Servers may need short, planned restarts outside working hours.

WHAT WE NEED FROM YOU
Agree a maintenance window, and budget for replacing any servers that are out of support.

Secure Active Directory

About 3 hours

Why it matters. Active Directory controls sign-in to every PC and server. A weakness here can let one compromised account take over the whole network.

Stale and out-of-support accounts are cleaned up	3 hours

WHAT YOUR STAFF WILL NOTICE
Mostly no change. A few old accounts may be disabled and some service accounts given new passwords.

WHAT WE NEED FROM YOU
Confirm which old accounts and service accounts are still needed.

Keep virtualisation hosts healthy

About 1.5 days

Why it matters. One host runs many servers, so a problem there affects all of them. Old snapshots, unsupported versions and missing redundancy put every virtual server at risk.

Hyper-V hosts are dedicated	1.5 days

WHAT YOUR STAFF WILL NOTICE
Hosts may need planned maintenance windows.

WHAT WE NEED FROM YOU
Agree maintenance windows and any budget for host upgrades.

Patch and harden Linux servers

About 1 hour

Why it matters. Linux servers often run websites, databases and file transfers that face the internet. Keeping them patched and locked down stops them becoming a way in.

Linux disk space, packages and kernel settings	1 hour

WHAT YOUR STAFF WILL NOTICE
Servers may need short, planned restarts outside working hours.

WHAT WE NEED FROM YOU
Agree a maintenance window and who owns each server.

Secure your Azure services

About 4 days

Why it matters. Cloud servers and services that are open to the internet, or have no security monitoring, are a frequent target for attackers.

Defender for Cloud secure score	1.5 days
Microsoft cloud security benchmark compliance	1.5 days
Virtual machines do not have public IP addresses	2 hours
Subnets are protected by network security groups	2 hours
Key vaults have purge protection and restricted network access	1 hour
Servers have no outstanding critical or security updates	3 hours
Defender for Cloud alert emails reach the right people	30 minutes
Virtual machines use Trusted Launch	2 hours

WHAT YOUR STAFF WILL NOTICE
No change for staff.

WHAT WE NEED FROM YOU
Confirm which Azure services must be reachable from the internet.

Make sure Azure can recover

About 6 hours

Why it matters. Backups and protection against accidental deletion mean a mistake or a ransomware attack does not become a lasting outage.

Backup vaults are protected against deletion and ransomware	1 hour
High-impact Azure Advisor recommendations	4 hours
Azure Arc servers are connected	1 hour

WHAT YOUR STAFF WILL NOTICE
No change for staff.

WHAT WE NEED FROM YOU
Confirm how much data you could afford to lose and how quickly systems must be back.

Control Azure access and cost

About 7 hours

Why it matters. Clear ownership, budgets and removing unused resources stop surprise bills and limit who can change live systems.

The Azure activity log is kept beyond 90 days	1 hour
Critical resources have delete locks	1 hour
No unattached disks or unused public IP addresses	1 hour
Azure Advisor cost recommendations	2 hours
Every subscription has a budget alert	30 minutes
The Microsoft cloud security benchmark policy is assigned	1 hour
Network Watcher is enabled where networks exist	30 minutes

WHAT YOUR STAFF WILL NOTICE
No change for staff.

WHAT WE NEED FROM YOU
Agree a monthly Azure budget and who should be alerted.

4 Use what you already pay for

Features included in your current licences that are not set up yet. Using them adds protection or saves time at no extra licence cost.

Feature	Now	What it gives you	Effort
Self-service password reset	Not used	Fewer password reset calls to the service desk and faster recovery for users out of hours.	0.5 days
Dynamic groups	Not used	Less manual administration and fewer access mistakes when staff change roles.	0.5 days
Universal Print	Not used	Cloud printing from Entra joined devices with no print server to patch.	1.5 days
Sensitivity labels	Not used	Sensitive documents stay protected wherever they go, and it prepares the tenant for Copilot by controlling what it can surface.	4 days
Online archiving	Not used	Keeps large mailboxes fast and within quota without buying extra storage.	0.5 days
Device-based Conditional Access	Not used	Stolen passwords alone cannot be used to download company data to an unmanaged computer.	1.5 days
Teams Phone	Not used	Replaces a separate phone system and puts calling in the app users already have open.	3 days
Retention policies	Partly used	Protection against accidental or malicious deletion beyond the default recycle bin periods, and support for legal obligations.	1 day
Conditional Access	Partly used	Granular, auditable access control that security defaults cannot provide, without blocking legitimate users.	2 days
Defender for Endpoint or Defender for Business	Partly used	Endpoint detection and response that can stop ransomware, often replacing a separately licensed antivirus product.	3 days
Defender for Office 365 (Safe Links, Safe Attachments, impersonation)	Partly used	Stronger protection against phishing, business email compromise and malicious attachments than the default built-in policy.	1 day

Feature	Now	What it gives you	Effort
Data loss prevention for email and files	Partly used	Reduces the risk of a reportable data breach from misdirected email or oversharing.	3 days
Microsoft 365 desktop apps	Partly used	Users get current, supported Office apps and the client can stop paying for separate Office licences.	1 day
OneDrive	Partly used	User files are backed up to the cloud and a lost laptop no longer means lost work.	1 day
SharePoint for company files	Partly used	Secure access from anywhere, version history and co-authoring, and one less server to maintain and back up.	5 days
Intune device management	Partly used	Consistent, provable device security and remote wipe for lost or stolen devices.	5 days
App protection for mobiles	Partly used	Supports bring-your-own phones while keeping company data contained.	1 day
Microsoft 365 Copilot	Partly used	A return on an expensive licence, and idle licences moved to people who will use them.	2 days

Things to confirm with you

These could not be checked automatically. We will go through them with you.

Teams external access and anonymous meeting join

Teams policy settings are not readable through delegated Graph access. Check in the Teams admin centre.

Microsoft 365 data is backed up

Backup coverage cannot be read from the tenant. Confirm the backup product, scope and last successful run.

3. Findings

Identity and access

Fail Licensed users are registered for MFA

High severity IAM-05

CURRENT STATE	88% of 25 enabled licensed users are MFA capable (3 not capable).
RECOMMENDATION	Run an MFA registration campaign and follow up with users who are not registered. Unregistered accounts can be registered by an attacker who has the password.
ESTIMATED EFFORT	4 hours
PRIORITY	**P1**
REFERENCE	https://learn.microsoft.com/entra/identity/authentication/how-to-mfa-registration-campaign
BENCHMARKS	CIS 5.2.3.4

3 affected items (listed in the HTML report and FindingDetails.csv)

Fail All administrators are registered for MFA

High severity IAM-06

CURRENT STATE	Admin accounts not MFA capable: 1 of 7.
RECOMMENDATION	Register strong MFA methods for every account that holds an admin role before anything else. Remove roles from accounts that do not need them.
ESTIMATED EFFORT	1 hour
PRIORITY	**P1**
REFERENCE	https://learn.microsoft.com/entra/identity/role-based-access-control/best-practices

1 affected item (listed in the HTML report and FindingDetails.csv)

Fail Users cannot consent to applications

High severity IAM-13

CURRENT STATE	Users can consent to any application for any delegated permission.
RECOMMENDATION	Set user consent to "Do not allow" or "Allow for verified publishers, for selected low-impact permissions", and turn on the admin consent workflow.
ESTIMATED EFFORT	1 hour
PRIORITY	**P1**
REFERENCE	https://learn.microsoft.com/entra/identity/enterprise-apps/configure-user-consent
BENCHMARKS	CIS 5.1.5.1; MS.AAD.5.2v1

Fail Directory synchronisation is healthy

High severity IAM-22

CURRENT STATE	Last sync 16/10/2026 10:31 (30 hours ago).
RECOMMENDATION	Investigate the Entra Connect or Cloud Sync server. A stalled sync means leavers disabled on-premises keep cloud access.
ESTIMATED EFFORT	2 hours
PRIORITY	**P1**
REFERENCE	https://learn.microsoft.com/entra/identity/hybrid/connect/how-to-connect-health-sync
BENCHMARKS	CIS 5.1.8.1

Warning

Legacy authentication is blocked

High severity IAM-02

CURRENT STATE	Legacy authentication block is in report-only mode: CA002 Block legacy authentication
RECOMMENDATION	Create a Conditional Access policy that blocks Exchange ActiveSync and other legacy clients for all users. Check sign-in logs for legacy clients first, then enforce.
ESTIMATED EFFORT	2 hours
PRIORITY	**P2**
REFERENCE	https://learn.microsoft.com/entra/identity/conditional-access/policy-block-legacy-authentication
BENCHMARKS	CIS 5.2.2.3; MS.AAD.1.1v1

Warning

Administrators use phishing-resistant MFA

Medium severity IAM-04

CURRENT STATE	No enabled policy requires phishing-resistant MFA for administrators.
RECOMMENDATION	Issue FIDO2 security keys, passkeys or Windows Hello for Business to administrators and require the built-in Phishing-resistant MFA authentication strength for admin roles.
ESTIMATED EFFORT	3 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/entra/identity/conditional-access/policy-admin-phish-resistant-mfa
BENCHMARKS	CIS 5.2.2.5; MS.AAD.3.1v1; MS.AAD.3.6v1

Warning

Weak MFA methods (SMS and voice) are disabled

Medium severity IAM-07

CURRENT STATE	Enabled: Sms
RECOMMENDATION	Move users to Microsoft Authenticator or passkeys, then disable SMS and voice call in the authentication methods policy.
ESTIMATED EFFORT	2 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/entra/identity/authentication/concept-authentication-methods-manage
BENCHMARKS	CIS 5.2.3.5; MS.AAD.3.5v2

Warning

Conditional Access requires compliant or managed devices

Medium severity IAM-11

CURRENT STATE	No enabled policy requires a compliant device, hybrid-joined device or protected app.
RECOMMENDATION	Once Intune compliance policies are in place, require a compliant or hybrid-joined device for access to Microsoft 365 on desktops, and app protection on mobile.
ESTIMATED EFFORT	4 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/entra/identity/conditional-access/policy-all-users-device-compliance
BENCHMARKS	CIS 5.2.2.9; MS.AAD.3.7v1

Warning

Users cannot register applications or create tenants

Medium severity IAM-15

CURRENT STATE	Users can register applications; Users can create tenants; Users can create security groups
RECOMMENDATION	Set "Users can register applications" and "Restrict non-admin users from creating tenants" so only administrators can do these.
ESTIMATED EFFORT	0.5 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/entra/fundamentals/users-default-permissions
BENCHMARKS	CIS 5.1.2.2; CIS 5.1.2.3; MS.AAD.5.1v1

Warning

Guest invitations are restricted

Medium severity IAM-16

CURRENT STATE	All member users can invite guests.
RECOMMENDATION	Limit guest invitations to admins and users in the Guest Inviter role, or to members only, in line with the client's collaboration needs.
ESTIMATED EFFORT	0.5 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/entra/external-id/external-collaboration-settings-configure
BENCHMARKS	CIS 5.1.6.3; MS.AAD.8.2v1

Warning

Guest user access to the directory is restricted

Medium severity IAM-17

CURRENT STATE	Default limited guest access. Guests can see membership of non-hidden groups.
RECOMMENDATION	Set guest user access to "Guest user access is restricted to properties and memberships of their own directory objects".
ESTIMATED EFFORT	0.5 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/entra/identity/users/users-restrict-guest-permissions
BENCHMARKS	CIS 5.1.6.2; MS.AAD.8.1v1

Warning

No inactive enabled user accounts

Medium severity IAM-20

CURRENT STATE	Enabled member accounts not signed in for 90+ days: 3.
RECOMMENDATION	Confirm leavers with the client, then block sign-in, remove licences and convert or delete accounts that have not signed in within the inactivity window.
ESTIMATED EFFORT	3 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/entra/identity/monitoring-health/howto-manage-inactive-user-accounts

3 affected items (listed in the HTML report and FindingDetails.csv)

Warning

Windows LAPS is enabled

Medium severity IAM-25

CURRENT STATE	Microsoft Entra LAPS is not enabled in device settings.
RECOMMENDATION	Enable Windows LAPS in Entra device settings and deploy an Intune LAPS policy so local administrator passwords are unique and rotated.
ESTIMATED EFFORT	2 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/entra/identity/devices/howto-manage-local-admin-passwords
BENCHMARKS	CIS 5.1.4.5

Warning

Strong authentication methods are enabled

Low severity IAM-08

CURRENT STATE	Authenticator: enabled; FIDO2: disabled; Registration campaign: default
RECOMMENDATION	Enable Microsoft Authenticator and passkeys (FIDO2) in the authentication methods policy, and enable the registration campaign to nudge users onto Authenticator.
ESTIMATED EFFORT	1 hour
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/entra/identity/authentication/how-to-mfa-registration-campaign

Warning

Report-only and disabled Conditional Access policies

Low severity IAM-12

CURRENT STATE	Enabled: 1; Report-only: 1; Disabled: 1
RECOMMENDATION	Review report-only policies with the sign-in log impact data, then enable or remove them. Delete disabled policies that are no longer needed.
ESTIMATED EFFORT	1 hour
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/entra/identity/conditional-access/concept-conditional-access-report-only

2 affected items (listed in the HTML report and FindingDetails.csv)

Warning

Admin consent workflow is enabled

Low severity IAM-14

CURRENT STATE	Admin consent workflow is disabled.
RECOMMENDATION	Enable the admin consent workflow so users can request apps rather than work around the block.
ESTIMATED EFFORT	1 hour
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/entra/identity/enterprise-apps/configure-admin-consent-workflow
BENCHMARKS	CIS 5.1.5.2; MS.AAD.5.3v1

Warning

Self-service sign-up is disabled

Low severity IAM-18

CURRENT STATE	Users can sign up for email-based subscriptions
RECOMMENDATION	Disable email-verified self-service sign-up and self-service subscription sign-up to stop unmanaged accounts and trials appearing in the tenant.
ESTIMATED EFFORT	0.5 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/entra/identity/users/directory-self-service-signup

Warning

Passwords are set not to expire

Low severity IAM-19

CURRENT STATE	Password expiry is configured on one or more domains.
RECOMMENDATION	With MFA enforced, set passwords to never expire in line with NCSC and Microsoft guidance. Forced rotation encourages weak, predictable passwords.
ESTIMATED EFFORT	0.5 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/microsoft-365/admin/misc/password-policy-recommendations
BENCHMARKS	CIS 1.3.1; MS.AAD.6.1v1

1 affected item (listed in the HTML report and FindingDetails.csv)

Warning

No inactive guest accounts

Low severity IAM-21

CURRENT STATE	Guest accounts: 3; inactive for 90+ days: 2.
RECOMMENDATION	Remove guests who have not signed in within the inactivity window, or put an Entra access review in place for guests.
ESTIMATED EFFORT	1 hour
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/entra/id-governance/access-reviews-overview

2 affected items (listed in the HTML report and FindingDetails.csv)

Warning

No stale devices in Entra ID

Low severity IAM-24

CURRENT STATE	Devices not signed in for 180+ days: 3 of 15.
RECOMMENDATION	Disable, then delete, devices that have not signed in for the stale window, after checking for BitLocker and LAPS recovery needs.
ESTIMATED EFFORT	2 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/entra/identity/devices/manage-stale-devices

3 affected items (listed in the HTML report and FindingDetails.csv)

Info **No users are flagged as at risk** High severity IAM-23

CURRENT STATE	Entra ID P2 is not licensed, so risky user detection is not available.
RECOMMENDATION	Investigate each risky user in Entra ID Protection, reset credentials and revoke sessions where compromise is confirmed, then dismiss or confirm the risk.
REFERENCE	https://learn.microsoft.com/entra/id-protection/howto-identity-protection-investigate-risk

Info **Risk-based Conditional Access policies are in place** Medium severity IAM-09

CURRENT STATE	Entra ID P2 is not licensed, so risk-based policies are not available.
RECOMMENDATION	With Entra ID P2, require MFA for medium and high sign-in risk and a secure password change for high user risk.
REFERENCE	https://learn.microsoft.com/entra/identity/conditional-access/policy-risk-based-user
BENCHMARKS	CIS 5.2.2.6; CIS 5.2.2.7; MS.AAD.2.1v1; MS.AAD.2.3v1

Pass **Multi-factor authentication is enforced for all users** High severity IAM-01

CURRENT STATE	Enforced by: CA001 Require MFA for all users
REFERENCE	https://learn.microsoft.com/entra/identity/conditional-access/policy-all-users-mfa-strength
BENCHMARKS	CIS 5.2.2.2; MS.AAD.3.2v2

Pass **MFA is enforced for administrator roles** High severity IAM-03

CURRENT STATE	Covered by: CA001 Require MFA for all users
REFERENCE	https://learn.microsoft.com/entra/identity/conditional-access/policy-admin-phish-resistant-mfa
BENCHMARKS	CIS 5.2.2.1

Pass **Emergency access accounts are excluded from Conditional Access** Medium severity IAM-10

CURRENT STATE	Accounts excluded from every enforcing policy: 1. Confirm these are emergency access accounts.
REFERENCE	https://learn.microsoft.com/entra/identity/role-based-access-control/security-emergency-access
BENCHMARKS	CIS 1.1.2

1 affected item (listed in the HTML report and FindingDetails.csv)

Privileged access

Fail **No guest accounts hold admin roles** High severity PRV-02

CURRENT STATE	Admin role assignments held by guests: 1.
RECOMMENDATION	Remove admin roles from guest accounts. Partner access should use GDAP, not guest accounts with roles.
ESTIMATED EFFORT	0.5 hours
PRIORITY	**P1**
REFERENCE	https://learn.microsoft.com/partner-center/customers/gdap-introduction

1 affected item (listed in the HTML report and FindingDetails.csv)

Fail Between two and four Global Administrators

Medium severity PRV-01

CURRENT STATE	Global Administrators: 5.
RECOMMENDATION	Keep at least two (including emergency access) and no more than four Global Administrators. Move day-to-day admin work to least-privileged roles.
ESTIMATED EFFORT	1 hour
PRIORITY	**P2**
REFERENCE	https://learn.microsoft.com/entra/identity/role-based-access-control/best-practices
BENCHMARKS	CIS 1.1.3; MS.AAD.7.1v1; MS.AAD.7.2v1

5 affected items (listed in the HTML report and FindingDetails.csv)

Warning Privileged accounts are cloud-only

Medium severity PRV-03

CURRENT STATE	Privileged role assignments held by synced accounts: 1.
RECOMMENDATION	Use cloud-only accounts for privileged roles so an on-premises compromise cannot take over the tenant.
ESTIMATED EFFORT	2 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/entra/architecture/protect-m365-from-on-premises-attacks
BENCHMARKS	CIS 1.1.1; MS.AAD.7.3v1

1 affected item (listed in the HTML report and FindingDetails.csv)

Warning Service principals with privileged directory roles

Medium severity PRV-06

CURRENT STATE	Privileged role assignments held by applications: 1.
RECOMMENDATION	Confirm each application that holds a privileged directory role is known and still required. Replace with least-privileged Graph permissions where possible.
ESTIMATED EFFORT	1 hour
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/entra/identity/role-based-access-control/best-practices

1 affected item (listed in the HTML report and FindingDetails.csv)

Warning Admins use separate accounts from daily email accounts

Low severity PRV-04

CURRENT STATE	Licensed privileged accounts, likely used for daily work: 3.
RECOMMENDATION	Give administrators a separate unlicensed admin account and remove admin roles from their mailbox-enabled daily accounts.
ESTIMATED EFFORT	3 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/microsoft-365/admin/add-users/about-admin-roles
BENCHMARKS	CIS 1.1.4

3 affected items (listed in the HTML report and FindingDetails.csv)

Info **Privileged Identity Management is used** Low severity PRV-05

CURRENT STATE	Entra ID P2 is not licensed.
RECOMMENDATION	With Entra ID P2, make privileged roles eligible rather than permanent and require approval or justification to activate.
REFERENCE	https://learn.microsoft.com/entra/id-governance/privileged-identity-management/pim-configure
BENCHMARKS	CIS 5.3.1; MS.AAD.7.4v1; MS.AAD.7.5v1

Applications

Warning **High-risk application permissions are reviewed** High severity APP-01

CURRENT STATE	Applications with high-risk application permissions: 2.
RECOMMENDATION	Review each non-Microsoft application holding high-impact application permissions (mail, files, directory write). Remove apps that are unused or unknown and reduce permissions where possible.
ESTIMATED EFFORT	3 hours
PRIORITY	**P2**
REFERENCE	https://learn.microsoft.com/entra/identity/enterprise-apps/manage-application-permissions

2 affected items (listed in the HTML report and FindingDetails.csv)

Warning **User-consented applications are reviewed** Medium severity APP-03

CURRENT STATE	User consents granting high-impact access to non-Microsoft apps: 1.
RECOMMENDATION	Review applications individual users have consented to with mail, file or offline access. These are a common route for consent phishing.
ESTIMATED EFFORT	2 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/entra/identity/enterprise-apps/investigate-risky-oauth-app

1 affected item (listed in the HTML report and FindingDetails.csv)

Warning **App registration credentials are current** Low severity APP-04

CURRENT STATE	Credentials expired or expiring within 30 days: 2.
RECOMMENDATION	Renew credentials expiring in the next 30 days, remove expired secrets and certificates, and prefer certificates or managed identities over client secrets.
ESTIMATED EFFORT	1 hour
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/entra/identity-platform/how-to-add-credentials

2 affected items (listed in the HTML report and FindingDetails.csv)

Info **Third-party application inventory** Low severity APP-05

CURRENT STATE	Enterprise applications: 6 (2 third party, 1 internal, 3 Microsoft or other).
RECOMMENDATION	Use the Applications inventory to confirm with the client which third-party apps are in use and remove the rest.
REFERENCE	https://learn.microsoft.com/entra/identity/enterprise-apps/view-applications-portal

Pass **Tenant-wide delegated consents are reviewed** Medium severity APP-02

CURRENT STATE	No tenant-wide high-impact delegated consents to non-Microsoft apps.
REFERENCE	https://learn.microsoft.com/entra/identity/enterprise-apps/manage-application-permissions

Licensing

Warning **Subscriptions are in good standing** Medium severity LIC-03

CURRENT STATE	Subscriptions needing attention: 1.
RECOMMENDATION	Renew or remove subscriptions in a warning or suspended state before services are switched off.
ESTIMATED EFFORT	0.5 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/microsoft-365/commerce/subscriptions/what-if-my-subscription-expires

1 affected item (listed in the HTML report and FindingDetails.csv)

Warning **Unassigned paid licences** Low severity LIC-01

CURRENT STATE	Products with unassigned licences: 2.
RECOMMENDATION	Reduce subscription quantities at the next renewal, or assign the spare licences to users who need them.
ESTIMATED EFFORT	0.5 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/microsoft-365/commerce/licenses/buy-licenses

2 affected items (listed in the HTML report and FindingDetails.csv)

Warning **No licences assigned to disabled accounts** Low severity LIC-02

CURRENT STATE	Disabled accounts holding licences: 1.
RECOMMENDATION	Remove licences from blocked accounts, or convert leavers to shared mailboxes where the mailbox must be kept and is under 50 GB.
ESTIMATED EFFORT	1 hour
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/microsoft-365/admin/add-users/remove-former-employee

1 affected item (listed in the HTML report and FindingDetails.csv)

Warning **Shared and resource mailboxes are not licensed unnecessarily** Low severity LIC-04

CURRENT STATE	Shared or resource mailboxes licensed without an obvious need: 1.
RECOMMENDATION	Remove licences from shared and resource mailboxes unless they need more than 50 GB, an archive or a hold.
ESTIMATED EFFORT	0.5 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/microsoft-365/admin/email/about-shared-mailboxes

1 affected item (listed in the HTML report and FindingDetails.csv)

Info **Security feature licensing** Info severity LIC-05

CURRENT STATE	Entra ID P1: Yes; Entra ID P2: No; Intune: Yes; Defender for Office 365: Plan 1; Defender for Endpoint or Business: Yes
RECOMMENDATION	Use this to scope recommendations. Business Premium or E3 with add-ons unlocks Conditional Access, Intune and Defender for Office 365.
REFERENCE	https://learn.microsoft.com/office365/servicedescriptions/microsoft-365-service-descriptions/microsoft-365-business-service-description

Exchange Online

Fail **Mailbox forwarding is reviewed** High severity EXO-06

CURRENT STATE	Mailboxes forwarding mail: 1 (1 to external addresses).
RECOMMENDATION	Confirm every mailbox forward is authorised, particularly to external addresses. Unexpected forwarding is a common sign of a compromised account.
ESTIMATED EFFORT	1 hour
PRIORITY	**P1**
REFERENCE	https://learn.microsoft.com/defender-office-365/outbound-spam-policies-external-email-forwarding

1 affected item (listed in the HTML report and FindingDetails.csv)

Fail **SMTP AUTH client submission is disabled** Medium severity EXO-04

CURRENT STATE	SMTP AUTH is enabled for the whole organisation.
RECOMMENDATION	Disable SMTP AUTH at organisation level and allow it only on specific mailboxes used by devices or apps that cannot use modern methods. Plan moves to high volume email or a relay connector.
ESTIMATED EFFORT	2 hours
PRIORITY	**P2**
REFERENCE	https://learn.microsoft.com/exchange/clients-and-mobile-in-exchange-online/authenticated-client-smtp-submission
BENCHMARKS	CIS 6.5.4; MS.EXO.5.1v1

1 affected item (listed in the HTML report and FindingDetails.csv)

Warning **Mail flow rules do not weaken security** Medium severity EXO-07

CURRENT STATE	Mail flow rules that bypass filtering or copy or redirect mail: 1 of 2.
RECOMMENDATION	Review rules that bypass spam filtering (SCL -1) or copy or redirect mail. Replace sender allow rules with Tenant Allow/Block List entries or connectors scoped by IP.
ESTIMATED EFFORT	2 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/exchange/security-and-compliance/mail-flow-rules/mail-flow-rules
BENCHMARKS	CIS 6.2.1; CIS 6.2.2

1 affected item (listed in the HTML report and FindingDetails.csv)

Warning

Anti-spam policies do not allow whole sender domains

Medium severity EXO-08

CURRENT STATE	Anti-spam policies contain allowed senders or domains.
RECOMMENDATION	Remove allowed sender domains and addresses from anti-spam policies. Spoofed mail from these domains skips filtering. Use the Tenant Allow/Block List for genuine false positives.
ESTIMATED EFFORT	1 hour
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/defender-office-365/create-safe-sender-lists-in-office-365
BENCHMARKS	CIS 2.1.14; MS.SECURITYSUITE.6.2v1

1 affected item (listed in the HTML report and FindingDetails.csv)

Warning

Anti-phishing protection is configured

Medium severity EXO-09

CURRENT STATE	Strongest policy: Office365 AntiPhish Default; gaps: first contact safety tips off, user impersonation protection off, domain impersonation protection off, mailbox intelligence protection off
RECOMMENDATION	Enable spoof intelligence, first contact safety tips and honour DMARC policy. With Defender for Office 365, add impersonation protection for executives and the client's domains and turn on mailbox intelligence.
ESTIMATED EFFORT	2 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/defender-office-365/anti-phishing-policies-about
BENCHMARKS	CIS 2.1.7; MS.SECURITYSUITE.2.1v1; MS.SECURITYSUITE.2.2v1

Warning

Safe Links protects email, Teams and Office apps

Medium severity EXO-10

CURRENT STATE	Only Built-in protection applies. No custom Safe Links policy is enabled.
RECOMMENDATION	Apply the Standard preset security policy, or a custom Safe Links policy for all users covering email, Teams and Office apps with click tracking and no click-through.
ESTIMATED EFFORT	2 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/defender-office-365/safe-links-about
BENCHMARKS	CIS 2.1.1; MS.SECURITYSUITE.7.1v1

Warning

Safe Attachments is enabled

Medium severity EXO-11

CURRENT STATE	No custom Safe Attachments policy is enabled. SharePoint, OneDrive and Teams protection: on.
RECOMMENDATION	Apply the Standard preset policy or a Safe Attachments policy with the Block action for all users, and enable Safe Attachments for SharePoint, OneDrive and Teams.
ESTIMATED EFFORT	1 hour
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/defender-office-365/safe-attachments-about
BENCHMARKS	CIS 2.1.4; MS.SECURITYSUITE.1.3v1

Warning

Sign-in is blocked for shared and resource mailboxes

Medium severity EX0-16

CURRENT STATE	Shared or resource mailbox accounts that allow sign-in: 2.
RECOMMENDATION	Block sign-in on shared, room and equipment mailbox accounts. Access should come through mailbox permissions, not the account password.
ESTIMATED EFFORT	1 hour
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/microsoft-365/admin/email/about-shared-mailboxes
BENCHMARKS	CIS 1.2.2

2 affected items (listed in the HTML report and FindingDetails.csv)

Warning

External sender tagging is enabled in Outlook

Low severity EX0-13

CURRENT STATE	External sender tagging is disabled.
RECOMMENDATION	Run Set-ExternalInOutlook -Enabled $true so Outlook marks mail from outside the organisation.
ESTIMATED EFFORT	0.5 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/powershell/module/exchangepowershell/set-externalinoutlook
BENCHMARKS	CIS 6.2.3; MS.EXO.7.1v1

Warning

Calendar details are not shared anonymously

Low severity EX0-14

CURRENT STATE	Anonymous calendar publishing is allowed.
RECOMMENDATION	Remove the Anonymous entry from the default sharing policy, or limit it to free/busy only.
ESTIMATED EFFORT	0.5 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/exchange/sharing/sharing-policies/sharing-policies
BENCHMARKS	CIS 1.3.3; MS.EXO.6.2v1

1 affected item (listed in the HTML report and FindingDetails.csv)

Warning

Outlook on the web third-party storage is disabled

Low severity EX0-15

CURRENT STATE	Third-party storage providers are available in Outlook on the web.
RECOMMENDATION	Set AdditionalStorageProvidersAvailable to False on OWA mailbox policies so users cannot attach files from personal storage such as Dropbox.
ESTIMATED EFFORT	0.5 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/powershell/module/exchangepowershell/set-owamailboxpolicy
BENCHMARKS	CIS 6.5.3

1 affected item (listed in the HTML report and FindingDetails.csv)

Warning **POP and IMAP are disabled where not needed** — Low severity — EXO-17

CURRENT STATE	Mailboxes with POP or IMAP enabled: 5 of 25.
RECOMMENDATION	Disable POP and IMAP on mailboxes and in the CAS mailbox plans so new mailboxes do not get them. Keep only documented exceptions.
ESTIMATED EFFORT	1 hour
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/exchange/clients-and-mobile-in-exchange-online/pop3-and-imap4/enable-or-disable-pop3-or-imap4-access

5 affected items (listed in the HTML report and FindingDetails.csv)

Warning **Mailboxes approaching their quota** — Low severity — EXO-19

CURRENT STATE	Mailboxes above 90% of quota: 1.
RECOMMENDATION	Enable archiving or auto-expanding archiving, or apply retention to mailboxes above 90% of their send quota.
ESTIMATED EFFORT	1 hour
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/purview/autoexpanding-archiving

1 affected item (listed in the HTML report and FindingDetails.csv)

Info **Mail connectors** — Info severity — EXO-20

CURRENT STATE	Connectors: 0 inbound, 0 outbound.
RECOMMENDATION	Confirm each connector is still needed. If mail is filtered by a third-party gateway before Microsoft 365, enable Enhanced Filtering for Connectors and lock down direct delivery.
REFERENCE	https://learn.microsoft.com/exchange/mail-flow-best-practices/use-connectors-to-configure-mail-flow/enhanced-filtering-for-connectors

Pass **Unified audit logging is enabled** — High severity — EXO-01

CURRENT STATE	Unified audit log ingestion is enabled.
REFERENCE	https://learn.microsoft.com/purview/audit-log-enable-disable
BENCHMARKS	CIS 3.1.1; MS.SECURITYSUITE.5.1v1

Pass **Mailbox auditing is on by default** — High severity — EXO-02

CURRENT STATE	Mailbox auditing is on by default.
REFERENCE	https://learn.microsoft.com/purview/audit-mailboxes
BENCHMARKS	CIS 6.1.1; MS.EXO.13.1v1

Pass **Automatic forwarding to external recipients is blocked** — High severity — EXO-05

CURRENT STATE	External automatic forwarding is blocked.
REFERENCE	https://learn.microsoft.com/defender-office-365/outbound-spam-policies-external-email-forwarding
BENCHMARKS	CIS 6.2.1; MS.EXO.1.1v2

Pass Modern authentication is enabled for Exchange Online

Medium severity EXO-03

CURRENT STATE	Modern authentication is enabled.
REFERENCE	https://learn.microsoft.com/exchange/clients-and-mobile-in-exchange-online/enable-or-disable-modern-authentication-in-exchange-online
BENCHMARKS	CIS 6.5.1

Pass Anti-malware common attachment filter and ZAP are on

Medium severity EXO-12

CURRENT STATE	Default: attachment filter and ZAP on.
REFERENCE	https://learn.microsoft.com/defender-office-365/anti-malware-policies-configure
BENCHMARKS	CIS 2.1.2; MS.SECURITYSUITE.1.1v1; MS.SECURITYSUITE.1.2v1

Pass Users can report suspicious messages

Low severity EXO-18

CURRENT STATE	Report to Microsoft: True; to custom mailbox: False
REFERENCE	https://learn.microsoft.com/defender-office-365/submissions-user-reported-messages-custom-mailbox
BENCHMARKS	CIS 8.6.1

Email authentication

Fail SPF records are valid

High severity DNS-01

CURRENT STATE	Mail domains with SPF problems: 1 of 2.
RECOMMENDATION	Publish exactly one SPF record per domain that includes spf.protection.outlook.com and every other legitimate sender, ending in -all or ~all.
ESTIMATED EFFORT	1 hour
PRIORITY	**P1**
REFERENCE	https://learn.microsoft.com/defender-office-365/email-authentication-spf-configure
BENCHMARKS	CIS 2.1.8; MS.EXO.2.2v3

1 affected item (listed in the HTML report and FindingDetails.csv)

Fail DKIM signing is enabled for every mail domain

High severity DNS-02

CURRENT STATE	Email domains not DKIM signing: 1 of 2.
RECOMMENDATION	Publish the selector1 and selector2 CNAME records and enable DKIM signing in Defender for each custom domain.
ESTIMATED EFFORT	1 hour
PRIORITY	**P1**
REFERENCE	https://learn.microsoft.com/defender-office-365/email-authentication-dkim-configure
BENCHMARKS	CIS 2.1.9; MS.EXO.3.1v1

1 affected item (listed in the HTML report and FindingDetails.csv)

Fail DMARC is published and enforced

High severity DNS-03

CURRENT STATE	Domains without DMARC: 2; not enforcing: 1.
RECOMMENDATION	Publish DMARC for every domain, start at p=none with reporting, then move to p=quarantine and p=reject once legitimate senders pass SPF or DKIM.
ESTIMATED EFFORT	1 hour
PRIORITY	**P1**
REFERENCE	https://learn.microsoft.com/defender-office-365/email-authentication-dmarc-configure
BENCHMARKS	CIS 2.1.10; MS.EXO.4.1v1; MS.EXO.4.2v1

3 affected items (listed in the HTML report and FindingDetails.csv)

Warning Domains that do not send mail are locked down

Low severity DNS-05

CURRENT STATE	Non-mail domains that could be spoofed: 1.
RECOMMENDATION	For parked or non-mail domains publish v=spf1 -all and a DMARC record with p=reject so they cannot be spoofed.
ESTIMATED EFFORT	1 hour
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/defender-office-365/email-authentication-spf-configure
BENCHMARKS	CIS 2.1.8

1 affected item (listed in the HTML report and FindingDetails.csv)

Info Mail routing (MX) and MTA-STS

Info severity DNS-06

CURRENT STATE	Custom domains: 3; routed through a third party or on-premises system: 1.
RECOMMENDATION	Confirm MX routing matches the intended design. Consider MTA-STS to enforce TLS for inbound mail.
REFERENCE	https://learn.microsoft.com/purview/enhancing-mail-flow-with-mta-sts

3 affected items (listed in the HTML report and FindingDetails.csv)

Pass DMARC aggregate reporting is configured

Low severity DNS-04

CURRENT STATE	All DMARC records include aggregate reporting.
REFERENCE	https://learn.microsoft.com/defender-office-365/email-authentication-dmarc-configure
BENCHMARKS	CIS 2.1.10; MS.EXO.4.4v1

SharePoint and OneDrive

Warning Anonymous (Anyone) sharing links are controlled

Medium severity SPO-01

CURRENT STATE	Anyone links (no sign-in) are allowed at tenant level.
RECOMMENDATION	Restrict tenant sharing to "New and existing guests" unless Anyone links are a business need. If they are, set link expiry and view-only defaults and limit them to specific sites.
ESTIMATED EFFORT	2 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/sharepoint/turn-external-sharing-on-or-off
BENCHMARKS	CIS 7.2.3; MS.SHAREPOINT.1.1v1

Warning Guests cannot reshare content they do not own

Medium severity SPO-02

CURRENT STATE	Guests can reshare content they do not own.
RECOMMENDATION	Turn off "Allow guests to share items they don't own".
ESTIMATED EFFORT	0.5 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/sharepoint/turn-external-sharing-on-or-off
BENCHMARKS	CIS 7.2.5

Warning Guests must sign in with the invited account

Medium severity SPO-03

CURRENT STATE	Sharing invitations can be accepted by a different account.
RECOMMENDATION	Require guests to accept sharing invitations with the same account the invitation was sent to.
ESTIMATED EFFORT	0.5 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/powershell/module/sharepoint-online/set-spotenant

Warning Legacy authentication is blocked for SharePoint

Medium severity SPO-04

CURRENT STATE	Legacy authentication protocols are allowed.
RECOMMENDATION	Disable legacy authentication protocols for SharePoint and OneDrive (Set-SPOTenant -LegacyAuthProtocolsEnabled $false).
ESTIMATED EFFORT	0.5 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/powershell/module/sharepoint-online/set-spotenant
BENCHMARKS	CIS 7.2.1

Warning

Idle session sign-out is configured

Low severity SPO-06

CURRENT STATE	Idle session sign-out is not enabled.
RECOMMENDATION	Enable idle session sign-out for unmanaged devices so browser sessions on shared or personal computers end automatically.
ESTIMATED EFFORT	1 hour
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/sharepoint/sign-out-inactive-users
BENCHMARKS	CIS 1.3.2

Info

External sharing is limited by domain where appropriate

Low severity SPO-05

CURRENT STATE	Sharing is not restricted by domain.
RECOMMENDATION	Consider an allow list of partner domains, or a block list of personal email domains, if the client only collaborates with known organisations.
REFERENCE	https://learn.microsoft.com/sharepoint/restricted-domains-sharing
BENCHMARKS	CIS 7.2.6; MS.SHAREPOINT.1.3v1

Info

OneDrive sync is limited to managed devices

Low severity SPO-07

CURRENT STATE	OneDrive sync is allowed on any device. Check whether Conditional Access covers unmanaged devices.
RECOMMENDATION	Restrict the OneDrive sync app to domain-joined computers, or use Conditional Access to block downloads on unmanaged devices.
REFERENCE	https://learn.microsoft.com/sharepoint/allow-syncing-only-on-specific-domains

Info

Inactive SharePoint sites

Low severity SPO-09

CURRENT STATE	Sites with no activity in 180+ days: 2 of 6.
RECOMMENDATION	Confirm with owners whether inactive sites can be archived or deleted, or apply a site lifecycle policy.
REFERENCE	https://learn.microsoft.com/sharepoint/site-lifecycle-management

2 affected items (listed in the HTML report and FindingDetails.csv)

Pass

Usage reports show real names

Info severity SPO-08

CURRENT STATE	Usage reports show real names.
REFERENCE	https://learn.microsoft.com/microsoft-365/troubleshoot/miscellaneous/reports-show-anonymous-user-name

Teams and groups

Warning Every group and Team has an owner

Medium severity COL-02

CURRENT STATE	Microsoft 365 groups: 3; without an owner: 1; single owner: 1.
RECOMMENDATION	Assign at least two owners to every Team and Microsoft 365 group, and enable the ownerless group policy.
ESTIMATED EFFORT	2 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/microsoft-365/admin/create-groups/manage-groups

2 affected items (listed in the HTML report and FindingDetails.csv)

Manual check Teams external access and anonymous meeting join

Medium severity COL-05

CURRENT STATE	Teams policy settings are not readable through delegated Graph access. Check in the Teams admin centre.
RECOMMENDATION	In the Teams admin centre, confirm external access is limited to trusted domains (or blocked for unmanaged Teams accounts), anonymous users cannot start meetings, and lobby settings stop anonymous users joining directly.
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/microsoftteams/trusted-organizations-external-meetings-chat
BENCHMARKS	CIS 8.2.1; CIS 8.5.1; MS.TEAMS.2.1v2

Info Microsoft 365 group and Team creation is governed

Low severity COL-01

CURRENT STATE	Default settings: all users can create Microsoft 365 groups and Teams.
RECOMMENDATION	Decide with the client whether all users can create Teams. If not, limit creation to a security group, and consider a naming policy and expiry.
REFERENCE	https://learn.microsoft.com/microsoft-365/solutions/manage-creation-of-groups
BENCHMARKS	CIS 5.1.3.4

Info Groups and Teams with guest members

Low severity COL-03

CURRENT STATE	Groups or Teams with guest members: 1.
RECOMMENDATION	Review guest membership with each owner, or set up an Entra access review for groups with guests.
REFERENCE	https://learn.microsoft.com/entra/id-governance/create-access-review

1 affected item (listed in the HTML report and FindingDetails.csv)

Info Public groups and Teams

Low severity COL-04

CURRENT STATE	Public groups or Teams: 1.
RECOMMENDATION	Confirm public Teams contain nothing sensitive. Anyone in the organisation can join a public Team and read its files.
REFERENCE	https://learn.microsoft.com/microsoftteams/manage-teams-in-modern-portal
BENCHMARKS	CIS 1.2.1

1 affected item (listed in the HTML report and FindingDetails.csv)

Intune and devices

Fail Compliance policies cover every enrolled platform

High severity END-01

CURRENT STATE	No assigned compliance policy for: Android
RECOMMENDATION	Create and assign a compliance policy for each platform in use (Windows, iOS/iPadOS, Android, macOS) covering encryption, OS version, password and Defender status.
ESTIMATED EFFORT	4 hours
PRIORITY	**P1**
REFERENCE	https://learn.microsoft.com/intune/intune-service/protect/device-compliance-get-started

1 affected item (listed in the HTML report and FindingDetails.csv)

Fail Windows devices are encrypted

High severity END-05

CURRENT STATE	Windows devices reporting as not encrypted: 2 of 6.
RECOMMENDATION	Deploy a BitLocker disk encryption policy from Endpoint security and escrow recovery keys to Entra ID.
ESTIMATED EFFORT	4 hours
PRIORITY	**P1**
REFERENCE	https://learn.microsoft.com/intune/intune-service/protect/encrypt-devices

2 affected items (listed in the HTML report and FindingDetails.csv)

Fail Windows devices run a supported version

High severity END-06

CURRENT STATE	Windows devices: 6; on Windows 10: 1; on Windows 11 below the minimum build: 1.
RECOMMENDATION	Upgrade Windows 10 devices (out of support since 14 October 2025 unless covered by ESU) and Windows 11 builds below the minimum to a supported release.
ESTIMATED EFFORT	4 hours
PRIORITY	**P1**
REFERENCE	https://learn.microsoft.com/windows/release-health/windows11-release-information

2 affected items (listed in the HTML report and FindingDetails.csv)

Warning Devices without a compliance policy are marked non-compliant

Medium severity END-02

CURRENT STATE	Devices with no compliance policy are marked compliant.
RECOMMENDATION	Set "Mark devices with no compliance policy assigned as" to Not compliant so Conditional Access cannot be bypassed by unassigned devices.
ESTIMATED EFFORT	0.5 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/intune/intune-service/protect/device-compliance-get-started
BENCHMARKS	CIS 4.1

Warning

Managed devices are compliant

Medium severity END-03

CURRENT STATE	Devices not compliant: 1 of 10.
RECOMMENDATION	Work through non-compliant devices by reason in Intune and fix or retire them.
ESTIMATED EFFORT	3 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/intune/intune-service/protect/compliance-policy-monitor

1 affected item (listed in the HTML report and FindingDetails.csv)

Warning

Endpoint security policies are deployed

Medium severity END-07

CURRENT STATE	Missing: Firewall, Endpoint detection and response.
RECOMMENDATION	Deploy and assign Endpoint security policies for antivirus, disk encryption, firewall, EDR, attack surface reduction and account protection (LAPS).
ESTIMATED EFFORT	6 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/intune/intune-service/protect/endpoint-security

Warning

App protection policies protect mobile data

Medium severity END-09

CURRENT STATE	Assigned policies: iOS 1, Android 0
RECOMMENDATION	Create and assign app protection policies for iOS and Android so corporate data in Outlook, Teams and OneDrive is protected on personal phones.
ESTIMATED EFFORT	3 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/intune/intune-service/apps/app-protection-policy

Warning

Devices are checking in with Intune

Low severity END-04

CURRENT STATE	Devices not synced for 30+ days: 1.
RECOMMENDATION	Investigate devices that have not synced for 30 days. Retire lost or replaced devices.
ESTIMATED EFFORT	1 hour
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/intune/intune-service/remote-actions/devices-wipe

1 affected item (listed in the HTML report and FindingDetails.csv)

Warning Personal Windows device enrolment is blocked

Low severity END-08

CURRENT STATE	Personally owned Windows devices can enrol.
RECOMMENDATION	Block personally owned Windows enrolment in the default platform restriction unless BYOD Windows is in scope, and use Autopilot for corporate devices.
ESTIMATED EFFORT	1 hour
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/intune/intune-service/enrollment/enrollment-restrictions-set
BENCHMARKS	CIS 4.2

Warning Windows update management

Info severity END-10

CURRENT STATE	Intune update rings: 1 (1 assigned). Patching is expected through the RMM, so check for overlap.
RECOMMENDATION	Confirm Windows updates are managed by exactly one tool. If updates are handled by the RMM, avoid assigning Intune update rings to the same devices.
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/intune/intune-service/protect/windows-update-for-business-configure

1 affected item (listed in the HTML report and FindingDetails.csv)

Info Device estate summary

Info severity END-12

CURRENT STATE	Intune managed: 10 (Android 1, iOS 2, iPadOS 1, Windows 6); Entra registered or joined: 15; Autopilot registered: 5
RECOMMENDATION	Use the Devices inventory to agree the device estate with the client and identify devices that should be enrolled.
REFERENCE	https://learn.microsoft.com/intune/intune-service/fundamentals/deployment-guide-enrollment

Pass No jailbroken or rooted devices

High severity END-11

CURRENT STATE	No jailbroken or rooted devices.
REFERENCE	https://learn.microsoft.com/intune/intune-service/protect/compliance-policy-create-ios

Microsoft Secure Score

Fail Microsoft Secure Score

Medium severity SEC-01

CURRENT STATE	Secure Score 312 of 640 (48.8%). Comparable organisations (TotalSeats) average 44.6.
RECOMMENDATION	Work through the Secure Score improvement actions in the Secure Score inventory, starting with the largest gaps that have low user impact.
PRIORITY	**P2**
REFERENCE	https://learn.microsoft.com/defender-xdr/microsoft-secure-score

Permissions

Warning Mailbox permissions do not reference deleted or disabled accounts

Low severity PRM-02

CURRENT STATE	Permissions referencing deleted or disabled accounts: 2.
RECOMMENDATION	Remove permissions granted to deleted accounts (shown as SIDs) and to disabled accounts.
ESTIMATED EFFORT	1 hour
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/exchange/recipients-in-exchange-online/manage-permissions-for-recipients

2 affected items (listed in the HTML report and FindingDetails.csv)

Info Mailbox delegation is reviewed

Low severity PRM-01

CURRENT STATE	Mailbox delegations: 7 (2 on user mailboxes).
RECOMMENDATION	Ask the client to confirm Full Access, Send As and Send on Behalf permissions on user mailboxes. Delegation to user mailboxes should be rare and documented.
REFERENCE	https://learn.microsoft.com/exchange/recipients-in-exchange-online/manage-permissions-for-recipients

2 affected items (listed in the HTML report and FindingDetails.csv)

Microsoft Defender XDR

Fail Devices are onboarded to Defender for Endpoint

High severity DEF-01

CURRENT STATE	Onboarded devices: 4. Intune managed Windows and macOS devices: 4 of 6 onboarded (66.7%).
RECOMMENDATION	Onboard every Windows and macOS device to Defender for Endpoint or Defender for Business, ideally with the Intune EDR onboarding policy, and confirm each device reports in the Defender portal.
ESTIMATED EFFORT	4 hours
PRIORITY	**P1**
REFERENCE	https://learn.microsoft.com/defender-endpoint/onboarding

2 affected items (listed in the HTML report and FindingDetails.csv)

Fail No critical vulnerabilities with public exploits

High severity DEF-04

CURRENT STATE	Software with critical vulnerabilities: 2 (2 with public exploits). Software with high or critical vulnerabilities: 3.
RECOMMENDATION	Patch the listed software through the RMM or Intune, starting with critical vulnerabilities that have public exploits. Remove software that is no longer needed and make sure third-party applications are in the patch policy.
ESTIMATED EFFORT	8 hours
PRIORITY	**P1**
REFERENCE	https://learn.microsoft.com/defender-vulnerability-management/tvm-weaknesses

3 affected items (listed in the HTML report and FindingDetails.csv)

Fail **Security incidents are triaged and resolved** High severity DEF-08

CURRENT STATE	Incidents in the last 90 days: 2. Open: 1 (1 high severity). High-severity incidents open for more than 7 days: 1.
RECOMMENDATION	Assign, investigate and resolve open incidents, starting with high severity. Make sure incident notifications reach your service desk or SOC.
ESTIMATED EFFORT	2 hours
PRIORITY	**P1**
REFERENCE	https://learn.microsoft.com/defender-xdr/manage-incidents

1 affected item (listed in the HTML report and FindingDetails.csv)

Warning **Discovered devices that can be onboarded** Medium severity DEF-02

CURRENT STATE	Discovered devices that can be onboarded: 2. Unsupported discovered devices: 1.
RECOMMENDATION	Review devices found by device discovery that are not onboarded. Onboard company devices, and identify or isolate unknown ones.
ESTIMATED EFFORT	2 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/defender-endpoint/device-discovery

2 affected items (listed in the HTML report and FindingDetails.csv)

Warning **Onboarded devices report a healthy sensor** Medium severity DEF-03

CURRENT STATE	Onboarded devices with an unhealthy or inactive sensor: 1 of 4 (Inactive 1).
RECOMMENDATION	Investigate devices with an inactive, misconfigured or impaired sensor. Remove retired devices, and fix connectivity or service issues on the rest so they are protected and visible.
ESTIMATED EFFORT	2 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/defender-endpoint/fix-unhealthy-sensors

1 affected item (listed in the HTML report and FindingDetails.csv)

Warning **High-impact secure configuration gaps are addressed** Medium severity DEF-05

CURRENT STATE	Secure configuration gaps: 4 (3 high impact, rated 7 or more out of 10).
RECOMMENDATION	Work through the high-impact security recommendations (impact 7 or more), usually by adjusting Intune endpoint security, attack surface reduction or baseline policies, and test with a pilot group first.
ESTIMATED EFFORT	6 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/defender-vulnerability-management/tvm-security-recommendation

4 affected items (listed in the HTML report and FindingDetails.csv)

Warning **No devices with a high exposure level** Medium severity DEF-06

CURRENT STATE	Devices with high exposure: 1; medium exposure: 1; onboarded: 4.
RECOMMENDATION	Reduce the exposure of the listed devices by applying their security recommendations and patches, starting with devices used by administrators.
ESTIMATED EFFORT	2 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/defender-vulnerability-management/tvm-exposure-score

1 affected item (listed in the HTML report and FindingDetails.csv)

Warning **Defender for Endpoint is connected to Intune** Medium severity DEF-07

CURRENT STATE	Connector state: available; Windows devices connected: No; last heartbeat 07/09/2026.
RECOMMENDATION	Turn on the Microsoft Intune connection in Defender (Settings, Endpoints, Advanced features) and the Defender for Endpoint connector in Intune, then use device risk in compliance policies.
ESTIMATED EFFORT	1 hour
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/intune/intune-service/protect/advanced-threat-protection-configure

Info **Attack simulation training is used** Low severity DEF-09

CURRENT STATE	Defender for Office 365 Plan 2 is not licensed.
RECOMMENDATION	Run phishing simulations at least quarterly with automatic training for users who click, and report the trend to management.
REFERENCE	https://learn.microsoft.com/defender-office-365/attack-simulation-training-get-started

Microsoft Purview

Warning **Data loss prevention policies protect sensitive data** Medium severity PUR-01

CURRENT STATE	DLP policies: 1 (0 enforced, 1 in simulation). Workloads with an enforced policy: none.
RECOMMENDATION	Create DLP policies for UK financial and personal data (for example bank details, National Insurance and passport numbers) across Exchange, SharePoint, OneDrive and Teams. Start in simulation mode with policy tips, review matches with the client, then block external sharing.
ESTIMATED EFFORT	6 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/purview/dlp-create-deploy-policy
BENCHMARKS	CIS 3.2.1; MS.SECURITYSUITE.3.1v1; MS.SECURITYSUITE.3.2v1

1 affected item (listed in the HTML report and FindingDetails.csv)

Warning

Retention policies cover email, files and Teams

Medium severity PUR-02

CURRENT STATE	Active retention policies: 1. Covered org-wide: Exchange. Not covered: SharePoint, OneDrive, Teams.
RECOMMENDATION	Agree retention periods with the client (for example 6 or 7 years for finance and HR records) and apply org-wide retention policies to Exchange, SharePoint, OneDrive and Teams so deleted or changed content can be recovered.
ESTIMATED EFFORT	3 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/purview/create-retention-policies

1 affected item (listed in the HTML report and FindingDetails.csv)

Warning

Sensitivity labels are defined and published

Medium severity PUR-03

CURRENT STATE	Sensitivity labels: 0 (0 with encryption). Active label policies: 0. No sensitivity labels are defined.
RECOMMENDATION	Agree a simple label taxonomy with the client (Public, Internal, Confidential, Highly confidential), add encryption and markings where needed, publish the labels with a default label and justification for downgrades, and enable labels for SharePoint and Teams sites.
ESTIMATED EFFORT	8 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/purview/get-started-with-sensitivity-labels
BENCHMARKS	CIS 3.3.1

Warning

Default alert policies are enabled and notify administrators

Medium severity PUR-04

CURRENT STATE	Alert policies: 6 (5 default). Disabled default policies: 1. Enabled high-severity policies with no email notification: 1.
RECOMMENDATION	Re-enable disabled default alert policies and send high-severity alerts to a monitored support or client mailbox rather than individual administrators.
ESTIMATED EFFORT	1 hour
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/purview/alert-policies
BENCHMARKS	MS.SECURITYSUITE.4.1v1

2 affected items (listed in the HTML report and FindingDetails.csv)

Info

Purview configuration summary

Info severity PUR-05

CURRENT STATE	DLP policies 1; retention policies 1; sensitivity labels 0; label policies 0; alert policies 6; retention labels 1; eDiscovery cases 0.
RECOMMENDATION	Use the Purview inventories to agree the client's information protection and retention requirements.
REFERENCE	https://learn.microsoft.com/purview/purview

Governance

Manual check — Microsoft 365 data is backed up

Medium severity · GOV-01

CURRENT STATE	Backup coverage cannot be read from the tenant. Confirm the backup product, scope and last successful run.
RECOMMENDATION	Confirm Exchange, OneDrive, SharePoint and Teams are protected by a third-party backup or Microsoft 365 Backup, with retention that meets the client's requirements.
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/microsoft-365/backup/backup-overview

Intune connections

Fail — Apple MDM push certificate is valid

High severity · END-13

CURRENT STATE	The Apple MDM push certificate expires in 20 days (06/11/2026). Renew it with Apple ID it.fabrikam@personal.example.
RECOMMENDATION	Renew the Apple MDM push certificate in Intune (Devices, Enrolment, Apple) before it expires, using the same Apple ID that created it. Use a shared company Apple ID, not a personal one. If it expires, Apple devices stop receiving policy, and creating a new certificate with a different Apple ID means re-enrolling every Apple device.
ESTIMATED EFFORT	1 hour
PRIORITY	**P1**
REFERENCE	https://learn.microsoft.com/intune/intune-service/enrollment/apple-mdm-push-certificate-get

1 affected item (listed in the HTML report and FindingDetails.csv)

Warning — Apple Apps and Books (VPP) tokens are valid

Medium severity · END-15

CURRENT STATE	1 Apps and Books token is expiring soon or failing to sync.
RECOMMENDATION	Renew Apps and Books location tokens in Apple Business Manager and upload them to Intune before they expire, so purchased apps keep installing and updating.
ESTIMATED EFFORT	1 hour
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/intune/intune-service/apps/vpp-apps-ios

1 affected item (listed in the HTML report and FindingDetails.csv)

Warning — Android Enterprise is connected

Medium severity · END-16

CURRENT STATE	1 Android device is enrolled, but Managed Google Play is not connected. These devices are likely on device administrator management, which Microsoft no longer supports on devices with Google Mobile Services.
RECOMMENDATION	Connect Intune to Managed Google Play (Devices, Enrolment, Android) with a shared company Google account, and move any Android devices still on device administrator management to an Android Enterprise work profile or fully managed enrolment.
ESTIMATED EFFORT	2 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/intune/intune-service/enrollment/connect-intune-android-enterprise

Pass **Apple Business Manager enrolment tokens are valid and syncing** Medium severity END-14

CURRENT STATE	1 enrolment token is valid and syncing.
REFERENCE	https://learn.microsoft.com/intune/intune-service/enrollment/device-enrollment-program-enroll-ios

Intune configuration health

Warning **Policies apply without errors or conflicts** Medium severity END-18

CURRENT STATE	2 policies report errors or conflicts on devices (2 device results in error, 1 in conflict).
RECOMMENDATION	Open each listed policy in Intune, select the devices in error or conflict, and fix the failing settings. Conflicts mean two policies set the same setting to different values; keep one source for each setting.
ESTIMATED EFFORT	3 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/intune/intune-service/configuration/device-profile-monitor

2 affected items (listed in the HTML report and FindingDetails.csv)

Warning **Required apps install successfully** Medium severity END-28

CURRENT STATE	1 of 2 required apps has failed installs (2 device failures in total).
RECOMMENDATION	Open each listed app in Intune (Apps, Monitor, App install status), check the error codes on the failed devices, and fix the package, detection rule or requirement rules.
ESTIMATED EFFORT	3 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/intune/intune-service/apps/troubleshoot-app-install

1 affected item (listed in the HTML report and FindingDetails.csv)

Warning **Intune policies are assigned** Low severity END-17

CURRENT STATE	3 of 14 policies are not assigned.
RECOMMENDATION	Assign or delete policies that are not assigned to anyone. Unassigned policies are often drafts or leftovers that make it hard to see what is really applied, and they can be assigned by mistake later.
ESTIMATED EFFORT	1 hour
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/intune/intune-service/configuration/device-profile-assign

3 affected items (listed in the HTML report and FindingDetails.csv)

Warning **Device clean-up rule removes inactive devices** Low severity END-29

CURRENT STATE	No device clean-up rule is set, so devices that stop checking in stay in Intune indefinitely.
RECOMMENDATION	In Devices, Device clean-up rules, remove devices that have not checked in for 90 to 180 days, so stale records do not skew compliance reports and licence counts.
ESTIMATED EFFORT	0.5 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/intune/intune-service/remote-actions/devices-wipe#automatically-hide-devices-with-cleanup-rules

Windows security configuration

Fail **Windows Firewall is enforced on every profile** Medium severity END-21

CURRENT STATE	No assigned policy turns on Windows Firewall.
RECOMMENDATION	In Endpoint security, Firewall, create a Windows Firewall policy that turns the firewall on for the domain, private and public profiles, blocks inbound connections by default and stops local rules being merged on public networks. Assign it to all Windows devices.
ESTIMATED EFFORT	2 hours
PRIORITY	**P2**
REFERENCE	https://learn.microsoft.com/intune/intune-service/protect/endpoint-security-firewall-policy

Warning **Windows LAPS policy manages local administrator passwords** High severity END-19

CURRENT STATE	Assigned LAPS policy: Windows LAPS. Passwords are backed up to Microsoft Entra ID, rotated every 90 days.
RECOMMENDATION	In Endpoint security, Account protection, create a Local admin password solution (Windows LAPS) policy that backs up the password to Microsoft Entra ID, rotates it at least every 30 days and after use, and assign it to all Windows devices. Microsoft Entra LAPS must also be enabled in Entra device settings (IAM-25).
ESTIMATED EFFORT	2 hours
PRIORITY	**P2**
REFERENCE	https://learn.microsoft.com/intune/intune-service/protect/windows-laps-policy

Warning **BitLocker policy requires encryption and escrows recovery keys** High severity END-20

CURRENT STATE	BitLocker encryption is required (policy: BitLocker), but no assigned policy makes devices save recovery keys to Entra ID before encrypting.
RECOMMENDATION	In Endpoint security, Disk encryption, create a BitLocker policy that requires device encryption, uses silent encryption, and saves operating system drive recovery information to Microsoft Entra ID before encrypting. Assign it to all Windows devices.
ESTIMATED EFFORT	3 hours
PRIORITY	**P2**
REFERENCE	https://learn.microsoft.com/intune/intune-service/protect/encrypt-devices

Warning

Attack surface reduction rules are in block mode

High severity END-22

CURRENT STATE	7 rules configured: 4 in block mode, 3 in audit, warn or off. 2 of the three standard protection rules are not blocked.
RECOMMENDATION	Deploy the attack surface reduction rules from Endpoint security, Attack surface reduction. Put the three standard protection rules (vulnerable signed drivers, credential stealing from LSASS, persistence through WMI) into block mode straight away, run the others in audit mode for two to four weeks, review the audit events in Defender, then switch them to block.
ESTIMATED EFFORT	4 hours
PRIORITY	**P2**
REFERENCE	https://learn.microsoft.com/defender-endpoint/attack-surface-reduction-rules-deployment

4 affected items (listed in the HTML report and FindingDetails.csv)

Warning

Microsoft Defender Antivirus protections are on

Medium severity END-23

CURRENT STATE	Defender Antivirus gaps: potentially unwanted apps only audited, network protection not on, cloud block level below High.
RECOMMENDATION	In the Endpoint security antivirus policy, keep real-time, behaviour and cloud-delivered protection on, set the cloud block level to High, block potentially unwanted apps, turn on network protection in block mode, and send safe samples automatically.
ESTIMATED EFFORT	2 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/defender-endpoint/configure-microsoft-defender-antivirus-features

Warning

Windows Hello for Business is configured

Medium severity END-24

CURRENT STATE	Windows Hello for Business is not configured by Intune.
RECOMMENDATION	Turn on Windows Hello for Business for Entra joined devices (Devices, Enrolment, Windows Hello for Business, or an Account protection policy) with a PIN of at least six digits and biometrics allowed, so users sign in with a phishing-resistant credential instead of a password.
ESTIMATED EFFORT	3 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/windows/security/identity-protection/hello-for-business/configure

Warning

Security baselines are deployed and current

Medium severity END-25

CURRENT STATE	1 assigned baseline is on an old version or format.
RECOMMENDATION	Deploy the current Windows security baseline, and the Defender for Endpoint and Edge baselines where licensed, to a pilot group first and then to all Windows devices. When Microsoft releases a new baseline version, update the profile to it. Re-create baselines still in the old format.
ESTIMATED EFFORT	6 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/intune/intune-service/protect/security-baselines

1 affected item (listed in the HTML report and FindingDetails.csv)

Autopilot and enrolment

Warning **Autopilot profiles are assigned and users are not local administrators** Medium severity END-26

CURRENT STATE	5 registered devices; 1 deployment profile. 2 devices have no profile. 1 profile makes users local administrators.
RECOMMENDATION	Assign an Autopilot deployment profile to every registered device (for example through a dynamic group on the group tag or ZTDId), set the user account type to Standard so users are not local administrators, and use Microsoft Entra join rather than hybrid join for new devices.
ESTIMATED EFFORT	2 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/autopilot/profiles

3 affected items (listed in the HTML report and FindingDetails.csv)

Warning **Enrolment Status Page holds users until setup completes** Medium severity END-27

CURRENT STATE	The Enrolment Status Page is off, so users reach the desktop before apps and security policies are installed.
RECOMMENDATION	Turn on the Enrolment Status Page for Autopilot devices with Show app and profile configuration progress, block device use until required apps and security policies are installed, and allow a reset on failure. Without it users reach the desktop before BitLocker, Defender and other policies apply.
ESTIMATED EFFORT	2 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/intune/intune-service/enrollment/windows-enrollment-status

Compliance

Warning **Windows compliance policy checks the essentials** Medium severity END-30

CURRENT STATE	Windows compliance does not require: Secure Boot, TPM, Defender for Endpoint risk.
RECOMMENDATION	Make the assigned Windows compliance policy require BitLocker, Secure Boot, code integrity, a TPM, a minimum OS version, an active firewall and antivirus, and the Defender for Endpoint machine risk score where licensed, so Conditional Access only allows healthy devices.
ESTIMATED EFFORT	2 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/intune/intune-service/protect/compliance-policy-create-windows

3 affected items (listed in the HTML report and FindingDetails.csv)

Warning **Mobile compliance policies require a passcode and block jailbroken devices** Medium severity END-31

CURRENT STATE	Gaps for iOS/iPadOS, Android.
RECOMMENDATION	Make the assigned iOS/iPadOS and Android compliance policies require a device passcode, block jailbroken or rooted devices (and require Play Integrity on Android), and set a minimum OS version.
ESTIMATED EFFORT	2 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/intune/intune-service/protect/compliance-policy-create-ios

2 affected items (listed in the HTML report and FindingDetails.csv)

Pass **Devices that stop checking in become non-compliant within 30 days** Low severity END-32

CURRENT STATE	Devices that do not check in for 30 days become non-compliant.
REFERENCE	https://learn.microsoft.com/intune/intune-service/protect/device-compliance-get-started#compliance-policy-settings

Azure governance and cost

Fail **Subscription owners are limited and not guests** High severity AZ-19

CURRENT STATE	4 privileged role assignments at subscription or management group level (2 to users directly, 1 to service principals, 1 to guests).
RECOMMENDATION	Keep subscription Owner and User Access Administrator to two or three named admins through groups, make them eligible through Privileged Identity Management rather than permanent, remove guests and unused service principals, and review the CSP partner access. (MCSB PA-1, PA-7)
ESTIMATED EFFORT	2 hours
PRIORITY	**P1**
REFERENCE	https://learn.microsoft.com/azure/role-based-access-control/best-practices

4 affected items (listed in the HTML report and FindingDetails.csv)

Warning **The Azure activity log is kept beyond 90 days** Medium severity AZ-21

CURRENT STATE	1 subscription does not export the activity log, so changes are only kept for 90 days.
RECOMMENDATION	Send each subscription's activity log (administrative, security, policy and alert categories) to a Log Analytics workspace or storage account with at least one year of retention, so changes can be investigated after the 90-day default. (MCSB LT-3, LT-6)
ESTIMATED EFFORT	1 hour
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/azure/azure-monitor/essentials/activity-log

1 affected item (listed in the HTML report and FindingDetails.csv)

Warning

Critical resources have delete locks

Low severity AZ-20

CURRENT STATE	1 of 2 vaults has no delete lock.
RECOMMENDATION	Add CanNotDelete locks to Recovery Services vaults, key vaults and other resources whose loss would be hard to recover from, so they cannot be deleted by mistake or by a compromised account.
ESTIMATED EFFORT	1 hour
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/azure/azure-resource-manager/management/lock-resources

1 affected item (listed in the HTML report and FindingDetails.csv)

Warning

No unattached disks or unused public IP addresses

Low severity AZ-22

CURRENT STATE	1 managed disk (128 GB) and 1 public IP address are not attached to anything.
RECOMMENDATION	Delete unattached managed disks and public IP addresses that are no longer needed (take a snapshot first if in doubt). They are charged whether or not they are used.
ESTIMATED EFFORT	1 hour
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/azure/virtual-machines/disks-find-unattached-portal

2 affected items (listed in the HTML report and FindingDetails.csv)

Warning

Azure Advisor cost recommendations

Low severity AZ-23

CURRENT STATE	2 cost recommendations with potential savings of about GBP 3,610 a year.
RECOMMENDATION	Review the Azure Advisor cost recommendations with the client: right-size or shut down under-used virtual machines, buy reservations or savings plans for steady workloads, and apply Azure Hybrid Benefit where Windows Server and SQL licences allow.
ESTIMATED EFFORT	2 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/azure/advisor/advisor-cost-recommendations

2 affected items (listed in the HTML report and FindingDetails.csv)

Warning

Every subscription has a budget alert

Low severity AZ-25

CURRENT STATE	1 subscription has no budget.
RECOMMENDATION	Create a monthly budget on each subscription with email alerts at 80% and 100% of forecast and actual spend, sent to the client and their IT provider, so unexpected costs are caught early.
ESTIMATED EFFORT	0.5 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/azure/cost-management-billing/costs/tutorial-acm-create-budgets

1 affected item (listed in the HTML report and FindingDetails.csv)

Warning **The Microsoft cloud security benchmark policy is assigned** Low severity AZ-26

CURRENT STATE	1 subscription does not have the Microsoft cloud security benchmark initiative assigned.
RECOMMENDATION	Keep the Microsoft cloud security benchmark initiative (the Defender for Cloud default policy) assigned to every subscription or the management group above them, so Defender for Cloud can assess the resources.
ESTIMATED EFFORT	1 hour
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/azure/defender-for-cloud/security-policy-concept

1 affected item (listed in the HTML report and FindingDetails.csv)

Warning **Network Watcher is enabled where networks exist** Low severity AZ-27

CURRENT STATE	Network Watcher is missing in 1 region.
RECOMMENDATION	Make sure Network Watcher is enabled in every region that has virtual networks, and turn on virtual network flow logs for production networks. (MCSB LT-4)
ESTIMATED EFFORT	0.5 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/azure/network-watcher/network-watcher-create

1 affected item (listed in the HTML report and FindingDetails.csv)

Info **Azure subscriptions in scope** Info severity AZ-01

CURRENT STATE	2 subscriptions are visible (1 CSP, 1 Pay as you go). Some settings could not be read in Fabrikam Dev, because the account's role there does not allow it.
RECOMMENDATION	Confirm with the client that every Azure subscription is listed. Subscriptions where the signed-in account has no role are not visible, for example a pay-as-you-go or Enterprise Agreement subscription outside the CSP relationship. Give the review account Reader (and Security Reader) on any that are missing.
REFERENCE	https://learn.microsoft.com/azure/cost-management-billing/manage/view-all-accounts

2 affected items (listed in the HTML report and FindingDetails.csv)

Azure security

Fail **Microsoft Defender for Cloud protects servers and data services** High severity AZ-02

CURRENT STATE	3 Defender plans are not on for resources in use, including Defender for Servers in 1 subscription. The plans in Fabrikam Dev could not be read (the account needs Security Reader or Reader there).
RECOMMENDATION	Turn on Defender for Servers (Plan 1 at least, which includes Defender for Endpoint) in every subscription with virtual machines or Arc servers, and Defender for Storage, SQL and Key Vault where those resources hold client data. (MCSB LT-1, ES-1)
ESTIMATED EFFORT	3 hours
PRIORITY	**P1**
REFERENCE	https://learn.microsoft.com/azure/defender-for-cloud/connect-azure-subscription

4 affected items (listed in the HTML report and FindingDetails.csv)

Fail

Management ports are not open to the internet

High severity AZ-06

CURRENT STATE	1 rule in use allows management or database ports from the internet.
RECOMMENDATION	Remove network security group rules that allow RDP, SSH, WinRM, SMB or database ports from Any or Internet. Use Azure Bastion, Defender for Cloud just-in-time access or a VPN for administration, and limit any remaining rules to known source addresses. (MCSB NS-1, NS-2)
ESTIMATED EFFORT	2 hours
PRIORITY	**P1**
REFERENCE	https://learn.microsoft.com/azure/bastion/bastion-overview

2 affected items (listed in the HTML report and FindingDetails.csv)

Fail

Servers run a supported operating system

High severity AZ-12

CURRENT STATE	3 servers are out of support. 1 more server is on extended security updates or loses support within six months.
RECOMMENDATION	Upgrade or replace servers whose operating system is out of support (Windows Server 2012 and 2012 R2 extended security updates ended on 13 October 2026; Windows Server 2016 support ends on 12 January 2027). Plan upgrades for anything ending within six months. (MCSB PV-6)
ESTIMATED EFFORT	8 hours
PRIORITY	**P1**
REFERENCE	https://learn.microsoft.com/lifecycle/products/

4 affected items (listed in the HTML report and FindingDetails.csv)

Fail

Azure servers are onboarded to Defender for Endpoint

High severity AZ-13

CURRENT STATE	2 of 3 running servers are not onboarded to Defender for Endpoint.
RECOMMENDATION	Onboard every running server to Microsoft Defender for Endpoint (Defender for Servers deploys the MDE extension automatically). Replace the retired Log Analytics agent (MMA/OMS) with the Azure Monitor agent where monitoring data is needed. (MCSB ES-1, LT-1)
ESTIMATED EFFORT	3 hours
PRIORITY	**P1**
REFERENCE	https://learn.microsoft.com/azure/defender-for-cloud/integration-defender-for-endpoint

2 affected items (listed in the HTML report and FindingDetails.csv)

Fail

Storage accounts block public access and require TLS 1.2

High severity AZ-15

CURRENT STATE	1 of 2 storage accounts allows anonymous access, HTTP or old TLS.
RECOMMENDATION	On every storage account, turn off anonymous blob access, require secure transfer with TLS 1.2 or later, restrict network access to selected networks or private endpoints, and disable shared key access where applications support Entra ID authentication. (MCSB NS-2, DP-3, IM-1)
ESTIMATED EFFORT	2 hours
PRIORITY	**P1**
REFERENCE	https://learn.microsoft.com/azure/storage/common/security-recommendations

2 affected items (listed in the HTML report and FindingDetails.csv)

Fail

App Service apps enforce HTTPS and TLS 1.2

Medium severity AZ-18

CURRENT STATE	1 of 1 apps allows HTTP, old TLS or plain FTP.
RECOMMENDATION	Turn on HTTPS Only, set the minimum TLS version to 1.2, and set FTP to FTPS only or disabled on every App Service app and function app. (MCSB DP-3)
ESTIMATED EFFORT	1 hour
PRIORITY	**P2**
REFERENCE	https://learn.microsoft.com/azure/app-service/overview-security

1 affected item (listed in the HTML report and FindingDetails.csv)

Warning

Defender for Cloud secure score

Medium severity AZ-03

CURRENT STATE	Secure score: Fabrikam Production 48%, Fabrikam Dev 62%.
RECOMMENDATION	Work through the Defender for Cloud recommendations (see the Defender for Cloud recommendations inventory), starting with high-severity items on the most resources, to raise the secure score above 70%.
ESTIMATED EFFORT	8 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/azure/defender-for-cloud/secure-score-security-controls

2 affected items (listed in the HTML report and FindingDetails.csv)

Warning

Microsoft cloud security benchmark compliance

Medium severity AZ-04

CURRENT STATE	65.4% of assessed MCSB controls pass (70 passed, 37 failed across 2 subscriptions).
RECOMMENDATION	Use the Defender for Cloud regulatory compliance dashboard to work through the failed Microsoft cloud security benchmark (MCSB) controls listed here. Each one links to the recommendations that make it pass.
ESTIMATED EFFORT	8 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/security/benchmark/azure/overview

3 affected items (listed in the HTML report and FindingDetails.csv)

Warning

Virtual machines do not have public IP addresses

Medium severity AZ-07

CURRENT STATE	1 of 4 virtual machines has a public IP address. There is no Azure Bastion host.
RECOMMENDATION	Remove public IP addresses from virtual machines that do not publish a service. Publish services through a load balancer, Application Gateway or Front Door, and administer servers through Azure Bastion or a VPN. (MCSB NS-1)
ESTIMATED EFFORT	2 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/azure/virtual-network/ip-services/remove-public-ip-address-vm

1 affected item (listed in the HTML report and FindingDetails.csv)

Warning

Subnets are protected by network security groups

Medium severity AZ-08

CURRENT STATE	2 of 3 workload subnets have no network security group.
RECOMMENDATION	Associate a network security group with every workload subnet so traffic between subnets and from the internet is filtered by default. Gateway, Bastion and Firewall subnets are excluded. (MCSB NS-1)
ESTIMATED EFFORT	2 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/azure/virtual-network/network-security-groups-overview

2 affected items (listed in the HTML report and FindingDetails.csv)

Warning

Key vaults have purge protection and restricted network access

Medium severity AZ-16

CURRENT STATE	1 of 1 key vaults has gaps.
RECOMMENDATION	Turn on purge protection, use the Azure RBAC permission model rather than access policies, and restrict network access to selected networks or private endpoints. (MCSB DP-8)
ESTIMATED EFFORT	1 hour
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/azure/key-vault/general/security-features

1 affected item (listed in the HTML report and FindingDetails.csv)

Warning

Servers have no outstanding critical or security updates

Medium severity AZ-28

CURRENT STATE	1 of 2 assessed servers is missing critical or security updates.
RECOMMENDATION	Install outstanding critical and security updates, and make sure every server is covered by one patching tool (the RMM or Azure Update Manager, not both). Turn on periodic assessment in Azure Update Manager so missing updates are visible. (MCSB PV-6)
ESTIMATED EFFORT	3 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/azure/update-manager/overview

1 affected item (listed in the HTML report and FindingDetails.csv)

Warning

Defender for Cloud alert emails reach the right people

Low severity AZ-05

CURRENT STATE	1 subscription has no working security alert email.
RECOMMENDATION	In Defender for Cloud, Environment settings, Email notifications, add your security team mailbox and the client contact, notify subscription owners, and send alerts of Medium severity or higher. (MCSB IR-2)
ESTIMATED EFFORT	0.5 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/azure/defender-for-cloud/configure-email-notifications

2 affected items (listed in the HTML report and FindingDetails.csv)

Warning **Virtual machines use Trusted Launch** Low severity AZ-14

CURRENT STATE	2 of 4 virtual machines do not use Trusted Launch.
RECOMMENDATION	Use Trusted Launch (Secure Boot and vTPM) for new virtual machines and upgrade existing Generation 2 machines, so boot-level malware is blocked and BitLocker and Credential Guard can use a TPM. (MCSB PV-3)
ESTIMATED EFFORT	2 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/azure/virtual-machines/trusted-launch-existing-vm

2 affected items (listed in the HTML report and FindingDetails.csv)

Info **Azure SQL servers use Entra authentication, TLS 1.2 and private access** High severity AZ-17

CURRENT STATE	No Azure SQL servers were found.
RECOMMENDATION	Require TLS 1.2, switch to Microsoft Entra-only authentication, and disable public network access in favour of private endpoints (or limit firewall rules to known addresses). Turn on auditing and Defender for SQL. (MCSB IM-1, NS-2, DP-3)
REFERENCE	https://learn.microsoft.com/azure/azure-sql/database/security-best-practice

Azure resilience

Fail **No retired Basic SKU public IPs or load balancers** High severity AZ-09

CURRENT STATE	1 public IP address still uses the retired Basic SKU.
RECOMMENDATION	Upgrade Basic SKU public IP addresses and Basic load balancers to Standard. Microsoft retired both on 30 September 2025, so Basic resources are no longer supported and can stop working.
ESTIMATED EFFORT	4 hours
PRIORITY	**P1**
REFERENCE	https://learn.microsoft.com/azure/virtual-network/ip-services/public-ip-basic-upgrade-guidance

1 affected item (listed in the HTML report and FindingDetails.csv)

Fail **Virtual machines are backed up** High severity AZ-10

CURRENT STATE	2 of 4 virtual machines are not protected by Azure Backup, and 1 more has not backed up recently.
RECOMMENDATION	Protect every virtual machine with Azure Backup (or confirm another backup product covers it), with daily backups, at least 30 days of retention and alerts on failed jobs. Investigate any backup that has not completed in the last two days. (MCSB BR-1, BR-3)
ESTIMATED EFFORT	3 hours
PRIORITY	**P1**
REFERENCE	https://learn.microsoft.com/azure/backup/backup-azure-vms-introduction

3 affected items (listed in the HTML report and FindingDetails.csv)

Warning **Backup vaults are protected against deletion and ransomware** Medium severity AZ-11

CURRENT STATE	1 of 1 vaults lacks soft delete or immutability.
RECOMMENDATION	On each Recovery Services vault, keep soft delete always on, turn on immutability (and lock it once tested), use geo-redundant storage with cross-region restore for production, and protect critical operations with multi-user authorisation (Resource Guard). (MCSB BR-2)
ESTIMATED EFFORT	1 hour
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/azure/backup/guidance-best-practices

1 affected item (listed in the HTML report and FindingDetails.csv)

Warning **High-impact Azure Advisor recommendations** Medium severity AZ-24

CURRENT STATE	1 high-impact recommendation (1 reliability).
RECOMMENDATION	Work through the high-impact Azure Advisor recommendations for reliability, security and operational excellence.
ESTIMATED EFFORT	4 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/azure/advisor/advisor-overview

1 affected item (listed in the HTML report and FindingDetails.csv)

Warning **Azure Arc servers are connected** Medium severity AZ-29

CURRENT STATE	1 of 2 Arc servers is not connected.
RECOMMENDATION	Reconnect or remove Azure Arc servers that are disconnected or expired, so Defender for Servers, Update Manager and extended security updates keep working on them.
ESTIMATED EFFORT	1 hour
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/azure/azure-arc/servers/troubleshoot-agent-onboard

1 affected item (listed in the HTML report and FindingDetails.csv)

Windows servers

Fail **Windows servers run a supported version** High severity SRV-01

CURRENT STATE	1 of 5 Windows servers is out of support; 1 more loses support within six months.
RECOMMENDATION	Upgrade or replace servers whose Windows Server version is out of support (2012 and 2012 R2 extended security updates ended on 13 October 2026; Windows Server 2016 support ends on 12 January 2027). Plan upgrades for anything ending within six months.
ESTIMATED EFFORT	16 hours
PRIORITY	**P1**
REFERENCE	https://learn.microsoft.com/lifecycle/products/?terms=windows%20server

2 affected items (listed in the HTML report and FindingDetails.csv)

Fail

Windows servers are patched and rebooted

High severity SRV-02

CURRENT STATE	1 of 5 servers is missing security updates.
RECOMMENDATION	Install the outstanding security updates and restart servers that are waiting for a reboot. Check the RMM patch policy covers every server and that servers are restarted at least monthly.
ESTIMATED EFFORT	4 hours
PRIORITY	**P1**
REFERENCE	https://learn.microsoft.com/windows/deployment/update/waas-overview

2 affected items (listed in the HTML report and FindingDetails.csv)

Fail

Windows servers have working EDR and antivirus

High severity SRV-03

CURRENT STATE	1 of 5 servers has no EDR.
RECOMMENDATION	Onboard every server to Microsoft Defender for Endpoint (Defender for Servers or Defender for Business servers) or the client's chosen EDR, keep real-time protection and tamper protection on, and make sure signatures update daily.
ESTIMATED EFFORT	2 hours
PRIORITY	**P1**
REFERENCE	https://learn.microsoft.com/defender-endpoint/configure-server-endpoints

2 affected items (listed in the HTML report and FindingDetails.csv)

Fail

Remote management is not exposed or weakly protected

High severity SRV-04

CURRENT STATE	1 of 5 servers allows weakly protected remote access.
RECOMMENDATION	Require Network Level Authentication for Remote Desktop, limit RDP, SMB and WinRM firewall rules to management subnets instead of any address, and turn off unencrypted and Basic authentication on WinRM.
ESTIMATED EFFORT	2 hours
PRIORITY	**P1**
REFERENCE	https://learn.microsoft.com/windows-server/remote/remote-desktop-services/clients/remote-desktop-allow-access

2 affected items (listed in the HTML report and FindingDetails.csv)

Fail

SMBv1 is disabled and SMB signing is required

High severity SRV-05

CURRENT STATE	SMBv1 is enabled on 1 server; signing is not required on 2 servers.
RECOMMENDATION	Remove the SMB 1.0 feature, and require SMB signing on servers (Microsoft network server: Digitally sign communications (always)) through Group Policy, after checking for old devices such as copiers that still need SMBv1.
ESTIMATED EFFORT	2 hours
PRIORITY	**P1**
REFERENCE	https://learn.microsoft.com/windows-server/storage/file-server/troubleshoot/detect-enable-and-disable-smbv1-v2-v3

3 affected items (listed in the HTML report and FindingDetails.csv)

Fail Local administrator accounts are managed

High severity SRV-07

CURRENT STATE	1 of 3 member servers has unmanaged local administrator accounts.
RECOMMENDATION	Deploy Windows LAPS to every member server so the local administrator password is unique and rotated, disable the Guest account, and remove broad groups such as Domain Users or Everyone from the local Administrators group.
ESTIMATED EFFORT	3 hours
PRIORITY	**P1**
REFERENCE	https://learn.microsoft.com/windows-server/identity/laps/laps-overview

1 affected item (listed in the HTML report and FindingDetails.csv)

Fail Servers are backed up

High severity SRV-10

CURRENT STATE	1 server has not completed a Windows Server Backup in the last two days.
RECOMMENDATION	Confirm every server is covered by a backup with offsite or immutable copies: physical servers need a backup agent, and virtual machines need either an agent or host-level backup. Test a restore at least quarterly.
ESTIMATED EFFORT	2 hours
PRIORITY	**P1**
REFERENCE	https://www.ncsc.gov.uk/collection/small-business-guide/backing-your-data

4 affected items (listed in the HTML report and FindingDetails.csv)

Fail No out-of-support server software

High severity SRV-12

CURRENT STATE	4 items of out-of-support software were found.
RECOMMENDATION	Plan upgrades or migrations for software that no longer receives security updates, such as SQL Server 2016 and older, Exchange Server 2016 and 2019 (move to Exchange Online or Exchange Server Subscription Edition), and old Java, PHP or .NET runtimes.
ESTIMATED EFFORT	8 hours
PRIORITY	**P1**
REFERENCE	https://learn.microsoft.com/lifecycle/products/

4 affected items (listed in the HTML report and FindingDetails.csv)

Fail Windows servers meet the hardening baseline

Medium severity SRV-06

CURRENT STATE	49.7% of baseline settings are met across 5 servers. 3 servers are below 60%.
RECOMMENDATION	Apply the missing baseline settings through Group Policy (or the Intune server baseline): they are drawn from CIS Windows Server Level 1 and the Microsoft security baseline. The Servers tab shows each setting by server.
ESTIMATED EFFORT	6 hours
PRIORITY	**P2**
REFERENCE	https://learn.microsoft.com/windows/security/operating-system-security/device-management/windows-security-configuration-framework/windows-security-baselines

5 affected items (listed in the HTML report and FindingDetails.csv)

Fail **Server volumes have free space** Medium severity SRV-09

CURRENT STATE	1 volume is under 10% free.
RECOMMENDATION	Free space or extend volumes with less than 15% free, starting with system drives and database or mailbox volumes, and add free-space alerts to the RMM.
ESTIMATED EFFORT	1 hour
PRIORITY	**P2**
REFERENCE	https://learn.microsoft.com/windows-server/storage/disk-management/extend-a-basic-volume

2 affected items (listed in the HTML report and FindingDetails.csv)

Fail **Server time, certificates and stability** Medium severity SRV-13

CURRENT STATE	2 of 5 servers have time, certificate or stability issues.
RECOMMENDATION	Fix servers that are not syncing time (members should follow the domain hierarchy, the PDC emulator an external NTP source), renew certificates that expire within 30 days, and investigate unexpected shutdowns and disk errors.
ESTIMATED EFFORT	1 hour
PRIORITY	**P2**
REFERENCE	https://learn.microsoft.com/windows-server/networking/windows-time-service/windows-time-service-top

2 affected items (listed in the HTML report and FindingDetails.csv)

Warning **Security logging and audit policy are in place** Medium severity SRV-08

CURRENT STATE	3 of 5 servers have logging gaps.
RECOMMENDATION	Set advanced audit policy for logons, credential validation, process creation, group and policy changes through Group Policy, size the Security log to at least 192 MB (or forward events to a SIEM), and investigate any Security log that has been cleared.
ESTIMATED EFFORT	2 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/windows-server/identity/ad-ds/plan/security-best-practices/audit-policy-recommendations

3 affected items (listed in the HTML report and FindingDetails.csv)

Warning **Unnecessary and risky services are not running** Medium severity SRV-11

CURRENT STATE	4 of 5 servers run unnecessary or risky services.
RECOMMENDATION	Stop and disable the Print Spooler on servers that are not print servers, Remote Registry, SNMP v1/v2, Telnet and FTP where they are not needed, and quote service paths that contain spaces.
ESTIMATED EFFORT	2 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/windows-server/security/windows-services/security-guidelines-for-disabling-system-services-in-windows-server

4 affected items (listed in the HTML report and FindingDetails.csv)

Warning **Physical servers encrypt their disks** — Low severity — SRV-14

CURRENT STATE	The only physical server does not have BitLocker on the system drive.
RECOMMENDATION	Turn on BitLocker with TPM protection for physical servers, especially in branch offices or shared racks, and store recovery keys in Active Directory or Entra ID.
ESTIMATED EFFORT	2 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/windows/security/operating-system-security/data-protection/bitlocker/

1 affected item (listed in the HTML report and FindingDetails.csv)

Info **Server data coverage** — Info severity — SRV-15

CURRENT STATE	6 systems imported from 8 files.
RECOMMENDATION	Run the collector on every server (through the RMM, locally or over WinRM) as an administrator or SYSTEM, so all checks can be assessed. Data older than 30 days should be collected again.
REFERENCE	https://learn.microsoft.com/powershell/scripting/learn/remoting/running-remote-commands

8 affected items (listed in the HTML report and FindingDetails.csv)

Active Directory

Fail **Privileged AD groups are small and protected** — High severity — AD-02

CURRENT STATE	Domain Admins is too large (7 members; two to four is recommended).
RECOMMENDATION	Keep Domain Admins to two to four named admin accounts (separate from day-to-day accounts), leave Enterprise Admins and Schema Admins empty until needed, empty Account, Server, Print and Backup Operators, and add admin accounts to Protected Users.
ESTIMATED EFFORT	3 hours
PRIORITY	**P1**
REFERENCE	https://learn.microsoft.com/windows-server/identity/ad-ds/plan/security-best-practices/implementing-least-privilege-administrative-models

5 affected items (listed in the HTML report and FindingDetails.csv)

Fail **No accounts open to Kerberos and delegation attacks** — High severity — AD-03

CURRENT STATE	2 high-risk account settings found (3 more to review).
RECOMMENDATION	Remove service principal names from admin accounts and use group managed service accounts with long random passwords for services, turn Kerberos pre-authentication back on, clear "password not required" and reversible encryption flags, remove unconstrained delegation from non-DC computers and users, and remove passwords from account descriptions.
ESTIMATED EFFORT	4 hours
PRIORITY	**P1**
REFERENCE	https://learn.microsoft.com/windows-server/security/kerberos/kerberos-constrained-delegation-overview

5 affected items (listed in the HTML report and FindingDetails.csv)

Fail

Domain password and lockout policy is strong

High severity AD-04

CURRENT STATE	The domain password or lockout policy is weak: minimum length 8, no account lockout, history 12.
RECOMMENDATION	Set the default domain password policy to a minimum of 14 characters with complexity, keep 24 passwords of history, lock accounts after 5 to 10 failed attempts for at least 15 minutes, and never allow reversible encryption. Use fine-grained policies for admins and service accounts.
ESTIMATED EFFORT	2 hours
PRIORITY	**P1**
REFERENCE	https://learn.microsoft.com/windows/security/threat-protection/security-policy-settings/password-policy

1 affected item (listed in the HTML report and FindingDetails.csv)

Fail

Domain controllers are hardened

High severity AD-07

CURRENT STATE	Both domain controllers need hardening.
RECOMMENDATION	On every domain controller require LDAP signing (LDAPServerIntegrity 2) and enforce LDAP channel binding, disable the Print Spooler, run a supported Windows Server version, and do not install other roles or software on DCs.
ESTIMATED EFFORT	3 hours
PRIORITY	**P1**
REFERENCE	https://learn.microsoft.com/troubleshoot/windows-server/active-directory/enable-ldap-signing-in-windows-server

2 affected items (listed in the HTML report and FindingDetails.csv)

Fail

Directory recovery and krbtgt hygiene

Medium severity AD-05

CURRENT STATE	fabrikam.local: AD Recycle Bin off; krbtgt password 1461 days old; machine account quota 10; domain functional level Windows2012R2Domain.
RECOMMENDATION	Turn on the AD Recycle Bin, reset the krbtgt password (twice, at least 10 hours apart) if it has not changed in 180 days, set ms-DS-MachineAccountQuota to 0 so ordinary users cannot join computers, and raise the domain and forest functional levels to Windows Server 2016.
ESTIMATED EFFORT	2 hours
PRIORITY	**P2**
REFERENCE	https://learn.microsoft.com/windows-server/identity/ad-ds/manage/ad-forest-recovery-resetting-the-krbtgt-password

1 affected item (listed in the HTML report and FindingDetails.csv)

Warning

LAPS covers domain computers

High severity AD-08

CURRENT STATE	LAPS covers 53.4% of computers in the weakest domain.
RECOMMENDATION	Extend the schema for Windows LAPS (Update-LapsADSchema), grant computers permission to update their password (Set-LapsADComputerSelfPermission) and deploy a LAPS policy to every workstation and member server OU.
ESTIMATED EFFORT	3 hours
PRIORITY	**P2**
REFERENCE	https://learn.microsoft.com/windows-server/identity/laps/laps-scenarios-windows-server-active-directory

1 affected item (listed in the HTML report and FindingDetails.csv)

Warning **Stale and out-of-support accounts are cleaned up** Medium severity AD-06

CURRENT STATE	14 stale users, 6 stale computers and 2 out-of-support computers found.
RECOMMENDATION	Disable, then delete, user and computer accounts that have not signed in for 90 days, and remove or upgrade computers running out-of-support Windows versions.
ESTIMATED EFFORT	3 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/services-hub/unified/health/remediation-steps-ad/regularly-check-for-and-remove-inactive-user-accounts-in-active-directory

22 affected items (listed in the HTML report and FindingDetails.csv)

Pass **Active Directory replication and SYSVOL are healthy** High severity AD-01

CURRENT STATE	Replication is healthy for fabrikam.local.
REFERENCE	https://learn.microsoft.com/troubleshoot/windows-server/active-directory/diagnose-replication-failures

Hyper-V

Fail **Hyper-V virtual machines are healthy** Medium severity HV-01

CURRENT STATE	2 virtual machines have old checkpoints, replication or cluster problems.
RECOMMENDATION	Delete checkpoints older than a week (they grow and slow the VM), fix failed or warning replication, update integration services and VM configuration versions, set the automatic stop action to Save or Shut down, and use Secure Boot and a virtual TPM on Generation 2 VMs.
ESTIMATED EFFORT	2 hours
PRIORITY	**P2**
REFERENCE	https://learn.microsoft.com/windows-server/virtualization/hyper-v/manage/choose-between-standard-or-production-checkpoints-in-hyper-v

3 affected items (listed in the HTML report and FindingDetails.csv)

Warning **Hyper-V hosts are dedicated** Medium severity HV-02

CURRENT STATE	The only Hyper-V host runs other roles.
RECOMMENDATION	Keep Hyper-V hosts to the Hyper-V role (plus clustering and storage features). Move domain controller, file, print, SQL or other workloads into virtual machines, and keep the host off the general user network.
ESTIMATED EFFORT	8 hours
PRIORITY	**P3**
REFERENCE	https://learn.microsoft.com/windows-server/virtualization/hyper-v/plan/plan-hyper-v-security-in-windows-server

1 affected item (listed in the HTML report and FindingDetails.csv)

Linux servers

Fail Linux servers run a supported release and are patched

High severity LNX-01

CURRENT STATE	The only Linux server is out of support or missing security updates.
RECOMMENDATION	Upgrade servers on releases that no longer receive security updates (or add extended support such as Ubuntu Pro), install outstanding security updates, restart servers that need it, and turn on automatic security updates where the workload allows.
ESTIMATED EFFORT	8 hours
PRIORITY	**P1**
REFERENCE	https://ubuntu.com/about/release-cycle

1 affected item (listed in the HTML report and FindingDetails.csv)

Fail Linux SSH and accounts are hardened

High severity LNX-02

CURRENT STATE	The only Linux server allows risky SSH or account access.
RECOMMENDATION	In sshd_config set PermitRootLogin no, PasswordAuthentication no (keys only), PermitEmptyPasswords no and MaxAuthTries 4 or lower. Remove extra UID 0 accounts and empty passwords, and limit passwordless sudo to specific commands.
ESTIMATED EFFORT	2 hours
PRIORITY	**P1**
REFERENCE	https://www.ncsc.gov.uk/collection/device-security-guidance

1 affected item (listed in the HTML report and FindingDetails.csv)

Fail Linux servers have EDR, a firewall and audit logging

High severity LNX-03

CURRENT STATE	The only Linux server has no EDR.
RECOMMENDATION	Install Defender for Endpoint on Linux (or the client's EDR), turn on the host firewall (ufw or firewalld) with a default-deny inbound policy, keep SELinux enforcing or AppArmor enabled, run auditd, and make sure time is synchronised.
ESTIMATED EFFORT	3 hours
PRIORITY	**P1**
REFERENCE	https://learn.microsoft.com/defender-endpoint/microsoft-defender-endpoint-linux

1 affected item (listed in the HTML report and FindingDetails.csv)

Warning Linux disk space, packages and kernel settings

Medium severity LNX-04

CURRENT STATE	The only Linux server has settings to tighten.
RECOMMENDATION	Free space on file systems over 85% full, remove legacy network services (telnet, rsh, FTP, TFTP, NIS), and keep kernel hardening defaults (ASLR on, ICMP redirects off, no core dumps of setuid programs).
ESTIMATED EFFORT	1 hour
PRIORITY	**P3**
REFERENCE	https://www.cisecurity.org/cis-benchmarks

1 affected item (listed in the HTML report and FindingDetails.csv)

VMware

Info **VMware hosts run a supported, hardened ESXi** High severity VMW-01

CURRENT STATE	No VMware data was imported.
RECOMMENDATION	Upgrade ESXi and vCenter 7.0 and older to 8.0 (or plan a move to another platform), keep SSH and the ESXi Shell stopped unless needed, turn on lockdown mode, and configure NTP and remote syslog on every host.
REFERENCE	https://knowledge.broadcom.com/external/article?legacyId=2145103

Info **VMware virtual machines, datastores and clusters are healthy** Medium severity VMW-02

CURRENT STATE	No VMware data was imported.
RECOMMENDATION	Delete snapshots older than three days, keep VMware Tools current and running, disconnect ISO images, keep datastores above 15% free, and turn on vSphere HA for clusters.
REFERENCE	https://knowledge.broadcom.com/external/article?legacyId=1025279

4. Prioritised recommendations

This is the technical list for engineers; the Action plan gives the same work in plain English. Priority P1 items (must do) are high-severity failures to fix first, P2 (should do) are medium-severity failures or high-severity warnings, and P3 (could do) are improvements and manual checks. Effort is an estimate of engineer hours for remediation and is for scoping only. Total: 353.0 hours (47.1 days at 7.5 hours per day).

Priority	Recommendation	Area	Status	Effort (hours)
P1	**Privileged AD groups are small and protected** AD-02 Keep Domain Admins to two to four named admin accounts (separate from day-to-day accounts), leave Enterprise Admins and Schema Admins empty until needed, empty Account, Server, Print and Backup Operators, and add admin accounts to Protected Users.	Active Directory	Fail	3
P1	**No accounts open to Kerberos and delegation attacks** AD-03 Remove service principal names from admin accounts and use group managed service accounts with long random passwords for services, turn Kerberos pre-authentication back on, clear "password not required" and reversible encryption flags, remove unconstrained delegation from non-DC computers and users, and remove passwords from account descriptions.	Active Directory	Fail	4
P1	**Domain password and lockout policy is strong** AD-04 Set the default domain password policy to a minimum of 14 characters with complexity, keep 24 passwords of history, lock accounts after 5 to 10 failed attempts for at least 15 minutes, and never allow reversible encryption. Use fine-grained policies for admins and service accounts.	Active Directory	Fail	2
P1	**Domain controllers are hardened** AD-07 On every domain controller require LDAP signing (LDAPServerIntegrity 2) and enforce LDAP channel binding, disable the Print Spooler, run a supported Windows Server version, and do not install other roles or software on DCs.	Active Directory	Fail	3
P1	**Microsoft Defender for Cloud protects servers and data services** AZ-02 Turn on Defender for Servers (Plan 1 at least, which includes Defender for Endpoint) in every subscription with virtual machines or Arc servers, and Defender for Storage, SQL and Key Vault where those resources hold client data. (MCSB LT-1, ES-1)	Azure security	Fail	3
P1	**Management ports are not open to the internet** AZ-06 Remove network security group rules that allow RDP, SSH, WinRM, SMB or database ports from Any or Internet. Use Azure Bastion, Defender for Cloud just-in-time access or a VPN for administration, and limit any remaining rules to known source addresses. (MCSB NS-1, NS-2)	Azure security	Fail	2
P1	**No retired Basic SKU public IPs or load balancers** AZ-09 Upgrade Basic SKU public IP addresses and Basic load balancers to Standard. Microsoft retired both on 30 September 2025, so Basic resources are no longer supported and can stop working.	Azure resilience	Fail	4
P1	**Virtual machines are backed up** AZ-10 Protect every virtual machine with Azure Backup (or confirm another backup product covers it), with daily backups, at least 30 days of	Azure resilience	Fail	3

Priority	Recommendation	Area	Status	Effort (hours)
	retention and alerts on failed jobs. Investigate any backup that has not completed in the last two days. (MCSB BR-1, BR-3)			
P1	**Servers run a supported operating system** AZ-12 Upgrade or replace servers whose operating system is out of support (Windows Server 2012 and 2012 R2 extended security updates ended on 13 October 2026; Windows Server 2016 support ends on 12 January 2027). Plan upgrades for anything ending within six months. (MCSB PV-6)	Azure security	Fail	8
P1	**Azure servers are onboarded to Defender for Endpoint** AZ-13 Onboard every running server to Microsoft Defender for Endpoint (Defender for Servers deploys the MDE extension automatically). Replace the retired Log Analytics agent (MMA/OMS) with the Azure Monitor agent where monitoring data is needed. (MCSB ES-1, LT-1)	Azure security	Fail	3
P1	**Storage accounts block public access and require TLS 1.2** AZ-15 On every storage account, turn off anonymous blob access, require secure transfer with TLS 1.2 or later, restrict network access to selected networks or private endpoints, and disable shared key access where applications support Entra ID authentication. (MCSB NS-2, DP-3, IM-1)	Azure security	Fail	2
P1	**Subscription owners are limited and not guests** AZ-19 Keep subscription Owner and User Access Administrator to two or three named admins through groups, make them eligible through Privileged Identity Management rather than permanent, remove guests and unused service principals, and review the CSP partner access. (MCSB PA-1, PA-7)	Azure governance and cost	Fail	2
P1	**Devices are onboarded to Defender for Endpoint** DEF-01 Onboard every Windows and macOS device to Defender for Endpoint or Defender for Business, ideally with the Intune EDR onboarding policy, and confirm each device reports in the Defender portal.	Microsoft Defender XDR	Fail	4
P1	**No critical vulnerabilities with public exploits** DEF-04 Patch the listed software through the RMM or Intune, starting with critical vulnerabilities that have public exploits. Remove software that is no longer needed and make sure third-party applications are in the patch policy.	Microsoft Defender XDR	Fail	8
P1	**Security incidents are triaged and resolved** DEF-08 Assign, investigate and resolve open incidents, starting with high severity. Make sure incident notifications reach your service desk or SOC.	Microsoft Defender XDR	Fail	2
P1	**SPF records are valid** DNS-01 Publish exactly one SPF record per domain that includes spf.protection.outlook.com and every other legitimate sender, ending in -all or ~all.	Email authentication	Fail	1
P1	**DKIM signing is enabled for every mail domain** DNS-02 Publish the selector1 and selector2 CNAME records and enable DKIM signing in Defender for each custom domain.	Email authentication	Fail	1
P1	**DMARC is published and enforced** DNS-03 Publish DMARC for every domain, start at p=none with reporting, then	Email authentication	Fail	1

Priority	Recommendation	Area	Status	Effort (hours)
	move to p=quarantine and p=reject once legitimate senders pass SPF or DKIM.			
P1	**Compliance policies cover every enrolled platform** END-01 Create and assign a compliance policy for each platform in use (Windows, iOS/iPadOS, Android, macOS) covering encryption, OS version, password and Defender status.	Intune and devices	Fail	4
P1	**Windows devices are encrypted** END-05 Deploy a BitLocker disk encryption policy from Endpoint security and escrow recovery keys to Entra ID.	Intune and devices	Fail	4
P1	**Windows devices run a supported version** END-06 Upgrade Windows 10 devices (out of support since 14 October 2025 unless covered by ESU) and Windows 11 builds below the minimum to a supported release.	Intune and devices	Fail	4
P1	**Apple MDM push certificate is valid** END-13 Renew the Apple MDM push certificate in Intune (Devices, Enrolment, Apple) before it expires, using the same Apple ID that created it. Use a shared company Apple ID, not a personal one. If it expires, Apple devices stop receiving policy, and creating a new certificate with a different Apple ID means re-enrolling every Apple device.	Intune connections	Fail	1
P1	**Mailbox forwarding is reviewed** EXO-06 Confirm every mailbox forward is authorised, particularly to external addresses. Unexpected forwarding is a common sign of a compromised account.	Exchange Online	Fail	1
P1	**Licensed users are registered for MFA** IAM-05 Run an MFA registration campaign and follow up with users who are not registered. Unregistered accounts can be registered by an attacker who has the password.	Identity and access	Fail	4
P1	**All administrators are registered for MFA** IAM-06 Register strong MFA methods for every account that holds an admin role before anything else. Remove roles from accounts that do not need them.	Identity and access	Fail	1
P1	**Users cannot consent to applications** IAM-13 Set user consent to "Do not allow" or "Allow for verified publishers, for selected low-impact permissions", and turn on the admin consent workflow.	Identity and access	Fail	1
P1	**Directory synchronisation is healthy** IAM-22 Investigate the Entra Connect or Cloud Sync server. A stalled sync means leavers disabled on-premises keep cloud access.	Identity and access	Fail	2
P1	**Linux servers run a supported release and are patched** LNX-01 Upgrade servers on releases that no longer receive security updates (or add extended support such as Ubuntu Pro), install outstanding security updates, restart servers that need it, and turn on automatic security updates where the workload allows.	Linux servers	Fail	8
P1	**Linux SSH and accounts are hardened** LNX-02 In sshd_config set PermitRootLogin no, PasswordAuthentication no (keys only), PermitEmptyPasswords no and MaxAuthTries 4 or lower.	Linux servers	Fail	2

Priority	Recommendation	Area	Status	Effort (hours)
	Remove extra UID 0 accounts and empty passwords, and limit passwordless sudo to specific commands.			
P1	**Linux servers have EDR, a firewall and audit logging** LNX-03 Install Defender for Endpoint on Linux (or the client's EDR), turn on the host firewall (ufw or firewalld) with a default-deny inbound policy, keep SELinux enforcing or AppArmor enabled, run auditd, and make sure time is synchronised.	Linux servers	Fail	3
P1	**No guest accounts hold admin roles** PRV-02 Remove admin roles from guest accounts. Partner access should use GDAP, not guest accounts with roles.	Privileged access	Fail	0.5
P1	**Windows servers run a supported version** SRV-01 Upgrade or replace servers whose Windows Server version is out of support (2012 and 2012 R2 extended security updates ended on 13 October 2026; Windows Server 2016 support ends on 12 January 2027). Plan upgrades for anything ending within six months.	Windows servers	Fail	16
P1	**Windows servers are patched and rebooted** SRV-02 Install the outstanding security updates and restart servers that are waiting for a reboot. Check the RMM patch policy covers every server and that servers are restarted at least monthly.	Windows servers	Fail	4
P1	**Windows servers have working EDR and antivirus** SRV-03 Onboard every server to Microsoft Defender for Endpoint (Defender for Servers or Defender for Business servers) or the client's chosen EDR, keep real-time protection and tamper protection on, and make sure signatures update daily.	Windows servers	Fail	2
P1	**Remote management is not exposed or weakly protected** SRV-04 Require Network Level Authentication for Remote Desktop, limit RDP, SMB and WinRM firewall rules to management subnets instead of any address, and turn off unencrypted and Basic authentication on WinRM.	Windows servers	Fail	2
P1	**SMBv1 is disabled and SMB signing is required** SRV-05 Remove the SMB 1.0 feature, and require SMB signing on servers (Microsoft network server: Digitally sign communications (always)) through Group Policy, after checking for old devices such as copiers that still need SMBv1.	Windows servers	Fail	2
P1	**Local administrator accounts are managed** SRV-07 Deploy Windows LAPS to every member server so the local administrator password is unique and rotated, disable the Guest account, and remove broad groups such as Domain Users or Everyone from the local Administrators group.	Windows servers	Fail	3
P1	**Servers are backed up** SRV-10 Confirm every server is covered by a backup with offsite or immutable copies: physical servers need a backup agent, and virtual machines need either an agent or host-level backup. Test a restore at least quarterly.	Windows servers	Fail	2
P1	**No out-of-support server software** SRV-12 Plan upgrades or migrations for software that no longer receives security updates, such as SQL Server 2016 and older, Exchange	Windows servers	Fail	8

Priority	Recommendation	Area	Status	Effort (hours)
	Server 2016 and 2019 (move to Exchange Online or Exchange Server Subscription Edition), and old Java, PHP or .NET runtimes.			
P2	**LAPS covers domain computers** AD-08 Extend the schema for Windows LAPS (Update-LapsADSchema), grant computers permission to update their password (Set-LapsADComputerSelfPermission) and deploy a LAPS policy to every workstation and member server OU.	Active Directory	Warning	3
P2	**High-risk application permissions are reviewed** APP-01 Review each non-Microsoft application holding high-impact application permissions (mail, files, directory write). Remove apps that are unused or unknown and reduce permissions where possible.	Applications	Warning	3
P2	**Windows LAPS policy manages local administrator passwords** END-19 In Endpoint security, Account protection, create a Local admin password solution (Windows LAPS) policy that backs up the password to Microsoft Entra ID, rotates it at least every 30 days and after use, and assign it to all Windows devices. Microsoft Entra LAPS must also be enabled in Entra device settings (IAM-25).	Windows security configuration	Warning	2
P2	**BitLocker policy requires encryption and escrows recovery keys** END-20 In Endpoint security, Disk encryption, create a BitLocker policy that requires device encryption, uses silent encryption, and saves operating system drive recovery information to Microsoft Entra ID before encrypting. Assign it to all Windows devices.	Windows security configuration	Warning	3
P2	**Attack surface reduction rules are in block mode** END-22 Deploy the attack surface reduction rules from Endpoint security, Attack surface reduction. Put the three standard protection rules (vulnerable signed drivers, credential stealing from LSASS, persistence through WMI) into block mode straight away, run the others in audit mode for two to four weeks, review the audit events in Defender, then switch them to block.	Windows security configuration	Warning	4
P2	**Legacy authentication is blocked** IAM-02 Create a Conditional Access policy that blocks Exchange ActiveSync and other legacy clients for all users. Check sign-in logs for legacy clients first, then enforce.	Identity and access	Warning	2
P2	**Directory recovery and krbtgt hygiene** AD-05 Turn on the AD Recycle Bin, reset the krbtgt password (twice, at least 10 hours apart) if it has not changed in 180 days, set ms-DS-MachineAccountQuota to 0 so ordinary users cannot join computers, and raise the domain and forest functional levels to Windows Server 2016.	Active Directory	Fail	2
P2	**App Service apps enforce HTTPS and TLS 1.2** AZ-18 Turn on HTTPS Only, set the minimum TLS version to 1.2, and set FTP to FTPS only or disabled on every App Service app and function app. (MCSB DP-3)	Azure security	Fail	1
P2	**Windows Firewall is enforced on every profile** END-21 In Endpoint security, Firewall, create a Windows Firewall policy that turns the firewall on for the domain, private and public profiles, blocks	Windows security configuration	Fail	2

Priority	Recommendation	Area	Status	Effort (hours)
	inbound connections by default and stops local rules being merged on public networks. Assign it to all Windows devices.			
P2	**SMTP AUTH client submission is disabled** EXO-04 Disable SMTP AUTH at organisation level and allow it only on specific mailboxes used by devices or apps that cannot use modern methods. Plan moves to high volume email or a relay connector.	Exchange Online	Fail	2
P2	**Hyper-V virtual machines are healthy** HV-01 Delete checkpoints older than a week (they grow and slow the VM), fix failed or warning replication, update integration services and VM configuration versions, set the automatic stop action to Save or Shut down, and use Secure Boot and a virtual TPM on Generation 2 VMs.	Hyper-V	Fail	2
P2	**Between two and four Global Administrators** PRV-01 Keep at least two (including emergency access) and no more than four Global Administrators. Move day-to-day admin work to least-privileged roles.	Privileged access	Fail	1
P2	**Microsoft Secure Score** SEC-01 Work through the Secure Score improvement actions in the Secure Score inventory, starting with the largest gaps that have low user impact.	Microsoft Secure Score	Fail	
P2	**Windows servers meet the hardening baseline** SRV-06 Apply the missing baseline settings through Group Policy (or the Intune server baseline): they are drawn from CIS Windows Server Level 1 and the Microsoft security baseline. The Servers tab shows each setting by server.	Windows servers	Fail	6
P2	**Server volumes have free space** SRV-09 Free space or extend volumes with less than 15% free, starting with system drives and database or mailbox volumes, and add free-space alerts to the RMM.	Windows servers	Fail	1
P2	**Server time, certificates and stability** SRV-13 Fix servers that are not syncing time (members should follow the domain hierarchy, the PDC emulator an external NTP source), renew certificates that expire within 30 days, and investigate unexpected shutdowns and disk errors.	Windows servers	Fail	1
P3	**Stale and out-of-support accounts are cleaned up** AD-06 Disable, then delete, user and computer accounts that have not signed in for 90 days, and remove or upgrade computers running out-of-support Windows versions.	Active Directory	Warning	3
P3	**User-consented applications are reviewed** APP-03 Review applications individual users have consented to with mail, file or offline access. These are a common route for consent phishing.	Applications	Warning	2
P3	**Defender for Cloud secure score** AZ-03 Work through the Defender for Cloud recommendations (see the Defender for Cloud recommendations inventory), starting with high-severity items on the most resources, to raise the secure score above 70%.	Azure security	Warning	8

Priority	Recommendation	Area	Status	Effort (hours)
P3	**Microsoft cloud security benchmark compliance** AZ-04 Use the Defender for Cloud regulatory compliance dashboard to work through the failed Microsoft cloud security benchmark (MCSB) controls listed here. Each one links to the recommendations that make it pass.	Azure security	Warning	8
P3	**Virtual machines do not have public IP addresses** AZ-07 Remove public IP addresses from virtual machines that do not publish a service. Publish services through a load balancer, Application Gateway or Front Door, and administer servers through Azure Bastion or a VPN. (MCSB NS-1)	Azure security	Warning	2
P3	**Subnets are protected by network security groups** AZ-08 Associate a network security group with every workload subnet so traffic between subnets and from the internet is filtered by default. Gateway, Bastion and Firewall subnets are excluded. (MCSB NS-1)	Azure security	Warning	2
P3	**Backup vaults are protected against deletion and ransomware** AZ-11 On each Recovery Services vault, keep soft delete always on, turn on immutability (and lock it once tested), use geo-redundant storage with cross-region restore for production, and protect critical operations with multi-user authorisation (Resource Guard). (MCSB BR-2)	Azure resilience	Warning	1
P3	**Key vaults have purge protection and restricted network access** AZ-16 Turn on purge protection, use the Azure RBAC permission model rather than access policies, and restrict network access to selected networks or private endpoints. (MCSB DP-8)	Azure security	Warning	1
P3	**The Azure activity log is kept beyond 90 days** AZ-21 Send each subscription's activity log (administrative, security, policy and alert categories) to a Log Analytics workspace or storage account with at least one year of retention, so changes can be investigated after the 90-day default. (MCSB LT-3, LT-6)	Azure governance and cost	Warning	1
P3	**High-impact Azure Advisor recommendations** AZ-24 Work through the high-impact Azure Advisor recommendations for reliability, security and operational excellence.	Azure resilience	Warning	4
P3	**Servers have no outstanding critical or security updates** AZ-28 Install outstanding critical and security updates, and make sure every server is covered by one patching tool (the RMM or Azure Update Manager, not both). Turn on periodic assessment in Azure Update Manager so missing updates are visible. (MCSB PV-6)	Azure security	Warning	3
P3	**Azure Arc servers are connected** AZ-29 Reconnect or remove Azure Arc servers that are disconnected or expired, so Defender for Servers, Update Manager and extended security updates keep working on them.	Azure resilience	Warning	1
P3	**Every group and Team has an owner** COL-02 Assign at least two owners to every Team and Microsoft 365 group, and enable the ownerless group policy.	Teams and groups	Warning	2
P3	**Teams external access and anonymous meeting join** COL-05 In the Teams admin centre, confirm external access is limited to trusted domains (or blocked for unmanaged Teams accounts), anonymous	Teams and groups	Manual check	

Priority	Recommendation	Area	Status	Effort (hours)
	users cannot start meetings, and lobby settings stop anonymous users joining directly.			
P3	**Discovered devices that can be onboarded** DEF-02 Review devices found by device discovery that are not onboarded. Onboard company devices, and identify or isolate unknown ones.	Microsoft Defender XDR	Warning	2
P3	**Onboarded devices report a healthy sensor** DEF-03 Investigate devices with an inactive, misconfigured or impaired sensor. Remove retired devices, and fix connectivity or service issues on the rest so they are protected and visible.	Microsoft Defender XDR	Warning	2
P3	**High-impact secure configuration gaps are addressed** DEF-05 Work through the high-impact security recommendations (impact 7 or more), usually by adjusting Intune endpoint security, attack surface reduction or baseline policies, and test with a pilot group first.	Microsoft Defender XDR	Warning	6
P3	**No devices with a high exposure level** DEF-06 Reduce the exposure of the listed devices by applying their security recommendations and patches, starting with devices used by administrators.	Microsoft Defender XDR	Warning	2
P3	**Defender for Endpoint is connected to Intune** DEF-07 Turn on the Microsoft Intune connection in Defender (Settings, Endpoints, Advanced features) and the Defender for Endpoint connector in Intune, then use device risk in compliance policies.	Microsoft Defender XDR	Warning	1
P3	**Devices without a compliance policy are marked non-compliant** END-02 Set "Mark devices with no compliance policy assigned as" to Not compliant so Conditional Access cannot be bypassed by unassigned devices.	Intune and devices	Warning	0.5
P3	**Managed devices are compliant** END-03 Work through non-compliant devices by reason in Intune and fix or retire them.	Intune and devices	Warning	3
P3	**Endpoint security policies are deployed** END-07 Deploy and assign Endpoint security policies for antivirus, disk encryption, firewall, EDR, attack surface reduction and account protection (LAPS).	Intune and devices	Warning	6
P3	**App protection policies protect mobile data** END-09 Create and assign app protection policies for iOS and Android so corporate data in Outlook, Teams and OneDrive is protected on personal phones.	Intune and devices	Warning	3
P3	**Apple Apps and Books (VPP) tokens are valid** END-15 Renew Apps and Books location tokens in Apple Business Manager and upload them to Intune before they expire, so purchased apps keep installing and updating.	Intune connections	Warning	1
P3	**Android Enterprise is connected** END-16 Connect Intune to Managed Google Play (Devices, Enrolment, Android) with a shared company Google account, and move any Android devices still on device administrator management to an Android Enterprise work profile or fully managed enrolment.	Intune connections	Warning	2

Priority	Recommendation	Area	Status	Effort (hours)
P3	**Policies apply without errors or conflicts** END-18 Open each listed policy in Intune, select the devices in error or conflict, and fix the failing settings. Conflicts mean two policies set the same setting to different values; keep one source for each setting.	Intune configuration health	Warning	3
P3	**Microsoft Defender Antivirus protections are on** END-23 In the Endpoint security antivirus policy, keep real-time, behaviour and cloud-delivered protection on, set the cloud block level to High, block potentially unwanted apps, turn on network protection in block mode, and send safe samples automatically.	Windows security configuration	Warning	2
P3	**Windows Hello for Business is configured** END-24 Turn on Windows Hello for Business for Entra joined devices (Devices, Enrolment, Windows Hello for Business, or an Account protection policy) with a PIN of at least six digits and biometrics allowed, so users sign in with a phishing-resistant credential instead of a password.	Windows security configuration	Warning	3
P3	**Security baselines are deployed and current** END-25 Deploy the current Windows security baseline, and the Defender for Endpoint and Edge baselines where licensed, to a pilot group first and then to all Windows devices. When Microsoft releases a new baseline version, update the profile to it. Re-create baselines still in the old format.	Windows security configuration	Warning	6
P3	**Autopilot profiles are assigned and users are not local administrators** END-26 Assign an Autopilot deployment profile to every registered device (for example through a dynamic group on the group tag or ZTDId), set the user account type to Standard so users are not local administrators, and use Microsoft Entra join rather than hybrid join for new devices.	Autopilot and enrolment	Warning	2
P3	**Enrolment Status Page holds users until setup completes** END-27 Turn on the Enrolment Status Page for Autopilot devices with Show app and profile configuration progress, block device use until required apps and security policies are installed, and allow a reset on failure. Without it users reach the desktop before BitLocker, Defender and other policies apply.	Autopilot and enrolment	Warning	2
P3	**Required apps install successfully** END-28 Open each listed app in Intune (Apps, Monitor, App install status), check the error codes on the failed devices, and fix the package, detection rule or requirement rules.	Intune configuration health	Warning	3
P3	**Windows compliance policy checks the essentials** END-30 Make the assigned Windows compliance policy require BitLocker, Secure Boot, code integrity, a TPM, a minimum OS version, an active firewall and antivirus, and the Defender for Endpoint machine risk score where licensed, so Conditional Access only allows healthy devices.	Compliance	Warning	2
P3	**Mobile compliance policies require a passcode and block jailbroken devices** END-31 Make the assigned iOS/iPadOS and Android compliance policies require a device passcode, block jailbroken or rooted devices (and require Play Integrity on Android), and set a minimum OS version.	Compliance	Warning	2
P3	**Mail flow rules do not weaken security** EXO-07 Review rules that bypass spam filtering (SCL -1) or copy or redirect	Exchange Online	Warning	2

Priority	Recommendation	Area	Status	Effort (hours)
	mail. Replace sender allow rules with Tenant Allow/Block List entries or connectors scoped by IP.			
P3	**Anti-spam policies do not allow whole sender domains** EXO-08 Remove allowed sender domains and addresses from anti-spam policies. Spoofed mail from these domains skips filtering. Use the Tenant Allow/Block List for genuine false positives.	Exchange Online	Warning	1
P3	**Anti-phishing protection is configured** EXO-09 Enable spoof intelligence, first contact safety tips and honour DMARC policy. With Defender for Office 365, add impersonation protection for executives and the client's domains and turn on mailbox intelligence.	Exchange Online	Warning	2
P3	**Safe Links protects email, Teams and Office apps** EXO-10 Apply the Standard preset security policy, or a custom Safe Links policy for all users covering email, Teams and Office apps with click tracking and no click-through.	Exchange Online	Warning	2
P3	**Safe Attachments is enabled** EXO-11 Apply the Standard preset policy or a Safe Attachments policy with the Block action for all users, and enable Safe Attachments for SharePoint, OneDrive and Teams.	Exchange Online	Warning	1
P3	**Sign-in is blocked for shared and resource mailboxes** EXO-16 Block sign-in on shared, room and equipment mailbox accounts. Access should come through mailbox permissions, not the account password.	Exchange Online	Warning	1
P3	**Microsoft 365 data is backed up** GOV-01 Confirm Exchange, OneDrive, SharePoint and Teams are protected by a third-party backup or Microsoft 365 Backup, with retention that meets the client's requirements.	Governance	Manual check	
P3	**Hyper-V hosts are dedicated** HV-02 Keep Hyper-V hosts to the Hyper-V role (plus clustering and storage features). Move domain controller, file, print, SQL or other workloads into virtual machines, and keep the host off the general user network.	Hyper-V	Warning	8
P3	**Administrators use phishing-resistant MFA** IAM-04 Issue FIDO2 security keys, passkeys or Windows Hello for Business to administrators and require the built-in Phishing-resistant MFA authentication strength for admin roles.	Identity and access	Warning	3
P3	**Weak MFA methods (SMS and voice) are disabled** IAM-07 Move users to Microsoft Authenticator or passkeys, then disable SMS and voice call in the authentication methods policy.	Identity and access	Warning	2
P3	**Conditional Access requires compliant or managed devices** IAM-11 Once Intune compliance policies are in place, require a compliant or hybrid-joined device for access to Microsoft 365 on desktops, and app protection on mobile.	Identity and access	Warning	4
P3	**Users cannot register applications or create tenants** IAM-15 Set "Users can register applications" and "Restrict non-admin users from creating tenants" so only administrators can do these.	Identity and access	Warning	0.5

Priority	Recommendation	Area	Status	Effort (hours)
P3	**Guest invitations are restricted** IAM-16 Limit guest invitations to admins and users in the Guest Inviter role, or to members only, in line with the client's collaboration needs.	Identity and access	Warning	0.5
P3	**Guest user access to the directory is restricted** IAM-17 Set guest user access to "Guest user access is restricted to properties and memberships of their own directory objects".	Identity and access	Warning	0.5
P3	**No inactive enabled user accounts** IAM-20 Confirm leavers with the client, then block sign-in, remove licences and convert or delete accounts that have not signed in within the inactivity window.	Identity and access	Warning	3
P3	**Windows LAPS is enabled** IAM-25 Enable Windows LAPS in Entra device settings and deploy an Intune LAPS policy so local administrator passwords are unique and rotated.	Identity and access	Warning	2
P3	**Subscriptions are in good standing** LIC-03 Renew or remove subscriptions in a warning or suspended state before services are switched off.	Licensing	Warning	0.5
P3	**Linux disk space, packages and kernel settings** LNX-04 Free space on file systems over 85% full, remove legacy network services (telnet, rsh, FTP, TFTP, NIS), and keep kernel hardening defaults (ASLR on, ICMP redirects off, no core dumps of setuid programs).	Linux servers	Warning	1
P3	**Privileged accounts are cloud-only** PRV-03 Use cloud-only accounts for privileged roles so an on-premises compromise cannot take over the tenant.	Privileged access	Warning	2
P3	**Service principals with privileged directory roles** PRV-06 Confirm each application that holds a privileged directory role is known and still required. Replace with least-privileged Graph permissions where possible.	Privileged access	Warning	1
P3	**Data loss prevention policies protect sensitive data** PUR-01 Create DLP policies for UK financial and personal data (for example bank details, National Insurance and passport numbers) across Exchange, SharePoint, OneDrive and Teams. Start in simulation mode with policy tips, review matches with the client, then block external sharing.	Microsoft Purview	Warning	6
P3	**Retention policies cover email, files and Teams** PUR-02 Agree retention periods with the client (for example 6 or 7 years for finance and HR records) and apply org-wide retention policies to Exchange, SharePoint, OneDrive and Teams so deleted or changed content can be recovered.	Microsoft Purview	Warning	3
P3	**Sensitivity labels are defined and published** PUR-03 Agree a simple label taxonomy with the client (Public, Internal, Confidential, Highly confidential), add encryption and markings where needed, publish the labels with a default label and justification for downgrades, and enable labels for SharePoint and Teams sites.	Microsoft Purview	Warning	8

Priority	Recommendation	Area	Status	Effort (hours)
P3	**Default alert policies are enabled and notify administrators** PUR-04 Re-enable disabled default alert policies and send high-severity alerts to a monitored support or client mailbox rather than individual administrators.	Microsoft Purview	Warning	1
P3	**Anonymous (Anyone) sharing links are controlled** SPO-01 Restrict tenant sharing to "New and existing guests" unless Anyone links are a business need. If they are, set link expiry and view-only defaults and limit them to specific sites.	SharePoint and OneDrive	Warning	2
P3	**Guests cannot reshare content they do not own** SPO-02 Turn off "Allow guests to share items they don't own".	SharePoint and OneDrive	Warning	0.5
P3	**Guests must sign in with the invited account** SPO-03 Require guests to accept sharing invitations with the same account the invitation was sent to.	SharePoint and OneDrive	Warning	0.5
P3	**Legacy authentication is blocked for SharePoint** SPO-04 Disable legacy authentication protocols for SharePoint and OneDrive (Set-SPOTenant -LegacyAuthProtocolsEnabled $false).	SharePoint and OneDrive	Warning	0.5
P3	**Security logging and audit policy are in place** SRV-08 Set advanced audit policy for logons, credential validation, process creation, group and policy changes through Group Policy, size the Security log to at least 192 MB (or forward events to a SIEM), and investigate any Security log that has been cleared.	Windows servers	Warning	2
P3	**Unnecessary and risky services are not running** SRV-11 Stop and disable the Print Spooler on servers that are not print servers, Remote Registry, SNMP v1/v2, Telnet and FTP where they are not needed, and quote service paths that contain spaces.	Windows servers	Warning	2
P3	**App registration credentials are current** APP-04 Renew credentials expiring in the next 30 days, remove expired secrets and certificates, and prefer certificates or managed identities over client secrets.	Applications	Warning	1
P3	**Defender for Cloud alert emails reach the right people** AZ-05 In Defender for Cloud, Environment settings, Email notifications, add your security team mailbox and the client contact, notify subscription owners, and send alerts of Medium severity or higher. (MCSB IR-2)	Azure security	Warning	0.5
P3	**Virtual machines use Trusted Launch** AZ-14 Use Trusted Launch (Secure Boot and vTPM) for new virtual machines and upgrade existing Generation 2 machines, so boot-level malware is blocked and BitLocker and Credential Guard can use a TPM. (MCSB PV-3)	Azure security	Warning	2
P3	**Critical resources have delete locks** AZ-20 Add CanNotDelete locks to Recovery Services vaults, key vaults and other resources whose loss would be hard to recover from, so they cannot be deleted by mistake or by a compromised account.	Azure governance and cost	Warning	1

Priority	Recommendation	Area	Status	Effort (hours)
P3	**No unattached disks or unused public IP addresses** AZ-22 Delete unattached managed disks and public IP addresses that are no longer needed (take a snapshot first if in doubt). They are charged whether or not they are used.	Azure governance and cost	Warning	1
P3	**Azure Advisor cost recommendations** AZ-23 Review the Azure Advisor cost recommendations with the client: right-size or shut down under-used virtual machines, buy reservations or savings plans for steady workloads, and apply Azure Hybrid Benefit where Windows Server and SQL licences allow.	Azure governance and cost	Warning	2
P3	**Every subscription has a budget alert** AZ-25 Create a monthly budget on each subscription with email alerts at 80% and 100% of forecast and actual spend, sent to the client and their IT provider, so unexpected costs are caught early.	Azure governance and cost	Warning	0.5
P3	**The Microsoft cloud security benchmark policy is assigned** AZ-26 Keep the Microsoft cloud security benchmark initiative (the Defender for Cloud default policy) assigned to every subscription or the management group above them, so Defender for Cloud can assess the resources.	Azure governance and cost	Warning	1
P3	**Network Watcher is enabled where networks exist** AZ-27 Make sure Network Watcher is enabled in every region that has virtual networks, and turn on virtual network flow logs for production networks. (MCSB LT-4)	Azure governance and cost	Warning	0.5
P3	**Domains that do not send mail are locked down** DNS-05 For parked or non-mail domains publish v=spf1 -all and a DMARC record with p=reject so they cannot be spoofed.	Email authentication	Warning	1
P3	**Devices are checking in with Intune** END-04 Investigate devices that have not synced for 30 days. Retire lost or replaced devices.	Intune and devices	Warning	1
P3	**Personal Windows device enrolment is blocked** END-08 Block personally owned Windows enrolment in the default platform restriction unless BYOD Windows is in scope, and use Autopilot for corporate devices.	Intune and devices	Warning	1
P3	**Intune policies are assigned** END-17 Assign or delete policies that are not assigned to anyone. Unassigned policies are often drafts or leftovers that make it hard to see what is really applied, and they can be assigned by mistake later.	Intune configuration health	Warning	1
P3	**Device clean-up rule removes inactive devices** END-29 In Devices, Device clean-up rules, remove devices that have not checked in for 90 to 180 days, so stale records do not skew compliance reports and licence counts.	Intune configuration health	Warning	0.5
P3	**External sender tagging is enabled in Outlook** EXO-13 Run Set-ExternalInOutlook -Enabled $true so Outlook marks mail from outside the organisation.	Exchange Online	Warning	0.5

Priority	Recommendation	Area	Status	Effort (hours)
P3	**Calendar details are not shared anonymously** EXO-14 Remove the Anonymous entry from the default sharing policy, or limit it to free/busy only.	Exchange Online	Warning	0.5
P3	**Outlook on the web third-party storage is disabled** EXO-15 Set AdditionalStorageProvidersAvailable to False on OWA mailbox policies so users cannot attach files from personal storage such as Dropbox.	Exchange Online	Warning	0.5
P3	**POP and IMAP are disabled where not needed** EXO-17 Disable POP and IMAP on mailboxes and in the CAS mailbox plans so new mailboxes do not get them. Keep only documented exceptions.	Exchange Online	Warning	1
P3	**Mailboxes approaching their quota** EXO-19 Enable archiving or auto-expanding archiving, or apply retention to mailboxes above 90% of their send quota.	Exchange Online	Warning	1
P3	**Strong authentication methods are enabled** IAM-08 Enable Microsoft Authenticator and passkeys (FIDO2) in the authentication methods policy, and enable the registration campaign to nudge users onto Authenticator.	Identity and access	Warning	1
P3	**Report-only and disabled Conditional Access policies** IAM-12 Review report-only policies with the sign-in log impact data, then enable or remove them. Delete disabled policies that are no longer needed.	Identity and access	Warning	1
P3	**Admin consent workflow is enabled** IAM-14 Enable the admin consent workflow so users can request apps rather than work around the block.	Identity and access	Warning	1
P3	**Self-service sign-up is disabled** IAM-18 Disable email-verified self-service sign-up and self-service subscription sign-up to stop unmanaged accounts and trials appearing in the tenant.	Identity and access	Warning	0.5
P3	**Passwords are set not to expire** IAM-19 With MFA enforced, set passwords to never expire in line with NCSC and Microsoft guidance. Forced rotation encourages weak, predictable passwords.	Identity and access	Warning	0.5
P3	**No inactive guest accounts** IAM-21 Remove guests who have not signed in within the inactivity window, or put an Entra access review in place for guests.	Identity and access	Warning	1
P3	**No stale devices in Entra ID** IAM-24 Disable, then delete, devices that have not signed in for the stale window, after checking for BitLocker and LAPS recovery needs.	Identity and access	Warning	2
P3	**Unassigned paid licences** LIC-01 Reduce subscription quantities at the next renewal, or assign the spare licences to users who need them.	Licensing	Warning	0.5
P3	**No licences assigned to disabled accounts** LIC-02 Remove licences from blocked accounts, or convert leavers to shared mailboxes where the mailbox must be kept and is under 50 GB.	Licensing	Warning	1

Priority	Recommendation	Area	Status	Effort (hours)
P3	**Shared and resource mailboxes are not licensed unnecessarily** LIC-04 Remove licences from shared and resource mailboxes unless they need more than 50 GB, an archive or a hold.	Licensing	Warning	0.5
P3	**Mailbox permissions do not reference deleted or disabled accounts** PRM-02 Remove permissions granted to deleted accounts (shown as SIDs) and to disabled accounts.	Permissions	Warning	1
P3	**Admins use separate accounts from daily email accounts** PRV-04 Give administrators a separate unlicensed admin account and remove admin roles from their mailbox-enabled daily accounts.	Privileged access	Warning	3
P3	**Idle session sign-out is configured** SPO-06 Enable idle session sign-out for unmanaged devices so browser sessions on shared or personal computers end automatically.	SharePoint and OneDrive	Warning	1
P3	**Physical servers encrypt their disks** SRV-14 Turn on BitLocker with TPM protection for physical servers, especially in branch offices or shared racks, and store recovery keys in Active Directory or Entra ID.	Windows servers	Warning	2
P3	**Windows update management** END-10 Confirm Windows updates are managed by exactly one tool. If updates are handled by the RMM, avoid assigning Intune update rings to the same devices.	Intune and devices	Warning	
	Total			**353.0**

5. Licence utilisation opportunities

Each feature below is included in licences Fabrikam Lettings Ltd already pays for. It is compared with what is configured or used in the tenant, so the client can see where they are paying for capability they are not getting value from. Licensed users counts enabled users whose assigned licences include the feature. Effort is an estimate in days for Contoso IT to plan and configure the feature, and is for scoping only.

7	11	2	36.5
Not used	**Partly used**	**In use**	**Days to adopt**
Licensed, not set up	Licensed, partly set up	Licensed and in use	Estimated effort

Identity and access

Not used **Self-service password reset** — 24 licensed users — OPP-02

LICENSED THROUGH	Microsoft 365 Business Premium
CURRENT USE	Enabled for SSPR: 0 of 24 licensed users; registered: 21.
OPPORTUNITY	Enable self-service password reset for all users with combined MFA and SSPR registration, password writeback for synced accounts and admin notifications.
BENEFIT	Fewer password reset calls to the service desk and faster recovery for users out of hours.
ESTIMATED EFFORT	0.5 days
REFERENCE	https://learn.microsoft.com/entra/identity/authentication/tutorial-enable-sspr

Not used **Dynamic groups** — 24 licensed users — OPP-03

LICENSED THROUGH	Microsoft 365 Business Premium
CURRENT USE	Dynamic membership groups: 0.
OPPORTUNITY	Create dynamic groups for departments, locations and device platforms so licences, Intune policies, Teams and app access follow joiners, movers and leavers automatically.
BENEFIT	Less manual administration and fewer access mistakes when staff change roles.
ESTIMATED EFFORT	0.5 days
REFERENCE	https://learn.microsoft.com/entra/identity/users/groups-dynamic-membership

Partly used

Conditional Access

24 licensed users OPP-01

LICENSED THROUGH	Microsoft 365 Business Premium
CURRENT USE	Enabled policies: 1; report-only: 1; security defaults: off. No full baseline (MFA for all users plus supporting policies).
OPPORTUNITY	Replace security defaults with a Conditional Access baseline: MFA for all users, block legacy authentication, phishing-resistant MFA for admins, compliant devices for corporate data and tighter controls for guests, with emergency access accounts excluded.
BENEFIT	Granular, auditable access control that security defaults cannot provide, without blocking legitimate users.
ESTIMATED EFFORT	2 days
REFERENCE	https://learn.microsoft.com/entra/identity/conditional-access/plan-conditional-access

Devices and endpoints

Not used

Device-based Conditional Access

22 licensed users OPP-09

LICENSED THROUGH	Microsoft 365 Business Premium
CURRENT USE	Enabled policies requiring a compliant or joined device: 0 (0 for all users).
OPPORTUNITY	Require a compliant or hybrid-joined device for access to email and files from desktops, and app protection on mobiles, so corporate data only reaches managed devices.
BENEFIT	Stolen passwords alone cannot be used to download company data to an unmanaged computer.
ESTIMATED EFFORT	1.5 days
REFERENCE	https://learn.microsoft.com/entra/identity/conditional-access/policy-all-users-device-compliance

Not used

Universal Print

24 licensed users OPP-14

LICENSED THROUGH	Microsoft 365 Business Premium
CURRENT USE	Printers registered in Universal Print: 0.
OPPORTUNITY	Move printers to Universal Print (natively or through the connector) and deploy them to users with Intune, removing on-premises print servers and driver management.
BENEFIT	Cloud printing from Entra joined devices with no print server to patch.
ESTIMATED EFFORT	1.5 days
REFERENCE	https://learn.microsoft.com/universal-print/fundamentals/universal-print-getting-started

Partly used

Intune device management

22 licensed users OPP-07

LICENSED THROUGH	Microsoft 365 Business Premium
CURRENT USE	Managed devices: 10 (6 Windows or macOS, 4 mobile) for 22 licensed users; assigned compliance policies: 2.
OPPORTUNITY	Enrol corporate Windows devices (Autopilot or Entra join) and mobiles in Intune, with compliance policies, security baselines, BitLocker, Windows LAPS and app deployment.
BENEFIT	Consistent, provable device security and remote wipe for lost or stolen devices.
ESTIMATED EFFORT	5 days
REFERENCE	https://learn.microsoft.com/intune/intune-service/fundamentals/deployment-guide-intune-setup

Partly used

App protection for mobiles

22 licensed users OPP-10

LICENSED THROUGH	Microsoft 365 Business Premium
CURRENT USE	Assigned app protection policies: iOS 1, Android 0.
OPPORTUNITY	Protect Outlook, Teams and OneDrive on phones with app protection policies (PIN, no copy to personal apps, selective wipe) without enrolling personal devices.
BENEFIT	Supports bring-your-own phones while keeping company data contained.
ESTIMATED EFFORT	1 day
REFERENCE	https://learn.microsoft.com/intune/intune-service/apps/app-protection-policy

Partly used

Defender for Endpoint or Defender for Business

24 licensed users OPP-11

LICENSED THROUGH	Microsoft 365 Business Premium
CURRENT USE	Onboarded devices: 4; Intune managed Windows and macOS devices: 6 (66.7% coverage).
OPPORTUNITY	Onboard all Windows, macOS and server endpoints through Intune, configure next-generation protection, attack surface reduction rules, EDR in block mode and automated investigation, and route alerts to the IT provider monitoring.
BENEFIT	Endpoint detection and response that can stop ransomware, often replacing a separately licensed antivirus product.
ESTIMATED EFFORT	3 days
REFERENCE	https://learn.microsoft.com/defender-business/mdb-setup-configuration

In use

Windows Autopilot

22 licensed users OPP-08

LICENSED THROUGH	Microsoft 365 Business Premium
CURRENT USE	Autopilot registered devices: 5; corporate Windows devices in Intune: 6.
REFERENCE	https://learn.microsoft.com/autopilot/overview

Threat protection

Partly used

Defender for Office 365 (Safe Links, Safe Attachments, impersonation)

24 licensed users 0PP-15

LICENSED THROUGH	Microsoft 365 Business Premium
CURRENT USE	Enabled preset policies: 0; custom Safe Links rules: 0; custom Safe Attachments rules: 0; anti-phishing policies with impersonation protection: 0. Only the Built-in protection policy applies, with default settings and no impersonation protection.
OPPORTUNITY	Apply the Standard or Strict preset security policies, or tuned custom policies, for Safe Links, Safe Attachments and impersonation protection across email, Teams and Office apps, with priority accounts for directors and finance.
BENEFIT	Stronger protection against phishing, business email compromise and malicious attachments than the default built-in policy.
ESTIMATED EFFORT	1 day
REFERENCE	https://learn.microsoft.com/defender-office-365/preset-security-policies

Information protection and compliance

Not used

Sensitivity labels

24 licensed users 0PP-17

LICENSED THROUGH	Microsoft 365 Business Premium
CURRENT USE	Sensitivity labels: 0; active label policies: 0.
OPPORTUNITY	Design and publish a sensitivity label taxonomy (Public, Internal, Confidential, Highly confidential) with encryption and visual markings, default labels for email and documents, and labels for Teams and SharePoint sites.
BENEFIT	Sensitive documents stay protected wherever they go, and it prepares the tenant for Copilot by controlling what it can surface.
ESTIMATED EFFORT	4 days
REFERENCE	https://learn.microsoft.com/purview/deploymentmodels/depmod-securebydefault-intro

Not used

Online archiving

24 licensed users 0PP-22

LICENSED THROUGH	Microsoft 365 Business Premium
CURRENT USE	User mailboxes with an active archive: 0 of 22; mailboxes over 40 GB without an archive: 1.
OPPORTUNITY	Enable online archives with auto-expanding archiving and an archive policy for large mailboxes, and retire PST files.
BENEFIT	Keeps large mailboxes fast and within quota without buying extra storage.
ESTIMATED EFFORT	0.5 days
REFERENCE	https://learn.microsoft.com/purview/enable-archive-mailboxes

Partly used

Data loss prevention for email and files

24 licensed users OPP-19

LICENSED THROUGH	Microsoft 365 Business Premium
CURRENT USE	Enabled DLP policies: 1 (0 enforced); enforced workloads: none.
OPPORTUNITY	Deploy DLP policies for UK financial and personal data across Exchange, SharePoint, OneDrive and Teams, starting in simulation mode, then policy tips and blocking for external sharing.
BENEFIT	Reduces the risk of a reportable data breach from misdirected email or oversharing.
ESTIMATED EFFORT	3 days
REFERENCE	https://learn.microsoft.com/purview/dlp-create-deploy-policy

Partly used

Retention policies

25 licensed users OPP-21

LICENSED THROUGH	Microsoft 365 Business Premium, Exchange Online (Plan 1), Microsoft 365 Business Standard
CURRENT USE	Active retention policies: 1; workloads covered org-wide: Exchange.
OPPORTUNITY	Agree retention requirements with the client and apply org-wide retention policies for Exchange, SharePoint, OneDrive and Teams so deleted or altered content can be recovered and records are kept for the required period.
BENEFIT	Protection against accidental or malicious deletion beyond the default recycle bin periods, and support for legal obligations.
ESTIMATED EFFORT	1 day
REFERENCE	https://learn.microsoft.com/purview/retention

Productivity and AI

Not used

Teams Phone

2 licensed users OPP-31

LICENSED THROUGH	Teams Phone Standard
CURRENT USE	Users licensed for Teams Phone: 2; numbers assigned to users: 0; other assigned numbers: 0.
OPPORTUNITY	Set up Teams Phone with Operator Connect, Direct Routing or Calling Plans, port the numbers, build auto attendants and call queues, and assign numbers to licensed users.
BENEFIT	Replaces a separate phone system and puts calling in the app users already have open.
ESTIMATED EFFORT	3 days
REFERENCE	https://learn.microsoft.com/microsoftteams/what-is-phone-system-in-office-365

Partly used

Microsoft 365 desktop apps

24 licensed users 0PP-27

LICENSED THROUGH	Microsoft 365 Business Premium
CURRENT USE	Users with desktop apps activated on Windows or Mac: 12 of 24 licensed (50%).
OPPORTUNITY	Deploy Microsoft 365 Apps through Intune on a supported update channel, use shared computer activation where needed, and retire older perpetual Office versions.
BENEFIT	Users get current, supported Office apps and the client can stop paying for separate Office licences.
ESTIMATED EFFORT	1 day
REFERENCE	https://learn.microsoft.com/intune/intune-service/apps/apps-add-office365

Partly used

OneDrive

24 licensed users 0PP-28

LICENSED THROUGH	Microsoft 365 Business Premium
CURRENT USE	9 of 21 licensed users were active in OneDrive in the last 30 days (42.9%).
OPPORTUNITY	Configure OneDrive silently with Known Folder Move (Desktop, Documents and Pictures) through Intune so user files are protected and available on any device.
BENEFIT	User files are backed up to the cloud and a lost laptop no longer means lost work.
ESTIMATED EFFORT	1 day
REFERENCE	https://learn.microsoft.com/sharepoint/redirect-known-folders

Partly used

SharePoint for company files

24 licensed users 0PP-29

LICENSED THROUGH	Microsoft 365 Business Premium
CURRENT USE	6 of 21 licensed users were active in SharePoint in the last 30 days (28.6%).
OPPORTUNITY	Migrate remaining file shares to SharePoint and Teams with a clear site structure, permissions based on groups, and retirement of the old file server.
BENEFIT	Secure access from anywhere, version history and co-authoring, and one less server to maintain and back up.
ESTIMATED EFFORT	5 days
REFERENCE	https://learn.microsoft.com/sharepointmigration/migrate-to-sharepoint-online

Partly used

Microsoft 365 Copilot

3 licensed users 0PP-32

LICENSED THROUGH	Microsoft 365 Copilot
CURRENT USE	Users licensed for Copilot: 3; active in the last 30 days: 1 (33.3%).
OPPORTUNITY	Run a Copilot adoption programme: check oversharing and sensitivity labels first, train champions, run role-based scenario sessions, and review usage monthly to reassign idle licences.
BENEFIT	A return on an expensive licence, and idle licences moved to people who will use them.
ESTIMATED EFFORT	2 days
REFERENCE	https://learn.microsoft.com/copilot/microsoft-365/microsoft-365-copilot-enablement-resources

In use **Microsoft Teams** 24 licensed users OPP-30

LICENSED THROUGH	Microsoft 365 Business Premium
CURRENT USE	17 of 21 licensed users were active in Teams in the last 30 days (81%).
REFERENCE	https://learn.microsoft.com/microsoftteams/teams-adoption-get-started

6. CIS and CISA SCuBA benchmarks

Every control in the CIS Microsoft 365 Foundations Benchmark v7.0.0 and the CISA SCuBA secure configuration baselines for Microsoft 365 (ScubaGear 2.0) was assessed from the same data as the findings. Met and Not met are automated results. Check manually covers settings that have no API or need a judgement call. Not applicable means the control needs a licence the tenant does not have, or applies only to US federal agencies. The percentage is controls met divided by controls met plus not met. Control titles are short summaries; the published benchmarks hold the full wording. Mapped controls shows the matching control in the other framework, and Related checks shows the related findings in this report.



CIS Microsoft 365 Foundations Benchmark

v7.0.0

Met	**29**
Not met	**101**
Check manually	**15**
Not assessed	**0**
Not applicable	**15**
Level 1 controls met	**27%**



CISA SCuBA secure configuration baselines for Microsoft 365

ScubaGear 2.0

Met	**24**
Not met	**68**
Check manually	**6**
Not assessed	**0**
Not applicable	**11**
SHALL controls met	**30%**

Results by section

Framework	Section	Met	Not met	Check manually	Other
CIS v7.0.0	Microsoft 365 admin centre	2	10	2	1
CIS v7.0.0	Microsoft Defender	4	12	0	5
CIS v7.0.0	Microsoft Purview	1	3	0	1
CIS v7.0.0	Microsoft Intune	0	2	0	0
CIS v7.0.0	Microsoft Entra ID	7	37	11	8
CIS v7.0.0	Exchange Online	3	10	0	0
CIS v7.0.0	SharePoint and OneDrive	1	10	1	0
CIS v7.0.0	Microsoft Teams	5	11	1	0
CIS v7.0.0	Microsoft Fabric (Power BI)	6	6	0	0
CISA SCuBA	Microsoft Entra ID	4	19	2	9
CISA SCuBA	Defender and Purview	8	13	2	1
CISA SCuBA	Exchange Online	2	9	0	1
CISA SCuBA	SharePoint and OneDrive	0	8	0	0

Framework	Section	Met	Not met	Check manually	Other
CISA SCuBA	Microsoft Teams	5	9	0	0
CISA SCuBA	Power BI	3	5	0	0
CISA SCuBA	Power Platform	2	5	2	0

Controls

CIS v7.0.0: Microsoft 365 admin centre

Not met **Administrative accounts are cloud-only** E3 L1 CIS 1.1.1

2 of 7 administrators are synchronised from on-premises.

How to meet it: Use separate cloud-only accounts (onmicrosoft.com or a cloud UPN) for every administrative role, never accounts synchronised from on-premises AD.

Mapped controls: MS.AAD.7.3v1 Related checks: PRV-03 (Warning)

2 affected items (listed in the HTML report and BenchmarkDetails.csv)

Check manually **Two emergency access accounts are in place** E3 L1 CIS 1.1.2

Excluded from every enabled Conditional Access policy: breakglass01@fabrikam.onmicrosoft.com. Confirm these are the emergency access accounts, that they use phishing-resistant sign-in, and that the procedure is documented.

How to meet it: Keep two cloud-only Global Administrator accounts for emergencies, protected with FIDO2 keys or certificates, excluded from Conditional Access, monitored, and covered by a documented procedure.

Related checks: IAM-10 (Pass)

Not met **Between two and four Global Administrators** E3 L1 CIS 1.1.3

5 Global Administrator accounts: admin@fabrikam.onmicrosoft.com, breakglass01@fabrikam.onmicrosoft.com, jane.director@fabrikam.example, tom.synced@fabrikam.example, isla.patel@fabrikam.example.

How to meet it: Keep at least two Global Administrators for resilience and no more than four, using narrower roles for day-to-day administration.

Mapped controls: MS.AAD.7.1v1 Related checks: PRV-01 (Fail)

5 affected items (listed in the HTML report and BenchmarkDetails.csv)

Not met **Administrators hold only identity licences** E3 L1 CIS 1.1.4

4 of 7 administrators have productivity licences (Exchange, SharePoint, Teams or Office apps).

How to meet it: Admin accounts should carry an Entra ID licence only, not Exchange, SharePoint, Teams or Office apps, so they cannot be phished through mail or collaboration.

Related checks: PRV-04 (Warning)

4 affected items (listed in the HTML report and BenchmarkDetails.csv)

Not met **Microsoft 365 groups are private** E3 L2 CIS 1.2.1

1 public Microsoft 365 group.

How to meet it: Set Microsoft 365 groups and Teams to private unless there is a business reason for them to be public, and approve public groups through governance.

Related checks: COL-04 (Info)

1 affected item (listed in the HTML report and BenchmarkDetails.csv)

Not met **Sign-in is blocked for shared mailboxes** E3 L1 CIS 1.2.2

2 of 2 shared mailboxes allow sign-in.

How to meet it: Block sign-in on the Entra accounts behind shared mailboxes; people access them through delegated permissions.

Related checks: EXO-16 (Warning)

2 affected items (listed in the HTML report and BenchmarkDetails.csv)

Not met **Passwords are set never to expire** E3 L1 CIS 1.3.1

Passwords expire on 1 domain.

How to meet it: Set the password expiry policy to never expire, combined with MFA and banned password lists, in line with NCSC and NIST guidance.

Mapped controls: MS.AAD.6.1v1 Related checks: IAM-19 (Warning)

1 affected item (listed in the HTML report and BenchmarkDetails.csv)

Not met **Idle web sessions sign out within three hours** E3 L2 CIS 1.3.2

Idle session timeout is 6 hours. No Conditional Access policy applies app enforced restrictions to Office 365 browser sessions.

How to meet it: Turn on idle session timeout in the Microsoft 365 admin centre (3 hours or less) and add a Conditional Access policy for Office 365 browser sessions using app enforced restrictions.

Related checks: SPO-06 (Warning)

Not met **External calendar sharing is off** E3 L2 CIS 1.3.3

The default sharing policy is enabled: Anonymous:CalendarSharingFreeBusyReviewer, *:CalendarSharingFreeBusySimple.

How to meet it: Disable the Default Sharing Policy (or remove anonymous and all-domain calendar sharing) so calendars are not published outside the organisation.

Mapped controls: MS.EXO.6.2v1 Related checks: EXO-14 (Warning)

Not met **Users cannot use the Office Store or start trials** E3 L1 CIS 1.3.4

Office Store: allowed; user trials: blocked.

How to meet it: In Org settings, User owned apps and services, untick access to the Office Store and the option for users to start trials.

Check manually **Sway cannot be shared externally** E3 L2 CIS 1.3.8

This control cannot be read through an API. Check it by hand using the guidance.

How to meet it: In Org settings, Sway, untick letting people share sways with people outside the organisation. There is no API for this setting.

Not met **Shared Bookings is restricted** E3 L1 CIS 1.3.9

Bookings is on and users can create shared booking pages.

How to meet it: Turn off Bookings mailbox creation in the default OWA mailbox policy, or turn Bookings off for the organisation, and enable it only for approved users.

CIS v7.0.0: Microsoft Defender

Not met — Safe Links protects email, Teams and Office apps

E5 L2 | CIS | 2.1.1

Closest applied policy is Built-in protection, which differs on: TrackClicks, AllowClickThrough, ScanUrls, EnableForInternalSenders, DeliverMessageAfterScan.

How to meet it: Apply a Safe Links policy (or the Standard or Strict preset) that covers email, Teams and Office apps, scans URLs in real time, waits for scanning, tracks clicks and does not let users click through.

Mapped controls: MS.SECURITYSUITE.7.1v1; MS.SECURITYSUITE.7.2v1; MS.SECURITYSUITE.7.3v1

Related checks: EXO-10 (Warning) Needs: Defender for Office 365

Not met — Admins are told when internal users send malware

E3 L1 | CIS | 2.1.3

Internal sender malware notifications are not set up in the default anti-malware policy.

How to meet it: In the anti-malware policy, turn on notifications to an administrator mailbox when internal senders send malware.

Not met — Outbound spam notifications are set up

E3 L1 | CIS | 2.1.6

Copy suspicious messages: off; notify when blocked: off.

How to meet it: In the default outbound anti-spam policy, copy suspicious outbound messages to and notify a monitored mailbox when a sender is blocked.

Not met — Anti-phishing policy is tuned for impersonation

E5 L2 | CIS | 2.1.7

Closest applied policy is Office365 AntiPhish Default, which differs on: threshold 1, TargetedUserProtection, OrganizationDomainsProtection, MailboxIntelligenceProtection, FirstContactSafetyTips, SimilarUsersSafetyTips, SimilarDomainsSafetyTips, UnusualCharactersSafetyTips and 4 more.

How to meet it: Apply an anti-phishing policy to most of the organisation with threshold 3 or higher, user and domain impersonation protection, mailbox intelligence, quarantine actions, all safety tips and honour DMARC.

Mapped controls: MS.SECURITYSUITE.2.1v1; MS.SECURITYSUITE.2.2v1; MS.SECURITYSUITE.2.4v1

Related checks: EXO-09 (Warning) Needs: Defender for Office 365

Not met — SPF is published for every mail domain

E3 L1 | CIS | 2.1.8

2 of 3 domains do not meet the SPF requirement.

How to meet it: Publish one SPF record per sending domain ending in -all or ~all, and v=spf1 -all on domains that do not send mail.

Mapped controls: MS.EXO.2.2v3 Related checks: DNS-01 (Fail); DNS-05 (Warning)

2 affected items (listed in the HTML report and BenchmarkDetails.csv)

Not met — DKIM is enabled for every mail domain

E3 L1 | CIS | 2.1.9

1 of 2 mail domains are not DKIM signing.

How to meet it: Publish the selector CNAME records and enable DKIM signing for every custom domain that sends mail.

Mapped controls: MS.EXO.3.1v1 Related checks: DNS-02 (Fail)

1 affected item (listed in the HTML report and BenchmarkDetails.csv)

Not met — DMARC is enforced with reporting

E3 L1 | CIS | 2.1.10

4 of 4 domains do not meet the DMARC requirement.

How to meet it: Publish DMARC with p=quarantine or p=reject, pct=100, and rua and ruf reporting addresses on every custom domain and the onmicrosoft.com domain.

Mapped controls: MS.EXO.4.1v1; MS.EXO.4.2v1; MS.EXO.4.4v1 Related checks: DNS-03 (Fail); DNS-04 (Pass)

4 affected items (listed in the HTML report and BenchmarkDetails.csv)

Not met **A comprehensive attachment filter is in place** E3 L2 CIS 2.1.11

No applied anti-malware policy blocks more than 120 file types.

How to meet it: Apply an anti-malware policy that blocks at least 90% of the extended list of risky file types (184 types), documenting any exceptions.

Mapped controls: MS.SECURITYSUITE.1.1v1

Not met **The connection filter IP allow list is empty** E3 L1 CIS 2.1.12

The IP allow list has 1 entry: 203.0.113.10.

How to meet it: Remove entries from the IP allow list in the default connection filter policy; use mail flow rules or the Tenant Allow/Block List with care instead.

Mapped controls: MS.SECURITYSUITE.8.1v1

Not met **Inbound anti-spam policies allow no sender domains** E3 L1 CIS 2.1.14

1 anti-spam policy allows whole sender domains.

How to meet it: Remove all allowed sender domains from inbound anti-spam policies.

Mapped controls: MS.SECURITYSUITE.6.2v1 Related checks: EXO-08 (Warning)

1 affected item (listed in the HTML report and BenchmarkDetails.csv)

Not met **Outbound spam limits are set** E3 L1 CIS 2.1.15

The external recipient limit per hour is the service default; the internal recipient limit per hour is the service default; the daily recipient limit is the service default; the action when a limit is reached is BlockUserForToday; no notification recipients are set.

How to meet it: In the default outbound anti-spam policy set limits of 500 external and 1000 internal recipients per hour and 1000 per day, restrict the user when reached and notify a monitored mailbox.

Not met **Strict preset policies protect priority accounts** E5 L1 CIS 2.4.2

Strict preset: EOP rule missing; ATP rule missing.

How to meet it: Turn on the Strict preset security policy and add priority accounts or groups to both the Exchange Online Protection and Defender for Office 365 sections.

Needs: Defender for Office 365

CIS v7.0.0: Microsoft Purview

Not met **DLP policies are turned on** E3 L1 CIS 3.2.1

DLP policies exist but none are enforced (test or off): U.K. Financial Data.

How to meet it: Create and enforce DLP policies for Exchange, SharePoint and OneDrive covering the sensitive information the organisation handles.

Mapped controls: MS.SECURITYSUITE.3.1v1; MS.SECURITYSUITE.3.2v1 Related checks: PUR-01 (Warning)

Needs: Data loss prevention

Not met **DLP covers Microsoft 365 Copilot** E5 L1 CIS 3.2.3

No enforced DLP policy targets Microsoft 365 Copilot.

How to meet it: Enforce a DLP policy for Microsoft 365 Copilot and Copilot Chat so labelled or sensitive content is not processed or surfaced.

Needs: Microsoft 365 Copilot

Not met **Sensitivity label policies are published** E3 L1 CIS 3.3.1

No sensitivity label policy is published.

How to meet it: Create sensitivity labels and publish them with a label policy so users can classify content.

Related checks: PUR-03 (Warning)

CIS v7.0.0: Microsoft Intune

Not met **Devices without a compliance policy are non-compliant** E3 L1 CIS 4.1

Devices with no compliance policy are treated as compliant.

How to meet it: In Intune compliance policy settings, mark devices with no compliance policy assigned as Not compliant.

Related checks: END-02 (Warning) Needs: Microsoft Intune

Not met **Personal devices cannot enrol in Intune** E3 L1 CIS 4.2

Personal devices can enrol on: windows.

How to meet it: In the default device platform restriction, block personally owned devices for every platform, or block platforms that are not used.

Related checks: END-08 (Warning) Needs: Microsoft Intune

CIS v7.0.0: Microsoft Entra ID

Check manually **Per-user MFA is turned off** E3 L1 CIS 5.1.2.1

This control cannot be read through an API. Check it by hand using the guidance.

How to meet it: In Entra ID, Per-user MFA, confirm every account shows Disabled, and enforce MFA with Conditional Access instead.

Not met **Users cannot register applications** E3 L1 CIS 5.1.2.2

Users can register applications.

How to meet it: Set Users can register applications to No.

Mapped controls: MS.AAD.5.1v1 Related checks: IAM-15 (Warning)

Not met **Users cannot create tenants** E3 L1 CIS 5.1.2.3

Users can create tenants.

How to meet it: Set Restrict non-admin users from creating tenants to Yes.

Related checks: IAM-15 (Warning)

Check manually **Entra admin centre access is restricted** E3 L1 CIS 5.1.2.4

This control cannot be read through an API. Check it by hand using the guidance.

How to meet it: In Entra ID, User settings, set Restrict access to Microsoft Entra admin center to Yes.

Check manually **The stay signed in prompt is hidden** E3 L2 CIS 5.1.2.5

This control cannot be read through an API. Check it by hand using the guidance.

How to meet it: In Company branding, set Show option to remain signed in to No.

Check manually **LinkedIn account connections are off** E3 L2 CIS 5.1.2.6

This control cannot be read through an API. Check it by hand using the guidance.

How to meet it: In Entra ID, User settings, set LinkedIn account connections to No.

Not met **Users cannot create security groups** E3 L1 CIS 5.1.3.1

Users can create security groups.

How to meet it: Set Users can create security groups to No.

Check manually **My Groups web access is restricted** E3 L2 CIS 5.1.3.2

This control cannot be read through an API. Check it by hand using the guidance.

How to meet it: In Entra ID, Groups, General, set Restrict user ability to access groups features in My Groups to Yes.

Check manually **Self-service group management is restricted** E3 L1 CIS 5.1.3.3

This control cannot be read through an API. Check it by hand using the guidance.

How to meet it: In Entra ID, Groups, General, set Owners can manage group membership requests in My Groups to No.

Not met **Microsoft 365 group creation is restricted** E3 L2 CIS 5.1.3.4

All users can create Microsoft 365 groups.

How to meet it: Set EnableGroupCreation to false in the Group.Unified directory setting and allow a named security group to create groups.

Related checks: COL-01 (Info)

Not met **Entra join is limited to selected users** E3 L2 CIS 5.1.4.1

All users can join devices to Entra ID.

How to meet it: Set Users may join devices to Microsoft Entra to Selected or None.

Not met **Each user can register ten devices or fewer** E3 L1 CIS 5.1.4.2

The device limit is 50.

How to meet it: Set Maximum number of devices per user to 10 or less.

Not met **Global Administrators are not added as local admins** E3 L1 CIS 5.1.4.3

Global Administrators become local administrators on every joined device.

How to meet it: Set Global administrator role is added as local administrator on the device during Microsoft Entra join to No, and use Windows LAPS instead.

Not met **The registering user is not made local admin** E3 L1 CIS 5.1.4.4

Every user who joins a device becomes its local administrator.

How to meet it: Set Registering user is added as local administrator on the device during Microsoft Entra join to Selected or None.

Not met **Entra LAPS is turned on** E3 L1 CIS 5.1.4.5

Entra LAPS is turned off.

How to meet it: Set Enable Microsoft Entra Local Administrator Password Solution (LAPS) to Yes and deploy a Windows LAPS policy.

Related checks: IAM-25 (Warning)

Not met **Users cannot read their own BitLocker keys** E3 L2 CIS 5.1.4.6

Users can read the BitLocker keys of their own devices.

How to meet it: Set Restrict users from recovering the BitLocker key(s) for their owned devices to Yes.

Not met **Users cannot consent to applications** E3 L2 CIS 5.1.5.1

User consent is allowed: Allow user consent for apps (legacy setting).

How to meet it: Set user consent for applications to Do not allow user consent and use the admin consent workflow.

Mapped controls: MS.AAD.5.2v1 Related checks: IAM-13 (Fail)

Not met **The admin consent workflow is on** E3 L1 CIS 5.1.5.2

The admin consent workflow is off.

How to meet it: Turn on the admin consent request workflow with named reviewers.

Mapped controls: MS.AAD.5.3v1 Related checks: IAM-14 (Warning)

Not met **Apps cannot add password credentials** E3 L2 CIS 5.1.5.3

New client secrets blocked: not enforced for applications; not enforced for service principals.

How to meet it: Enable the tenant app management policy restriction that blocks new password credentials for applications and service principals.

Mapped controls: MS.AAD.5.5v1

Not met **App secrets last 180 days or less** E3 L1 CIS 5.1.5.4

Client secret lifetime limit: 365 days allowed for applications; not enforced for service principals.

How to meet it: Enable the app management policy restriction that limits client secret lifetime to 180 days or less.

Mapped controls: MS.AAD.5.6v1

Not met **Custom app passwords are blocked** E3 L1 CIS 5.1.5.5

Custom passwords blocked: not enforced for applications; not enforced for service principals.

How to meet it: Enable the app management policy restriction that blocks custom (caller supplied) password credentials.

Not met **App certificates last 180 days or less** E3 L1 CIS 5.1.5.6

Certificate lifetime limit: not enforced for applications; not enforced for service principals.

How to meet it: Enable the app management policy restriction that limits certificate credential lifetime.

Mapped controls: MS.AAD.5.7v1

Not met **Guest invitations are limited to approved domains** E3 L2 CIS 5.1.6.1

A block list is used instead of an allow list: gmail.com.

How to meet it: In External collaboration settings, allow invitations only to the specified domains and list the approved partner domains.

Mapped controls: MS.AAD.8.3v1

Not met **Only admins and Guest Inviters can invite guests** E3 L2 CIS 5.1.6.3

Invitations: adminsGuestInvitersAndAllMembers.

How to meet it: Set guest invite restrictions to Only users assigned to specific admin roles can invite guest users, or No one.

Mapped controls: MS.AAD.8.2v1 Related checks: IAM-16 (Warning)

Not met **Legacy authentication is blocked** E3 L1 CIS 5.2.2.3

No enabled Conditional Access policy blocks legacy authentication for all users. Report-only policies that would meet it once switched on: CA002 Block legacy authentication.

How to meet it: Create a Conditional Access policy for all users and all resources that blocks Exchange ActiveSync and other legacy clients.

Mapped controls: MS.AAD.1.1v1 Related checks: IAM-02 (Warning)

Not met **Admin sessions re-authenticate and do not persist** E3 L1 CIS 5.2.2.4

No enabled Conditional Access policy limits administrator sessions to 4 hours with no persistent browser.

How to meet it: For administrator roles, set sign-in frequency to 4 hours or less and persistent browser session to never.

Not met **Administrators use phishing-resistant MFA** E3 L2 CIS 5.2.2.5

No enabled Conditional Access policy requires phishing-resistant MFA for the administrator roles.

How to meet it: Require the phishing-resistant MFA authentication strength for the administrator roles on all resources.

Mapped controls: MS.AAD.3.6v1 Related checks: IAM-04 (Warning)

Not met **A managed device is required for access** E3 L1 CIS 5.2.2.9

No enabled Conditional Access policy requires a compliant device for all users on all resources.

How to meet it: Require a compliant or hybrid joined device for all users and all resources with Conditional Access.

Mapped controls: MS.AAD.3.7v1 Related checks: IAM-11 (Warning)

Not met **A managed device is required to register security info** E3 L1 CIS 5.2.2.10

No enabled Conditional Access policy requires a compliant device to register security information.

How to meet it: Create a Conditional Access policy for the Register security information user action that requires a compliant or hybrid joined device.

Mapped controls: MS.AAD.3.8v1

Not met **Intune enrolment requires sign-in every time** E3 L1 CIS 5.2.2.11

No enabled Conditional Access policy requires MFA every time for Intune enrolment.

How to meet it: Create a Conditional Access policy for the Microsoft Intune Enrollment app requiring MFA with sign-in frequency every time.

Not met **Device code sign-in is blocked** E3 L1 CIS 5.2.2.12

No enabled Conditional Access policy blocks the device code flow for all users.

How to meet it: Create a Conditional Access policy for all users and all resources that blocks the device code flow, with documented exceptions only.

Mapped controls: MS.AAD.3.9v1

Not met **Users sign in again at least every seven days** E3 L1 CIS 5.2.2.13

No enabled Conditional Access policy sets sign-in frequency of 7 days or less for all users.

How to meet it: Create a Conditional Access policy for all users and all resources with periodic re-authentication of 7 days or less.

Not met **Sign-ins from untrusted locations are blocked** E3 L2 CIS 5.2.2.15

No enabled Conditional Access policy blocks sign-ins from untrusted locations.

How to meet it: Block access for all users from untrusted or out-of-scope countries and locations, excluding trusted locations.

Not met **Token protection is required for desktop apps** E3 L2 CIS 5.2.2.16

No enabled Conditional Access policy requires token protection for Exchange, SharePoint and Teams on Windows.

How to meet it: Require token protection for sign-in sessions on Windows desktop clients for Exchange Online, SharePoint Online and Teams.

Not met **Authentication transfer is blocked** E3 L1 CIS 5.2.2.17

No enabled Conditional Access policy blocks authentication transfer for all users.

How to meet it: Create a Conditional Access policy for all users and all resources that blocks the authentication transfer flow.

Not met **Authenticator shows app name and location** E3 L1 CIS 5.2.3.1

The location is not shown to all users.

How to meet it: Enable Microsoft Authenticator for all users and turn on showing the application name and geographic location in push notifications.

Mapped controls: MS.AAD.3.3v2

Not met **A custom banned password list is enforced** E3 L1 CIS 5.2.3.2

No custom banned password list is enforced.

How to meet it: In Password protection, set Enforce custom list to Yes and add organisation-specific words.

Not met **Password protection is enforced on-premises** E3 L1 CIS 5.2.3.3

On-premises password protection is in Audit mode (the default), so weak passwords are logged but not blocked.

How to meet it: Deploy the Entra password protection agents to domain controllers and set the mode to Enforced.

Not met **All members are MFA capable** E3 L1 CIS 5.2.3.4

3 of 29 members are not MFA capable.

How to meet it: Make sure every member account has registered a strong method that the authentication methods policy allows.

Related checks: IAM-05 (Fail)

3 affected items (listed in the HTML report and BenchmarkDetails.csv)

Not met **SMS and voice sign-in methods are off** E3 L1 CIS 5.2.3.5

Still enabled: Sms.

How to meet it: Disable SMS and voice call in the authentication methods policy once users have moved to Authenticator or passkeys.

Mapped controls: MS.AAD.3.5v2 Related checks: IAM-07 (Warning)

Not met **System-preferred MFA is on** E3 L1 CIS 5.2.3.6

System-preferred MFA is Microsoft managed, not explicitly enabled.

How to meet it: Turn on system-preferred multifactor authentication for all users.

Not met **Email one-time passcode is off** E3 L2 CIS 5.2.3.7

Email one-time passcode is enabled.

How to meet it: Disable email OTP in the authentication methods policy.

Mapped controls: MS.AAD.3.5v2

Not met **Authenticator Lite in companion apps is off** E3 L1 CIS 5.2.3.10

Authenticator Lite is Microsoft managed (enabled).

How to meet it: In the Microsoft Authenticator method settings, disable Microsoft Authenticator on companion applications.

Check manually **Self-service password reset is on for all users** E3 L1 CIS 5.2.4.1

This control cannot be read through an API. Check it by hand using the guidance.

How to meet it: In Password reset, Properties, set Self service password reset enabled to All.

Check manually **Password reset needs two methods** E3 L2 CIS 5.2.4.2

This control cannot be read through an API. Check it by hand using the guidance.

How to meet it: In Password reset, Authentication methods, set Number of methods required to reset to 2.

Check manually **Users must register for password reset at sign-in** E3 L1 CIS 5.2.4.3

This control cannot be read through an API. Check it by hand using the guidance.

How to meet it: In Password reset, Registration, require users to register when signing in and set a non-zero re-confirmation period.

Check manually **Users are notified of password resets** E3 L1 CIS 5.2.4.4

This control cannot be read through an API. Check it by hand using the guidance.

How to meet it: In Password reset, Notifications, set Notify users on password resets to Yes.

Check manually **Admins are notified when other admins reset passwords** E3 L1 CIS 5.2.4.5

This control cannot be read through an API. Check it by hand using the guidance.

How to meet it: In Password reset, Notifications, set Notify all admins when other admins reset their password to Yes.

CIS v7.0.0: Exchange Online

Not met **User mailboxes audit the full set of actions** E3 L1 CIS 6.1.2

2 of 22 user mailboxes are missing audit actions.

How to meet it: Make sure every user mailbox has auditing enabled with the full admin, delegate and owner action sets.

Mapped controls: MS.EXO.13.1v1

2 affected items (listed in the HTML report and BenchmarkDetails.csv)

Not met **No accounts bypass mailbox auditing** E3 L1 CIS 6.1.3

1 account bypasses mailbox auditing.

How to meet it: Remove audit bypass from every account with Set-MailboxAuditBypassAssociation -AuditBypassEnabled $false.

1 affected item (listed in the HTML report and BenchmarkDetails.csv)

Not met **Mail forwarding to external domains is blocked** E3 L1 CIS 6.2.1

1 setting allows mail to be forwarded outside the organisation.

How to meet it: Set automatic forwarding to Off in every outbound anti-spam policy and remove mail flow rules that redirect mail to external addresses.

Mapped controls: MS.EXO.1.1v2 Related checks: EXO-05 (Pass); EXO-07 (Warning)

1 affected item (listed in the HTML report and BenchmarkDetails.csv)

Not met **External email is tagged in Outlook** E3 L1 CIS 6.2.3

External tagging is off.

How to meet it: Run Set-ExternalInOutlook -Enabled $true and keep the allow list to approved addresses.

Mapped controls: MS.EXO.7.1v1 Related checks: EXO-13 (Warning)

Not met **Users cannot install Outlook add-ins** E3 L2 CIS 6.3.1

The default policy (Default Role Assignment Policy) still grants: My Custom Apps, My Marketplace Apps, My ReadWriteMailbox Apps.

How to meet it: Remove My Custom Apps, My Marketplace Apps and My ReadWriteMailbox Apps from the default role assignment policy.

Not met **Personal accounts are blocked in Outlook** E3 L1 CIS 6.3.2

Not blocked: PersonalAccountsEnabled.

How to meet it: Set PersonalAccountsEnabled and PersonalAccountCalendarsEnabled to $false on the default OWA mailbox policy.

Not met **MailTips are on** E3 L1 CIS 6.5.2

Not set: MailTipsExternalRecipientsTipsEnabled.

How to meet it: Turn on all MailTips, external recipient tips and group metrics, and set a large audience threshold (25 by default).

Not met **Outlook on the web third-party storage is off** E3 L2 CIS 6.5.3

Users can open files from third-party storage in Outlook on the web.

How to meet it: Set AdditionalStorageProvidersAvailable to $false on the default OWA mailbox policy.

Related checks: EXO-15 (Warning)

Not met **SMTP AUTH is off for the organisation** E3 L1 CIS 6.5.4

SMTP AUTH is on for the organisation.

How to meet it: Turn off SMTP AUTH for the organisation and enable it only on the mailboxes that need it.

Mapped controls: MS.EXO.5.1v1 Related checks: EXO-04 (Fail)

Not met **Direct Send is rejected** E3 L2 CIS 6.5.5

Direct Send is allowed.

How to meet it: Run Set-OrganizationConfig -RejectDirectSend $true once devices and services that send as the organisation use a connector or SMTP relay.

CIS v7.0.0: SharePoint and OneDrive

Not met **SharePoint requires modern authentication** E3 L1 CIS 7.2.1

Apps that do not use modern authentication can access SharePoint.

How to meet it: Turn off apps that do not use modern authentication in SharePoint access control.

Related checks: SPO-04 (Warning)

Not met **SharePoint external sharing is restricted** E3 L1 CIS 7.2.3

SharePoint sharing: Anyone.

How to meet it: Set SharePoint external sharing to New and existing guests or more restrictive, not Anyone.

Mapped controls: MS.SHAREPOINT.1.1v1 Related checks: SPO-01 (Warning)

Not met **OneDrive content is not shared externally** E3 L2 CIS 7.2.4

OneDrive sharing: Anyone.

How to meet it: Set OneDrive external sharing to Only people in your organisation.

Mapped controls: MS.SHAREPOINT.1.2v1

Not met **Guests cannot reshare content** E3 L2 CIS 7.2.5

Guests can reshare content they do not own.

How to meet it: Untick Allow guests to share items they don't own.

Related checks: SPO-02 (Warning)

Not met **External sharing is limited to allowed domains** E3 L2 CIS 7.2.6

External sharing is not limited by domain.

How to meet it: Limit external sharing by domain with an allow list of trusted partner domains, or turn external sharing off.

Mapped controls: MS.SHAREPOINT.1.3v1 Related checks: SPO-05 (Info)

Not met **The default sharing link is restricted** E3 L1 CIS 7.2.7

Default link: Anyone.

How to meet it: Set the default link type to Specific people or Only people in your organisation.

Mapped controls: MS.SHAREPOINT.2.1v1

Check manually **External sharing is limited to security groups** E3 L2 CIS 7.2.8

The security group allow list is not exposed in the tenant settings that were read. Check More external sharing settings in the SharePoint admin centre.

How to meet it: Allow only members of named security groups to share externally (More external sharing settings).

Not met **Guest access expires after 30 days** E3 L1 CIS 7.2.9

Guest access does not expire.

How to meet it: Tick Guest access to a site or OneDrive will expire automatically and set it to 30 days.

Not met **Verification code users re-authenticate within 15 days** E3 L1 CIS 7.2.10

Re-authentication is not required.

How to meet it: Tick People who use a verification code must reauthenticate after this many days and set 15 or less.

Mapped controls: MS.SHAREPOINT.3.3v2

Not met **The default link permission is view** E3 L1 CIS 7.2.11

Default link permission: Edit.

How to meet it: Set the default permission for sharing links to View.

Mapped controls: MS.SHAREPOINT.2.2v1

Not met **Infected files cannot be downloaded** E5 L2 CIS 7.3.1

Users can download files flagged as malicious.

How to meet it: Run Set-SPOTenant -DisallowInfectedFileDownload $true.

Needs: Defender for Office 365

CIS v7.0.0: Microsoft Teams

Not met **Only approved cloud storage is used in Teams** E3 L2 CIS 8.1.1

Enabled providers: Dropbox, GoogleDrive. Accept only if approved.

How to meet it: Turn off third-party cloud storage providers in Teams files settings unless approved.

Not met **Email into Teams channels is off** E3 L1 CIS 8.1.2

Users can send email to channel addresses.

How to meet it: Turn off Users can send emails to a channel email address.

Mapped controls: MS.TEAMS.4.1v1

Not met **Teams external access is limited to allowed domains** E3 L2 CIS 8.2.1

External access is open to all external domains.

How to meet it: Set external access to allow only specific external domains, or turn it off.

Mapped controls: MS.TEAMS.2.1v2 Related checks: COL-05 (Manual check)

Not met **Chat with unmanaged Teams users is off** E3 L1 CIS 8.2.2

Users can communicate with unmanaged Teams accounts.

How to meet it: Turn off People in my organisation can communicate with unmanaged Teams accounts.

Mapped controls: MS.TEAMS.2.3v2

Not met **Trial-only Teams tenants are blocked** E3 L1 CIS 8.2.4

Trial-only tenants: Allowed.

How to meet it: Set external access with trial-only tenants to Blocked.

Check manually **Teams app installation is controlled** E3 L1 CIS 8.4.1

Global app permission policy: Microsoft apps BlockedAppList, third-party apps BlockedAppList, custom apps BlockedAppList. Confirm only approved apps are allowed.

How to meet it: In Teams apps, Manage apps, Org-wide app settings and permission policies, allow only approved Microsoft, third-party and custom apps.

Mapped controls: MS.TEAMS.5.1v2; MS.TEAMS.5.2v2; MS.TEAMS.5.3v2

Not met **Anonymous users cannot join meetings** E3 L2 CIS 8.5.1

Global policy: AllowAnonymousUsersToJoinMeeting = True.

How to meet it: Turn off Anonymous users can join a meeting in the Global meeting policy.

Related checks: COL-05 (Manual check)

1 affected item (listed in the HTML report and BenchmarkDetails.csv)

Not met **Anonymous users cannot use meeting chat** E3 L2 CIS 8.5.5

Global policy: MeetingChatEnabledType = Enabled.

How to meet it: Set meeting chat to On for everyone but anonymous users, or more restrictive.

1 affected item (listed in the HTML report and BenchmarkDetails.csv)

Not met **Only organisers and co-organisers present** E3 L2 CIS 8.5.6

Global policy: DesignatedPresenterRoleMode = EveryoneUserOverride.

How to meet it: Set Who can present to Only organisers and co-organisers.

1 affected item (listed in the HTML report and BenchmarkDetails.csv)

Not met **Meeting chat with untrusted organisations is off** E3 L2 CIS 8.5.8

Global policy: AllowExternalNonTrustedMeetingChat = True.

How to meet it: Turn off External meeting chat with untrusted organisations.

1 affected item (listed in the HTML report and BenchmarkDetails.csv)

Not met **Meeting recording is off by default** E3 L2 CIS 8.5.9

Global policy: AllowCloudRecording = True.

How to meet it: Turn off meeting recording in the Global policy and allow it through a separate policy for users who need it.

Mapped controls: MS.TEAMS.1.6v1

1 affected item (listed in the HTML report and BenchmarkDetails.csv)

Not met **Users can report security concerns in Teams** E5 L1 CIS 8.6.1

ReportJunk not sent to a mailbox; ReportNotJunk not sent to a mailbox; ReportPhish not sent to a mailbox; no reporting mailbox.

How to meet it: Turn on security reporting in the Teams messaging policy and send user reported messages to a monitored mailbox in Defender.

Related checks: EXO-18 (Pass) Needs: Defender for Office 365

CIS v7.0.0: Microsoft Fabric (Power BI)

Not met **Publish to web is restricted** E3 L1 CIS 9.1.4

Users can create new Publish to web embed codes.

How to meet it: Turn off Publish to web, or allow only existing embed codes for specific security groups.

Mapped controls: MS.POWERBI.1.1v1

Not met **R and Python visuals are off** E3 L2 CIS 9.1.5

'Interact with and share R and Python visuals' is turned on for the whole organisation.

How to meet it: Turn off Interact with and share R and Python visuals.

Mapped controls: MS.POWERBI.6.1v1

Not met **Users can apply sensitivity labels in Fabric** E3 L1 CIS 9.1.6

'Allow users to apply sensitivity labels for content' is turned off.

How to meet it: Turn on Allow users to apply sensitivity labels for content.

Mapped controls: MS.POWERBI.7.1v1

Not met **Organisation-wide shareable links are restricted** E3 L1 CIS 9.1.7

'Allow shareable links to grant access to everyone in your organization' is turned on for the whole organisation.

How to meet it: Turn off Allow shareable links to grant access to everyone in your organisation, or limit it to security groups.

Not met **External data sharing is restricted** E3 L1 CIS 9.1.8

'Allow guest users to work with shared semantic models in their own tenants' is turned on for the whole organisation.

How to meet it: Turn off External data sharing, or limit it to security groups.

Not met **ResourceKey authentication is blocked** E3 L1 CIS 9.1.9

'Block ResourceKey Authentication' is turned off.

How to meet it: Turn on Block ResourceKey Authentication.

Mapped controls: MS.POWERBI.5.1v1

CISA SCuBA: Microsoft Entra ID

Not met **Legacy authentication is blocked** Shall SCuBA MS.AAD.1.1v1

No enabled Conditional Access policy blocks legacy authentication for all users. Report-only policies that would meet it once switched on: CA002 Block legacy authentication.

How to meet it: Create a Conditional Access policy for all users and all resources that blocks Exchange ActiveSync and other legacy clients.

Mapped controls: CIS 5.2.2.3 Related checks: IAM-02 (Warning)

Not met **Phishing-resistant MFA for all users** Shall SCuBA MS.AAD.3.1v1

No enabled Conditional Access policy requires phishing-resistant MFA for all users.

How to meet it: Require the phishing-resistant MFA authentication strength (passkeys, Windows Hello or certificates) for all users and all resources.

Mapped controls: CIS 5.2.2.2 Related checks: IAM-04 (Warning)

Not met **Authenticator shows sign-in context** Shall SCuBA MS.AAD.3.3v2

Not shown to all users: location.

How to meet it: Where Microsoft Authenticator is enabled, show the application name and location in notifications for all users.

Mapped controls: CIS 5.2.3.1

Not met **SMS, voice and email OTP are off** Shall SCuBA MS.AAD.3.5v2

Still enabled: Sms, Email.

How to meet it: Disable SMS, voice call and email one-time passcode in the authentication methods policy.

Mapped controls: CIS 5.2.3.5; CIS 5.2.3.7 Related checks: IAM-07 (Warning)

Not met **Phishing-resistant MFA for highly privileged roles** Shall SCuBA MS.AAD.3.6v1

No enabled Conditional Access policy requires phishing-resistant MFA for every highly privileged role.

How to meet it: Require phishing-resistant MFA for Global, Privileged Role, User, SharePoint, Exchange, Hybrid Identity, Application and Cloud Application Administrators.

Mapped controls: CIS 5.2.2.1; CIS 5.2.2.5 Related checks: IAM-04 (Warning)

Not met **Managed devices are required** Should SCuBA MS.AAD.3.7v1

No enabled Conditional Access policy requires a compliant or hybrid joined device for all users.

How to meet it: Require a compliant or hybrid joined device for all users and all resources.

Mapped controls: CIS 5.2.2.9 Related checks: IAM-11 (Warning)

Not met **Managed devices are required to register MFA** Should SCuBA MS.AAD.3.8v1

No enabled Conditional Access policy requires a managed device to register security information.

How to meet it: Require a compliant or hybrid joined device for the Register security information user action.

Mapped controls: CIS 5.2.2.10

Not met **Device code sign-in is blocked** Should SCuBA MS.AAD.3.9v1

No enabled Conditional Access policy blocks the device code flow for all users.

How to meet it: Block the device code flow for all users and all resources with Conditional Access.

Mapped controls: CIS 5.2.2.12

Check manually **Security logs go to a security operations centre** Shall SCuBA MS.AAD.4.1v1

This control cannot be read through an API. Check it by hand using the guidance.

How to meet it: Send Entra sign-in and audit logs to the SIEM or SOC through diagnostic settings, Sentinel or a log forwarder.

Not met **Only administrators register applications** Shall SCuBA MS.AAD.5.1v1

Users can register applications.

How to meet it: Set Users can register applications to No.

Mapped controls: CIS 5.1.2.2 Related checks: IAM-15 (Warning)

Not met **User consent to applications is restricted** Shall SCuBA MS.AAD.5.2v1

User consent is allowed: Allow user consent for apps (legacy setting).

How to meet it: Do not allow user consent, or allow it only for verified publishers and low-impact permissions you have classified.

Mapped controls: CIS 5.1.5.1 Related checks: IAM-13 (Fail)

Not met **An admin consent workflow is configured** Shall SCuBA MS.AAD.5.3v1

The admin consent workflow is off.

How to meet it: Turn on the admin consent request workflow and name reviewers.

Mapped controls: CIS 5.1.5.2 Related checks: IAM-14 (Warning)

Not met **Apps cannot add password credentials** Should SCuBA MS.AAD.5.5v1

New client secrets blocked: not enforced for applications; not enforced for service principals.

How to meet it: Enable the tenant app management policy restriction that blocks new client secrets.

Mapped controls: CIS 5.1.5.3

Not met **App secrets last 180 days or less** Should SCuBA MS.AAD.5.6v1

Client secret lifetime limit: 365 days allowed for applications; not enforced for service principals.

How to meet it: Limit client secret lifetime to 180 days or less in the tenant app management policy.

Mapped controls: CIS 5.1.5.4

Not met **App certificates last a year or less** Should SCuBA MS.AAD.5.7v1

Certificate lifetime limit: not enforced for applications; not enforced for service principals.

How to meet it: Limit certificate credential lifetime to 365 days or less in the tenant app management policy.

Mapped controls: CIS 5.1.5.6

Not met **Passwords do not expire** Shall SCuBA MS.AAD.6.1v1

Passwords expire on 1 domain.

How to meet it: Set passwords to never expire.

Mapped controls: CIS 1.3.1 Related checks: IAM-19 (Warning)

1 affected item (listed in the HTML report and BenchmarkDetails.csv)

Not met **Narrower roles are used instead of Global Administrator** Shall SCuBA MS.AAD.7.2v1

5 Global Administrators to 1 user in other highly privileged roles (ratio 5).

How to meet it: Give administrators the least privileged role they need so there are no more Global Administrators than holders of other highly privileged roles.

Related checks: PRV-01 (Fail)

Not met **Privileged users are cloud-only** Shall SCuBA MS.AAD.7.3v1

1 of 6 privileged users are synchronised from on-premises.

How to meet it: Use cloud-only accounts for every highly privileged role.

Mapped controls: CIS 1.1.1 Related checks: PRV-03 (Warning)

1 affected item (listed in the HTML report and BenchmarkDetails.csv)

Not met **Only Guest Inviters can invite guests** Should SCuBA MS.AAD.8.2v1

Invitations: adminsGuestInvitersAndAllMembers.

How to meet it: Set guest invite restrictions so only admins and users in the Guest Inviter role can invite.

Mapped controls: CIS 5.1.6.3 Related checks: IAM-16 (Warning)

Not met **Guest invitations go only to approved domains** Should SCuBA MS.AAD.8.3v1

Invitations are not limited to an allow list of domains.

How to meet it: Allow invitations only to specified domains approved for business collaboration.

Mapped controls: CIS 5.1.6.1

Check manually **Risky AI agents are blocked** Shall SCuBA MS.AAD.9.1v1

This control cannot be read through an API. Check it by hand using the guidance.

How to meet it: Block agent identities flagged as risky by Entra ID Protection with a Conditional Access policy for agents.

CISA SCuBA: Defender and Purview

Not met **Sensitive accounts have impersonation protection** Should SCuBA MS.SECURITYSUITE.2.1v1

No applied anti-phishing policy protects named users from impersonation.

How to meet it: Add executives and other sensitive accounts to user impersonation protection in an applied anti-phishing policy.

Mapped controls: CIS 2.1.7 Related checks: EXO-09 (Warning) Needs: Defender for Office 365

Not met **Owned domains have impersonation protection** Should SCuBA MS.SECURITYSUITE.2.2v1

No applied anti-phishing policy protects the organisation's domains from impersonation.

How to meet it: Turn on domain impersonation protection for the organisation's own domains.

Mapped controls: CIS 2.1.7 Related checks: EXO-09 (Warning) Needs: Defender for Office 365

Not met **Partner domains have impersonation protection** Should SCuBA MS.SECURITYSUITE.2.3v1

No partner domains are listed for impersonation protection.

How to meet it: Add key suppliers' and partners' domains to domain impersonation protection.

Needs: Defender for Office 365

Not met **Impersonation safety tips are shown** Should SCuBA MS.SECURITYSUITE.2.4v1

Impersonation safety tips are not all on in any applied policy.

How to meet it: Turn on user, domain and unusual character impersonation safety tips.

Mapped controls: CIS 2.1.7 Needs: Defender for Office 365

Not met **DLP blocks sharing of card numbers and identifiers** Shall SCuBA MS.SECURITYSUITE.3.1v1

No enforced DLP rule blocks credit card numbers.

How to meet it: Enforce a DLP policy that blocks credit card numbers and the national identifiers the organisation holds. SCuBA names US SSN and ITIN; UK clients should use National Insurance and passport numbers.

Mapped controls: CIS 3.2.1 Related checks: PUR-01 (Warning) Needs: Data loss prevention

Not met **DLP covers mail, files, Teams and devices** Should SCuBA MS.SECURITYSUITE.3.2v1

No enforced DLP policy covers: Exchange, SharePoint, OneDrive, Teams, Devices.

How to meet it: Make sure enforced DLP policies cover Exchange, OneDrive, SharePoint, Teams chat and devices.

Mapped controls: CIS 3.2.1; CIS 3.2.2 Related checks: PUR-01 (Warning) Needs: Data loss prevention

Not met **DLP blocks sharing sensitive data with everyone** Should SCuBA MS.SECURITYSUITE.3.3v1

No enforced DLP rule blocks access.

How to meet it: Set DLP rule actions to block access for everyone when sensitive information is detected.

Needs: Data loss prevention

Not met **DLP notifies users** Should SCuBA MS.SECURITYSUITE.3.4v1

No enforced DLP rule notifies users.

How to meet it: Turn on user notifications and policy tips in DLP rules.

Needs: Data loss prevention

Not met **Required alert policies are on** Shall SCuBA MS.SECURITYSUITE.4.1v1

Missing or disabled: Suspicious Connector Activity, Tenant restricted from sending unprovisioned email, Tenant restricted from sending email, A potentially malicious URL click was detected.

How to meet it: Make sure the default alert policies for suspicious sending, connectors, forwarding, delayed and restricted mail and malicious URL clicks are enabled.

Related checks: PUR-04 (Warning)

Check manually **Alerts reach a monitored mailbox or SIEM** Should SCuBA

MS.SECURITYSUITE.4.2v1

Recipients: Suspicious email sending patterns detected -> TenantAdmins, Suspicious Email Forwarding Activity -> TenantAdmins, A potentially malicious URL click was detected -> none. Confirm these are monitored or that alerts reach the SIEM.

How to meet it: Send the required alerts to a monitored mailbox, or forward them to the SIEM.

Check manually **Audit logs are kept for 12 months** Shall SCuBA

MS.SECURITYSUITE.5.2v1

Audit (Premium) is not licensed, so standard retention is 180 days. Confirm logs are exported to a SIEM or log store for 12 months.

How to meet it: Keep audit logs searchable for 3 months and retrievable for 12, using Audit (Premium) retention policies or export to a SIEM or log store.

Not met **Anti-spam policies allow no sender domains** Shall SCuBA MS.SECURITYSUITE.6.2v1

Policies with allowed domains: Default.

How to meet it: Remove allowed sender domains from all inbound anti-spam policies.

Mapped controls: CIS 2.1.14 Related checks: EXO-08 (Warning)

Not met **Safe Links scans download links** Should SCuBA MS.SECURITYSUITE.7.2v1

No applied Safe Links policy scans URLs in real time.

How to meet it: Turn on real-time URL scanning for suspicious links and links to files.

Mapped controls: CIS 2.1.1 Needs: Defender for Office 365

Not met **Safe Links tracks user clicks** Should SCuBA MS.SECURITYSUITE.7.3v1

No applied Safe Links policy tracks clicks.

How to meet it: Turn on Track user clicks in Safe Links.

Mapped controls: CIS 2.1.1 Needs: Defender for Office 365

Not met **No IP allow lists** Should SCuBA MS.SECURITYSUITE.8.1v1

IP allow list entries: 203.0.113.10.

How to meet it: Remove all entries from the connection filter IP allow list.

Mapped controls: CIS 2.1.12

CISA SCuBA: Exchange Online

Not met — Automatic forwarding to external domains is off

Shall · SCuBA · MS.EXO.1.1v2

Remote domains allowing automatic forwarding: *.

How to meet it: Turn off automatic forwarding on the default remote domain and any others not explicitly approved.

Mapped controls: CIS 6.2.1 Related checks: EXO-05 (Pass)

1 affected item (listed in the HTML report and BenchmarkDetails.csv)

Not met — SPF fails unapproved senders

Shall · SCuBA · MS.EXO.2.2v3

2 of 3 domains lack a compliant SPF record.

How to meet it: Publish an SPF record for every domain ending in -all, ~all or a redirect to a record that does.

Mapped controls: CIS 2.1.8 Related checks: DNS-01 (Fail)

2 affected items (listed in the HTML report and BenchmarkDetails.csv)

Not met — DKIM is on for all domains

Should · SCuBA · MS.EXO.3.1v1

DKIM is off for: lettingsportal.example.

How to meet it: Enable DKIM signing for every custom domain.

Mapped controls: CIS 2.1.9 Related checks: DNS-02 (Fail)

Not met — DMARC is published for every domain

Shall · SCuBA · MS.EXO.4.1v1

No DMARC record for: lettingsportal.example, fabrikam-parked.example.

How to meet it: Publish a DMARC record for every second-level domain.

Mapped controls: CIS 2.1.10 Related checks: DNS-03 (Fail)

Not met — DMARC policy is reject

Shall · SCuBA · MS.EXO.4.2v1

Not at p=reject: fabrikam.example, lettingsportal.example, fabrikam-parked.example.

How to meet it: Move every DMARC record to p=reject once legitimate senders pass SPF or DKIM.

Mapped controls: CIS 2.1.10 Related checks: DNS-03 (Fail)

Not met — DMARC reports go to the organisation

Should · SCuBA · MS.EXO.4.4v1

Missing rua or ruf: fabrikam.example, lettingsportal.example, fabrikam-parked.example.

How to meet it: Add an organisation contact for both aggregate (rua) and failure (ruf) reports.

Mapped controls: CIS 2.1.10 Related checks: DNS-04 (Pass)

Not met — SMTP AUTH is off

Shall · SCuBA · MS.EXO.5.1v1

SMTP AUTH is on.

How to meet it: Turn off SMTP AUTH for the organisation.

Mapped controls: CIS 6.5.4 Related checks: EXO-04 (Fail)

Not met — Calendars are not shared with all domains

Shall · SCuBA · MS.EXO.6.2v1

Policies sharing calendars with all domains: Default Sharing Policy (Anonymous:CalendarSharingFreeBusyReviewer, *:CalendarSharingFreeBusySimple).

How to meet it: Remove calendar sharing for all domains (*) and anonymous users from sharing policies.

Mapped controls: CIS 1.3.3 Related checks: EXO-14 (Warning)

Not met **External senders are flagged** Shall SCuBA MS.EXO.7.1v1

External senders are not flagged.

How to meet it: Turn on external sender tagging in Outlook, or add a mail flow rule that warns about external senders.

Mapped controls: CIS 6.2.3 Related checks: EXO-13 (Warning)

CISA SCuBA: SharePoint and OneDrive

Not met **SharePoint sharing is existing guests or internal only** Shall SCuBA MS.SHAREPOINT.1.1v1

SharePoint sharing: Anyone.

How to meet it: Set SharePoint external sharing to Existing guests or Only people in your organisation.

Mapped controls: CIS 7.2.3 Related checks: SPO-01 (Warning)

Not met **OneDrive sharing is existing guests or internal only** Shall SCuBA MS.SHAREPOINT.1.2v1

OneDrive sharing: Anyone.

How to meet it: Set OneDrive external sharing to Existing guests or Only people in your organisation.

Mapped controls: CIS 7.2.4

Not met **External sharing is limited to approved domains** Shall SCuBA MS.SHAREPOINT.1.3v1

External sharing is not limited to an allow list of domains.

How to meet it: Limit external sharing to an allow list of approved domains, or to approved security groups.

Mapped controls: CIS 7.2.6 Related checks: SPO-05 (Info)

Not met **Default sharing scope is specific people** Shall SCuBA MS.SHAREPOINT.2.1v1

Default link: Anyone.

How to meet it: Set the default link type to Specific people.

Mapped controls: CIS 7.2.7

Not met **Default link permission is view** Shall SCuBA MS.SHAREPOINT.2.2v1

Default permission is not View.

How to meet it: Set the default link permission to View.

Mapped controls: CIS 7.2.11

Not met **Anyone links expire within 30 days** Shall SCuBA MS.SHAREPOINT.3.1v1

Anyone links never expire.

How to meet it: Where Anyone links are allowed, make them expire within 30 days.

Not met **Anyone links are view only** Shall SCuBA MS.SHAREPOINT.3.2v1

Anyone link permissions: files edit, folders edit.

How to meet it: Where Anyone links are allowed, set file and folder link permissions to View.

Not met **Verification code users re-authenticate within 30 days** Shall SCuBA MS.SHAREPOINT.3.3v2

Re-authentication is not required.

How to meet it: Require people who use a verification code to re-authenticate after 30 days or less.

Mapped controls: CIS 7.2.10

CISA SCuBA: Microsoft Teams

Not met **External participants cannot request control** Should SCuBA MS.TEAMS.1.1v1

1 of 2 policies do not meet this: Tag:Exec (AllowExternalParticipantGiveRequestControl = True).

How to meet it: Turn off giving or requesting control for external participants in all meeting policies.

Mapped controls: CIS 8.5.7

1 affected item (listed in the HTML report and BenchmarkDetails.csv)

Not met **Dial-in users cannot bypass the lobby** Should SCuBA MS.TEAMS.1.5v1

1 of 2 policies do not meet this: Tag:Exec (AllowPSTNUsersToBypassLobby = True).

How to meet it: Turn off dial-in lobby bypass in all meeting policies.

Mapped controls: CIS 8.5.4

1 affected item (listed in the HTML report and BenchmarkDetails.csv)

Not met **Meeting recording is off** Should SCuBA MS.TEAMS.1.6v1

Global policy: AllowCloudRecording = True.

How to meet it: Turn off cloud recording in the Global meeting policy.

Mapped controls: CIS 8.5.9

1 affected item (listed in the HTML report and BenchmarkDetails.csv)

Not met **External access is per domain only** Shall SCuBA MS.TEAMS.2.1v2

External access is open to all domains.

How to meet it: Allow external access only for specific domains, or turn it off.

Mapped controls: CIS 8.2.1 Related checks: COL-05 (Manual check)

Not met **Staff cannot contact unmanaged users** Should SCuBA MS.TEAMS.2.3v2

Staff can communicate with unmanaged Teams accounts.

How to meet it: Turn off communication with unmanaged Teams accounts.

Mapped controls: CIS 8.2.2

Not met **Teams email integration is off** Shall SCuBA MS.TEAMS.4.1v1

Channel email is on.

How to meet it: Turn off sending email to channel addresses.

Mapped controls: CIS 8.1.2

Not met **Only approved Microsoft apps can be installed** Should SCuBA MS.TEAMS.5.1v2

Global policy: DefaultCatalogAppsType = BlockedAppList.

How to meet it: Allow only approved Microsoft apps in org-wide app settings or app permission policies.

Mapped controls: CIS 8.4.1

1 affected item (listed in the HTML report and BenchmarkDetails.csv)

Not met **Only approved third-party apps can be installed** Should SCuBA MS.TEAMS.5.2v2

Global policy: GlobalCatalogAppsType = BlockedAppList.

How to meet it: Allow only approved third-party apps in org-wide app settings or app permission policies.

Mapped controls: CIS 8.4.1

1 affected item (listed in the HTML report and BenchmarkDetails.csv)

Not met **Only approved custom apps can be installed** Should SCuBA MS.TEAMS.5.3v2

Global policy: PrivateCatalogAppsType = BlockedAppList.

How to meet it: Allow only approved custom apps in org-wide app settings or app permission policies.

Mapped controls: CIS 8.4.1

1 affected item (listed in the HTML report and BenchmarkDetails.csv)

CISA SCuBA: Power BI

Not met **Publish to web is off** Should SCuBA MS.POWERBI.1.1v1

'Publish to web' is turned on for the whole organisation.

How to meet it: Turn off Publish to web unless there is a business need.

Mapped controls: CIS 9.1.4

Not met **Inviting external users is off** Should SCuBA MS.POWERBI.3.1v1

'Users can invite guest users to collaborate through item sharing and permissions' is turned on for Fabric guest inviters.

How to meet it: Turn off inviting external users through Power BI sharing unless there is a business need.

Mapped controls: CIS 9.1.2

Not met **ResourceKey authentication is blocked** Should SCuBA MS.POWERBI.5.1v1

'Block ResourceKey Authentication' is turned off.

How to meet it: Turn on Block ResourceKey Authentication unless streaming or push datasets need it.

Mapped controls: CIS 9.1.9

Not met **R and Python visuals are off** Should SCuBA MS.POWERBI.6.1v1

'Interact with and share R and Python visuals' is turned on for the whole organisation.

How to meet it: Turn off R and Python visuals.

Mapped controls: CIS 9.1.5

Not met **Sensitivity labels are used in Power BI** Should SCuBA MS.POWERBI.7.1v1

'Allow users to apply sensitivity labels for content' is turned off.

How to meet it: Let users apply sensitivity labels to Power BI content.

Mapped controls: CIS 9.1.6

CISA SCuBA: Power Platform

Not met **Only admins create production and sandbox environments** Shall SCuBA MS.POWERPLATFORM.1.1v1

Anyone can create production and sandbox environments.

How to meet it: In the Power Platform admin centre, restrict creating production and sandbox environments to admins.

Not met **Every other environment has a DLP policy** Should SCuBA MS.POWERPLATFORM.2.2v1

1 environment has no DLP policy: Lettings Apps.

How to meet it: Apply at least one DLP policy to every non-default environment.

1 affected item (listed in the HTML report and BenchmarkDetails.csv)

Not met **Tenant isolation is on** Shall SCuBA MS.POWERPLATFORM.3.1v1

Tenant isolation is off.

How to meet it: Turn on Power Platform tenant isolation and allow only approved partner tenants.

Check manually **Inbound and outbound connections use an allow list** Should SCuBA

MS.POWERPLATFORM.3.2v1

This control cannot be read through an API. Check it by hand using the guidance.

How to meet it: Add an allow list of inbound and outbound tenant connections in the tenant isolation settings.

Check manually **Content Security Policy is enforced** Shall SCuBA

MS.POWERPLATFORM.4.1v1

This control cannot be read through an API. Check it by hand using the guidance.

How to meet it: Turn on and enforce Content Security Policy for model-driven and canvas apps in each environment's privacy and security settings.

Not met **Only admins create Power Pages sites** Should SCuBA MS.POWERPLATFORM.5.1v1

Anyone can create Power Pages sites.

How to meet it: Restrict creating Power Pages sites to admins.

Not met **Share with everyone is off** Should SCuBA MS.POWERPLATFORM.6.1v1

Makers can share apps with everyone.

How to meet it: Turn off sharing canvas apps with everyone.

CIS Microsoft 365 Foundations Benchmark is published by the Center for Internet Security. The SCuBA baselines are published by CISA. Control numbers are used for reference; this report does not reproduce either benchmark.

7. Azure

Azure was read through Azure Resource Manager, Azure Resource Graph, Defender for Cloud and Azure Advisor with the review account's own Azure roles. Only subscriptions where that account has a role are visible, so confirm with Fabrikam Lettings Ltd that nothing is missing. Some settings could not be read in Fabrikam Dev; the related checks say so.

26%
Azure score
9 fail, 18 warning, 0 pass

2
Subscriptions
1 CSP, 1 Pay as you go

4
Virtual machines
3 running; 2 Arc servers

55%
Secure score
Defender for Cloud, average

65.4%
MCSB controls passed
70 passed, 37 failed

£3,610
Possible savings
A year, from Azure Advisor

Subscriptions

Subscription	Offer	State	Resources	Secure score
Fabrikam Dev	Pay as you go	Enabled	3	62%
Fabrikam Production	CSP	Enabled	15	48%

Azure findings

Status	Check	Current state
Fail	Microsoft Defender for Cloud protects servers and data services AZ-02	3 Defender plans are not on for resources in use, including Defender for Servers in 1 subscription. The plans in Fabrikam Dev could not be read (the account needs Security Reader or Reader there).
Fail	Management ports are not open to the internet AZ-06	1 rule in use allows management or database ports from the internet.
Fail	No retired Basic SKU public IPs or load balancers AZ-09	1 public IP address still uses the retired Basic SKU.
Fail	Virtual machines are backed up AZ-10	2 of 4 virtual machines are not protected by Azure Backup, and 1 more has not backed up recently.
Fail	Servers run a supported operating system AZ-12	3 servers are out of support. 1 more server is on extended security updates or loses support within six months.
Fail	Azure servers are onboarded to Defender for Endpoint AZ-13	2 of 3 running servers are not onboarded to Defender for Endpoint.
Fail	Storage accounts block public access and require TLS 1.2 AZ-15	1 of 2 storage accounts allows anonymous access, HTTP or old TLS.
Fail	Subscription owners are limited and not guests AZ-19	4 privileged role assignments at subscription or management group level (2 to users directly, 1 to service principals, 1 to guests).

Status	Check	Current state
Fail	App Service apps enforce HTTPS and TLS 1.2 AZ-18	1 of 1 apps allows HTTP, old TLS or plain FTP.
Warning	Defender for Cloud secure score AZ-03	Secure score: Fabrikam Production 48%, Fabrikam Dev 62%.
Warning	Microsoft cloud security benchmark compliance AZ-04	65.4% of assessed MCSB controls pass (70 passed, 37 failed across 2 subscriptions).
Warning	Virtual machines do not have public IP addresses AZ-07	1 of 4 virtual machines has a public IP address. There is no Azure Bastion host.
Warning	Subnets are protected by network security groups AZ-08	2 of 3 workload subnets have no network security group.
Warning	Backup vaults are protected against deletion and ransomware AZ-11	1 of 1 vaults lacks soft delete or immutability.
Warning	Key vaults have purge protection and restricted network access AZ-16	1 of 1 key vaults has gaps.
Warning	The Azure activity log is kept beyond 90 days AZ-21	1 subscription does not export the activity log, so changes are only kept for 90 days.
Warning	High-impact Azure Advisor recommendations AZ-24	1 high-impact recommendation (1 reliability).
Warning	Servers have no outstanding critical or security updates AZ-28	1 of 2 assessed servers is missing critical or security updates.
Warning	Azure Arc servers are connected AZ-29	1 of 2 Arc servers is not connected.
Warning	Defender for Cloud alert emails reach the right people AZ-05	1 subscription has no working security alert email.
Warning	Virtual machines use Trusted Launch AZ-14	2 of 4 virtual machines do not use Trusted Launch.
Warning	Critical resources have delete locks AZ-20	1 of 2 vaults has no delete lock.
Warning	No unattached disks or unused public IP addresses AZ-22	1 managed disk (128 GB) and 1 public IP address are not attached to anything.
Warning	Azure Advisor cost recommendations AZ-23	2 cost recommendations with potential savings of about GBP 3,610 a year.
Warning	Every subscription has a budget alert AZ-25	1 subscription has no budget.
Warning	The Microsoft cloud security benchmark policy is assigned AZ-26	1 subscription does not have the Microsoft cloud security benchmark initiative assigned.
Warning	Network Watcher is enabled where networks exist AZ-27	Network Watcher is missing in 1 region.

Status	Check	Current state
Info	Azure SQL servers use Entra authentication, TLS 1.2 and private access AZ-17	No Azure SQL servers were found.
Info	Azure subscriptions in scope AZ-01	2 subscriptions are visible (1 CSP, 1 Pay as you go). Some settings could not be read in Fabrikam Dev, because the account's role there does not allow it.

Virtual machines

VM	Operating system	Power	Backed up	Defender for Endpoint	Public IP
FAB-APP01	Windows Server 2022	running	No	No	Yes
FAB-DC01	Windows Server 2016 (support ends 12/01/2027)	running	Yes	Yes	No
FAB-SQL01	Windows Server 2012 R2 (out of support)	running	Yes	No	No
fab-web-lnx	Ubuntu 20.04 (out of support)	deallocated	No	No	No

The full Azure detail is in the Inventory tab: subscriptions, virtual machines, inbound internet rules, storage accounts, role assignments, Defender for Cloud recommendations, Azure Advisor and resources by type.

8. Servers

Server data was collected read-only by the collector on each server (locally, through the RMM or over WinRM), and from vCenter or ESXi for VMware. The hardening baseline is drawn from CIS Windows Server Level 1 and the Microsoft security baseline. 6 systems were imported, the oldest collected on 16/10/2026.

14%
Server score
20 fail, 7 warning, 1 pass

6
Systems
1 Linux, 5 Windows

2
Out of support
Operating system or hypervisor

2
Without EDR
Servers with no EDR detected

50%
Baseline met
Windows hardening, average

Servers

Server	Operating system	Roles	Last update	EDR	Backup	Baseline
fab-web01	Ubuntu 20.04 Out of support		07/08/2026	None	None detected	
FAB-APP01	Windows Server 2016 Ends 12/01/2027	SQL Server	08/09/2026	Microsoft Defender for Endpoint	None detected	31.2%
FAB-DC01	Windows Server 2019	Domain controller, DHCP, DNS	04/10/2026	Microsoft Defender for Endpoint	None detected	64.5%
FAB-DC02	Windows Server 2022	Domain controller, DNS	04/10/2026	Microsoft Defender for Endpoint	None detected	77.4%
FAB-FS01	Windows Server 2012 R2 Out of support		20/06/2026	None	Windows Server Backup (last success 07/10/2026)	31.2%
FAB-HV01	Windows Server 2022	Hyper-V host, DHCP	04/10/2026	Microsoft Defender for Endpoint	Veeam Backup & Replication	45.5%

Windows hardening baseline

Setting	Source	FAB-APP01	FAB-DC01	FAB-DC02	FAB-FS01	FAB-HV01
SMBv1 is disabled	CIS L1, MS baseline	Met	Met	Met	Not met	Met

Setting	Source	FAB-APP01	FAB-DC01	FAB-DC02	FAB-FS01	FAB-HV01
SMB server signing is required	CIS L1, MS baseline	Not met	Met	Met	Not met	Met
SMB client signing is required	CIS L1	Not met	Not met	Not met	Not met	Not met
Only NTLMv2 is accepted (LAN Manager level 5)	CIS L1, MS baseline	Not met	Met	Met	Not met	Met
LM hashes are not stored	CIS L1, MS baseline	Met	Met	Met	Met	Met
WDigest does not keep passwords in memory	MS baseline	Met	Met	Met	Met	Met
LSA protection is on	MS baseline	Not met	Met	Met	Not met	Not met
Anonymous enumeration of accounts and shares is blocked	CIS L1	Not met	Not met	Not met	Not met	Not met
LLMNR is turned off	CIS L1	Not met	Met	Met	Not met	Met
NetBIOS over TCP/IP is disabled	Hardening	Not met	Not met	Not met	Not met	Not met
User Account Control is on	CIS L1, MS baseline	Met	Met	Met	Met	Met
UAC restrictions apply to local accounts over the network	MS baseline	Met	Met	Met	Met	Met
AutoPlay is off for all drives	CIS L1	Not met	Met	Met	Not met	Not met
PowerShell 2.0 is removed	MS baseline	Not met	Not met	Met	Not met	Not met
PowerShell script block logging is on	CIS L1	Not met	Met	Met	Not met	Not met
Process creation events include the command line	CIS L1	Not met	Not met	Not met	Not met	Not met
Remote Desktop requires Network Level Authentication	CIS L1, MS baseline	Not met	Met	Met	Met	Met
Remote Desktop encryption is set to High	CIS L1	Not met	Not met	Not met	Not met	Not met
TLS 1.0 is disabled for incoming connections	MS guidance	Not met	Not met	Met	Not met	Not met
TLS 1.1 is disabled for incoming connections	MS guidance	Not met	Not met	Met	Not met	Not met
.NET applications use strong cryptography	MS guidance	Not met	Not met	Met	Not met	Not met
Windows Firewall is on for every profile	CIS L1, MS baseline	Met	Met	Met	Met	Met
Windows Firewall blocks inbound by default	CIS L1, MS baseline	Met	Met	Met	Met	Met

Setting	Source	FAB-APP01	FAB-DC01	FAB-DC02	FAB-FS01	FAB-HV01
Windows Firewall logs dropped packets	CIS L1	Not met	Not met	Not met	Not met	Not met
Security event log is at least 192 MB	CIS L1	Not met	Met	Met	Not met	Not met
Credential Guard is running	MS baseline	Not met	n/a	n/a	Not met	Not met
No more than four cached logons	CIS L1	Not met	Not met	Not met	Not met	Not met
Secure Boot is on	MS baseline	n/a	n/a	n/a	n/a	Met
Credential validation is audited	CIS L1, MS baseline	Not met	Met	Met	Not met	Not met
Logons are audited	CIS L1, MS baseline	Met	Met	Met	Met	Met
Process creation is audited	CIS L1, MS baseline	Not met	Met	Met	Not met	Not met
Security group changes are audited	CIS L1, MS baseline	Met	Met	Met	Met	Met
Audit policy changes are audited	CIS L1, MS baseline	Met	Met	Met	Met	Met

Server findings

Status	Check	Current state
Fail	Privileged AD groups are small and protected AD-02	Domain Admins is too large (7 members; two to four is recommended).
Fail	No accounts open to Kerberos and delegation attacks AD-03	2 high-risk account settings found (3 more to review).
Fail	Domain password and lockout policy is strong AD-04	The domain password or lockout policy is weak: minimum length 8, no account lockout, history 12.
Fail	Domain controllers are hardened AD-07	Both domain controllers need hardening.
Fail	Linux servers run a supported release and are patched LNX-01	The only Linux server is out of support or missing security updates.
Fail	Linux SSH and accounts are hardened LNX-02	The only Linux server allows risky SSH or account access.
Fail	Linux servers have EDR, a firewall and audit logging LNX-03	The only Linux server has no EDR.
Fail	Windows servers run a supported version SRV-01	1 of 5 Windows servers is out of support; 1 more loses support within six months.

Status	Check	Current state
Fail	Windows servers are patched and rebooted SRV-02	1 of 5 servers is missing security updates.
Fail	Windows servers have working EDR and antivirus SRV-03	1 of 5 servers has no EDR.
Fail	Remote management is not exposed or weakly protected SRV-04	1 of 5 servers allows weakly protected remote access.
Fail	SMBv1 is disabled and SMB signing is required SRV-05	SMBv1 is enabled on 1 server; signing is not required on 2 servers.
Fail	Local administrator accounts are managed SRV-07	1 of 3 member servers has unmanaged local administrator accounts.
Fail	Servers are backed up SRV-10	1 server has not completed a Windows Server Backup in the last two days.
Fail	No out-of-support server software SRV-12	4 items of out-of-support software were found.
Fail	Directory recovery and krbtgt hygiene AD-05	fabrikam.local: AD Recycle Bin off; krbtgt password 1461 days old; machine account quota 10; domain functional level Windows2012R2Domain.
Fail	Hyper-V virtual machines are healthy HV-01	2 virtual machines have old checkpoints, replication or cluster problems.
Fail	Windows servers meet the hardening baseline SRV-06	49.7% of baseline settings are met across 5 servers. 3 servers are below 60%.
Fail	Server volumes have free space SRV-09	1 volume is under 10% free.
Fail	Server time, certificates and stability SRV-13	2 of 5 servers have time, certificate or stability issues.
Warning	LAPS covers domain computers AD-08	LAPS covers 53.4% of computers in the weakest domain.
Warning	Stale and out-of-support accounts are cleaned up AD-06	14 stale users, 6 stale computers and 2 out-of-support computers found.
Warning	Hyper-V hosts are dedicated HV-02	The only Hyper-V host runs other roles.
Warning	Linux disk space, packages and kernel settings LNX-04	The only Linux server has settings to tighten.
Warning	Security logging and audit policy are in place SRV-08	3 of 5 servers have logging gaps.
Warning	Unnecessary and risky services are not running SRV-11	4 of 5 servers run unnecessary or risky services.
Warning	Physical servers encrypt their disks SRV-14	The only physical server does not have BitLocker on the system drive.
Info	Server data coverage SRV-15	6 systems imported from 8 files.

Status	Check	Current state
Pass	Active Directory replication and SYSVOL are healthy AD-01	Replication is healthy for fabrikam.local.

10. Method and limitations

Data was collected read-only through Microsoft Graph (including Defender XDR advanced hunting for the last 30 days), the Exchange Online management API and the Security & Compliance management API, plus the Teams, SharePoint, Fabric and Power Platform admin APIs where access was approved, using delegated access by engineer@reviewer.example. No settings were changed. DNS records were checked from public DNS. Each check compares the current configuration with Microsoft guidance and Contoso IT standards.

Azure was read through Azure Resource Manager, Azure Resource Graph, Defender for Cloud and Azure Advisor with the Azure roles of engineer@reviewer.example, after read access was approved at the start of the review. Only subscriptions where that account has a role are included (2 subscriptions).

Server data was collected separately with the Contoso IT server collectors (run on each Windows server as an administrator, through the RMM or over WinRM; a shell script on Linux; PowerCLI for VMware) and imported from 8 data files. Each server is compared with CIS Level 1 and Microsoft security baseline settings, supported versions, patching, protection and backup.

Licence utilisation compares the service plans in each user's assigned licences (excluding plans switched off on the licence) with configuration and 30-day usage reports. A feature shown as Not used is licensed but has no matching configuration or activity. Usage reports can lag by up to 48 hours.

169 of 180 collection steps succeeded. 0 failed and 11 were unavailable or skipped (often because a feature is not licensed). Checks that depend on missing data are shown as Not assessed. The Collection diagnostics inventory lists every step.

Not covered by automated checks

- Backup of Microsoft 365 data
- File and folder level permissions inside SharePoint sites and OneDrive (site membership is covered through groups and Teams)
- Defender for Cloud Apps policies and Defender portal advanced settings (licence use is flagged in Opportunities)
- Purview communication compliance, information barriers and records management file plans

Areas reviewed

Identity and access, Applications and consents, Licensing, Exchange Online and email security, Email DNS (SPF, DKIM, DMARC), SharePoint, OneDrive and Teams, Intune and devices, Microsoft Defender XDR, Microsoft Purview, Microsoft Secure Score, Licence utilisation opportunities, CIS v7 and CISA SCuBA benchmarks, Teams, SharePoint, Power BI and Power Platform settings, Mailbox permissions, Group, Team and site membership, Azure subscriptions and resources, Servers (imported server data)

Effort estimates assume the remediation is carried out by an experienced engineer with suitable admin access and exclude user communication, change control and testing with the client unless stated.